ISO/SAE 21434 Automotive Cybersecurity Certification

Road Vehicles – Cybersecurity Engineering



OMNEX

© 2022, Omnex, Inc.

315 Eisenhower Parkway Suite 214
Ann Arbor, Michigan 48108
USA
734-761-4940
Fax: 734-761-4966

Second Edition

June 2022

This publication is considered Omnex confidential information and is protected by Federal Copyright Law, with all rights reserved. No part of this publication may be stored in a retrieval system, transmitted or reproduced in any way, including but not limited to photocopy, photograph, magnetic or other record, without the prior agreement and written permission of the publisher.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Omnex provides training, consulting and software solutions to the international market with offices in the USA, Canada, Mexico, China (PRC), Germany, India, the Middle East, and SE Asia. Omnex offers over 400 standard and customized training courses in business, quality, environmental, cybersecurity, functional safety, food safety, laboratory and health & safety management systems worldwide.

Email: info@omnex.com

Web: www.omnex.com

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Course Objectives

- List and describe some automotive cybersecurity issues
- Determine the relevance of some automotive cybersecurity issues for specific products.
- Identify and describe some processes in your organization that might benefit from the ISO/SAE 21434 standard
- Identify and describe some products/projects in your organization that might benefit from the ISO/SAE 21434 standard
- Plan and perform cybersecurity management activities at the Organizational Level
- Plan and perform cybersecurity management activities at the Product/Project Level
- Perform an automotive TARA for a typical project
- Derive cybersecurity goals for a typical project
- Develop the Item Definition for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Course Objectives *(cont'd)*

- Develop the Cybersecurity Concept for a typical project
- Perform product development and cybersecurity validation activities for a typical project
- Perform activities of the Production, Operations and Maintenance, End of Cybersecurity Support and Decommissioning Phases for a typical project
- Perform a Plan for continual cybersecurity activities for a typical project
- Perform distributed cybersecurity activities for a typical project
- Develop a plan to Implement Automotive Cybersecurity for a typical project
- Develop a plan to Implement ISO21434 for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Course Agenda

Chapter 1: Overview of Automotive Cybersecurity and ISO/SAE 21434

- **Competency 01: Determine the Relevance of Automotive Cybersecurity for Specific Products**
- **Competency 02: Determine the Applicability of ISO/SAE 21434 in Your Organization and Current Products**

Breakout Exercise 1: Determine the Applicability of Automotive Cybersecurity and ISO/SAE 21434

Chapter 2: Cybersecurity Management (Clauses 5 & 6)

- **Competency 03: Plan and Perform Cybersecurity Management Activities**

Breakout Exercise 2: Define the Cybersecurity Case

Chapter 3: TARA and the Concept Phase (Clauses 15 & 9)

- **Competency 04: Perform Activities of the Concept Phase, including a Basic TARA**

Breakout Exercise 3: Create the Item Definition

Breakout Exercise 4: Perform a TARA

Breakout Exercise 5: Develop the Cybersecurity Goal, Cybersecurity Requirements, and Cybersecurity Concept

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Course Agenda

Chapter 4: Product Development Phases (Clauses 10 & 11)

- **Competency 05: Perform Activities of the Product Development Phases**

Breakout Exercise 6: Derive Flow-down of Hardware and Software Requirements

Chapter 5: Post-Development Phases (Clauses 12, 13 & 14)

- **Competency 06: List and Describe Applicable Activities of the Production, Operations & Maintenance, and Decommissioning Phases for a Typical Project**

Chapter 6: Continual Cybersecurity Activities (Clause 8)

- **Competency 07: Develop a Plan for Continual Cybersecurity Activities for a Typical Project**

Breakout Exercise 7: Develop Cybersecurity Plans (Continual Cybersecurity Activities and Incidence Response)

Chapter 7: Distributed Cybersecurity Activities (Clause 7)

- **Competency 08: Perform Distributed Cybersecurity Activities for a Typical Project**

Breakout Exercise 8: Develop a Cybersecurity Interface Agreement

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Course Agenda

Chapter 8: Implementing Automotive Cybersecurity

- Competency 9: Develop a Plan to Implement Automotive Cybersecurity

Chapter 9: ISO/SAE 21434 Implementation Strategy

- Competency 10: Develop a Plan to Implement ISO/SAE 21434 for a Typical Project

Glossary

Annex A: ISO/SAE 21434 Work Products

Annex B: Automotive Cybersecurity Controls

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

A BRIEF INTRODUCTION TO OMNEX



Omnex Introduction

- International consulting, training and software development organization founded in 1985.
- Specialties:
  - Integrated management system solutions.
  - Elevating the performance of client organizations.
  - Consulting and training services in:
    - Quality Management Systems, e.g., ISO 9001, IATF 16949, AS9100, QOS
    - Environmental Management Systems, e.g., ISO 14001
    - Health and Safety Management Systems, e.g., ISO 45001
- Leader in Lean, Six Sigma and other breakthrough systems and performance enhancement.
  - Provider of Lean Six Sigma services to Automotive Industry via AIAG alliance.

OMNEX – OET

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

About Omnex

- Headquartered in Ann Arbor, Michigan with offices in major global markets.
- In 1995-97 provided global roll out supplier training and development for Ford Motor Company.
- Trained more than 100,000 individuals in over 30 countries.
- Workforce of over 700 professionals, speaking over a dozen languages.
- Former Delegation Leader of the International Automotive Task Force (IATF) responsible for ISO/TS 16949.
- Served on committees that wrote QOS, ISO 9001, QS-9000, ISO/TS 16949 and its Semiconductor Supplement, and ISO IWA 1 (ISO 9000 for healthcare).
- Former member of AIAG manual writing committees for FMEA, SPC, MSA, Sub-tier Supplier Development, Error Proofing, and Effective Problem Solving (EPS).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Omnex Key Global Offices



AMERICAS
USA - Ann Arbor, MI, San Jose, CA
CANADA - Mississauga
MEXICO - Oaxaca
COLOMBIA - Bogota DC
BRAZIL - Sao Paulo

EUROPE
GERMANY - Berlin, Gosheim

EASTERN EUROPE
POLAND - Warsaw
ROMANIA - Bucharest
CZECH REPUBLIC - Prague
RUSSIA - Moscow

ASIA-PACIFIC
INDIA - Chennai (Asia Pac HQ), Pune, Delhi, Vadodara, Bangalore
CHINA - Shanghai (Far East HQ), Guangzhou, Wuhan, Chongqing, Suzhou
JAPAN - Tokyo
KOREA - Seoul
THAILAND - Bangkok
UAE - Dubai
SINGAPORE - Singapore
MALAYSIA - Kuala Lumpur (Rep)

International Headquarters | Regional Headquarters | Regional Offices | Delivery Associates

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Rules of the Classroom



- ✓ Start and end on time
- ✓ Return from breaks and lunch on time
- ✓ All questions welcome — Your input is valuable and is encouraged
- ✓ Don’t interrupt others — One meeting at a time
- ✓ Listen – and respect others’ ideas
- ✓ No “buts” – keep an open mind
- ✓ Phones in Do Not Disturb (silent) mode
- ✓ No e-mails, texting or tweeting during class
- ✓ If you are attending this course through the virtual classroom, your webcam must be on the entire time; microphones should be muted unless involved in discussion

If you must take a phone call or answer a text please notify the instructor by “Chat” and leave the session for as short a period as possible.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Icebreaker



- Instructor Information:
  - Name
  - Background
- Participant Introductions:
  - Name
  - Position / Responsibilities
  - What is your involvement in functional cybersecurity?
  - What are your experiences with functional cybersecurity?
  - *What do you expect to get out of this course?*
  - Please share something unique and/or interesting about yourself.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 1

Overview of Automotive Cybersecurity and ISO/SAE 21434



OMNEX

Chapter 1: Overview of Automotive Cybersecurity and ISO/SAE 21434 — What We Will Cover

Competency 01: Determine the Relevance of Automotive Cybersecurity for Specific Products

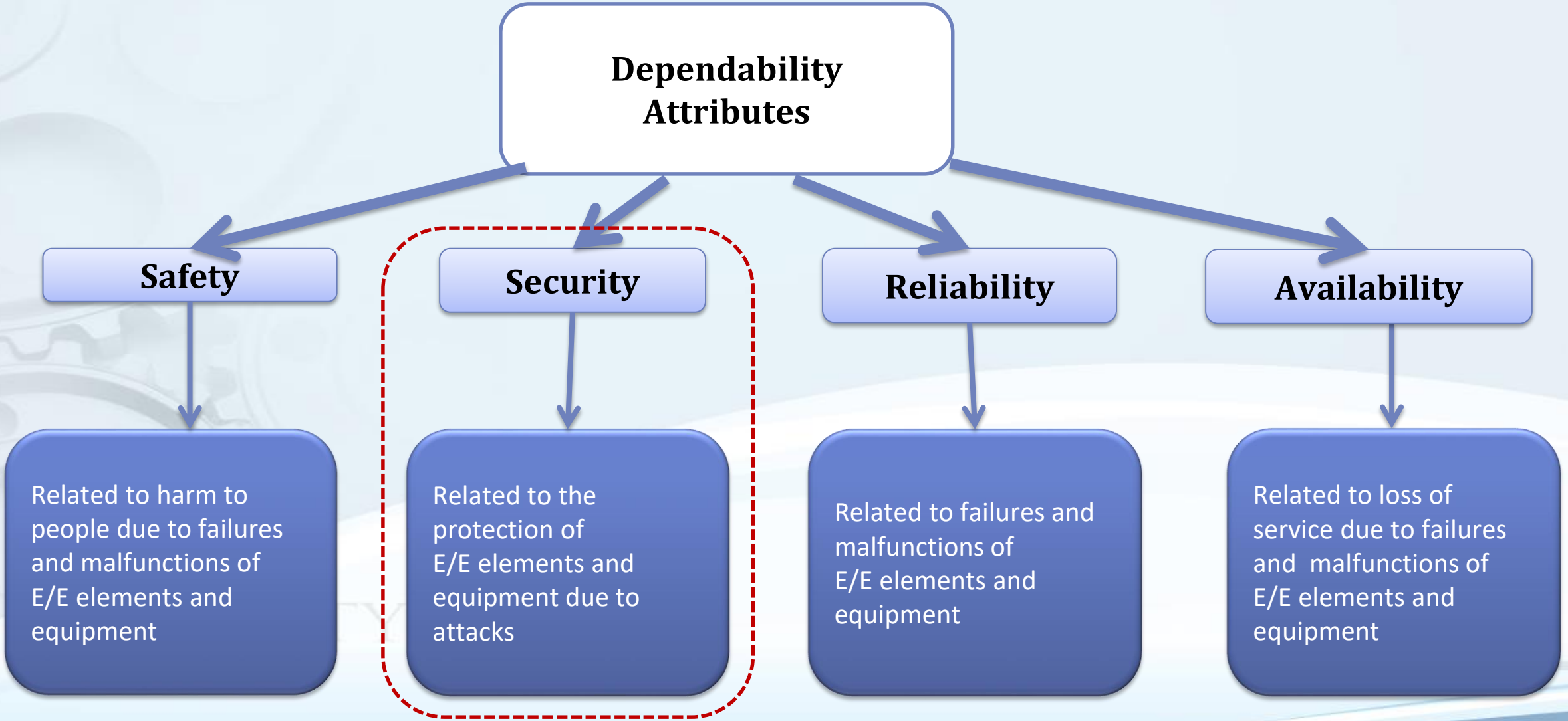
- Learning Objective 01: List and describe some automotive cybersecurity issues
- Learning Objective 02: Determine the relevance of some automotive cybersecurity issues for specific products

Competency 02: Determine the Applicability of ISO/SAE 21434 in Your Organization and Current Products

- Learning Objective 03: Identify and describe some processes in your organization that might benefit from ISO/SAE 21434
- Learning Objective 04: Identify and describe some products/projects in your organization that might benefit from ISO/SAE 21434
- ***Breakout Exercise 1: Determine the Applicability of Automotive Cybersecurity and ISO/SAE 21434***

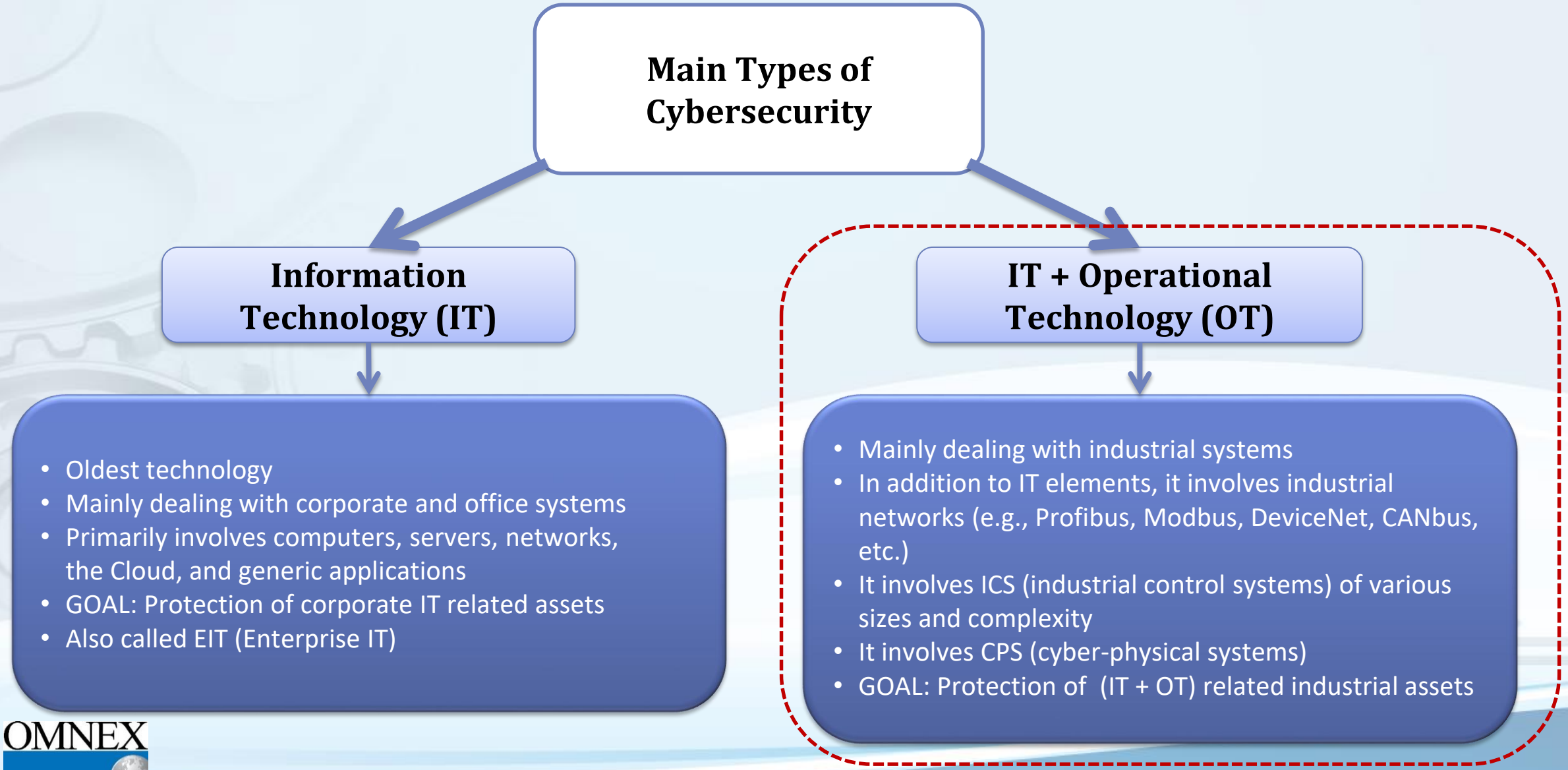
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Background of Cybersecurity



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Background of Cybersecurity

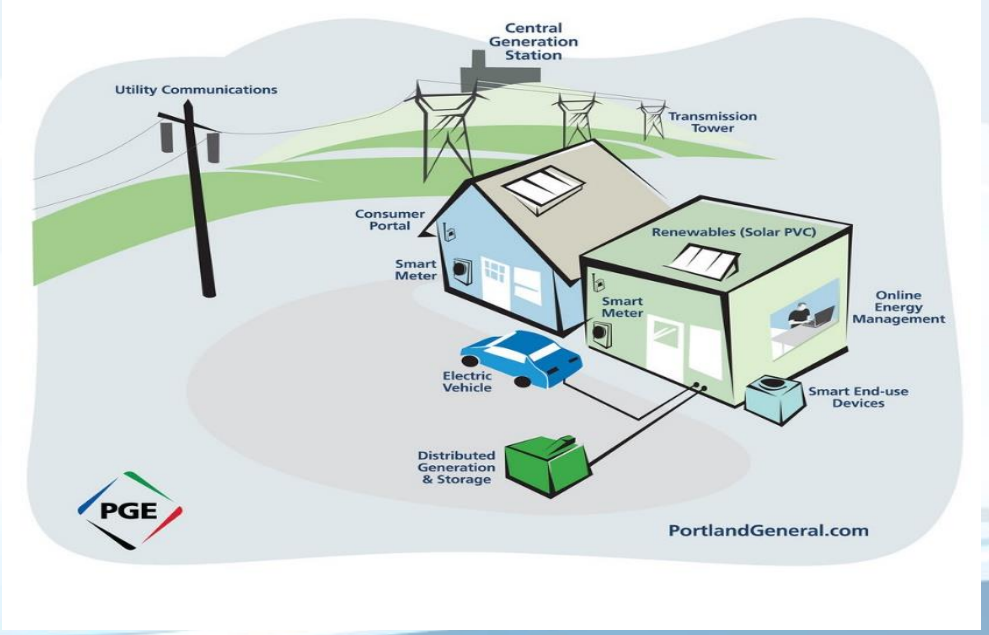


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(IT+OT) Systems: Smart Grid

- Involves the distribution of electrical power from power plants to customer premises.
- The monitoring and control of power distribution and protection devices is automated using sensors, actuators, and controllers.





Top figure: Power distribution station and EV (Electric Vehicle) charging stations.

Bottom figure: power distribution to customer premises.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(IT+OT) Systems: Process Control & ICS

- Involves flow and storage of process (or plant) goods (e.g., oil, gas, chemical, pulp, paper, etc.
- They are monitored and controlled by special process equipment
- Sensors: pressure, level, temperature O.m.n.ex OET
- Actuators: control valves

Figure below depicts three units of a 3-phase separator, separating crude into oil, gas, and water.

ICS: Industrial Control System

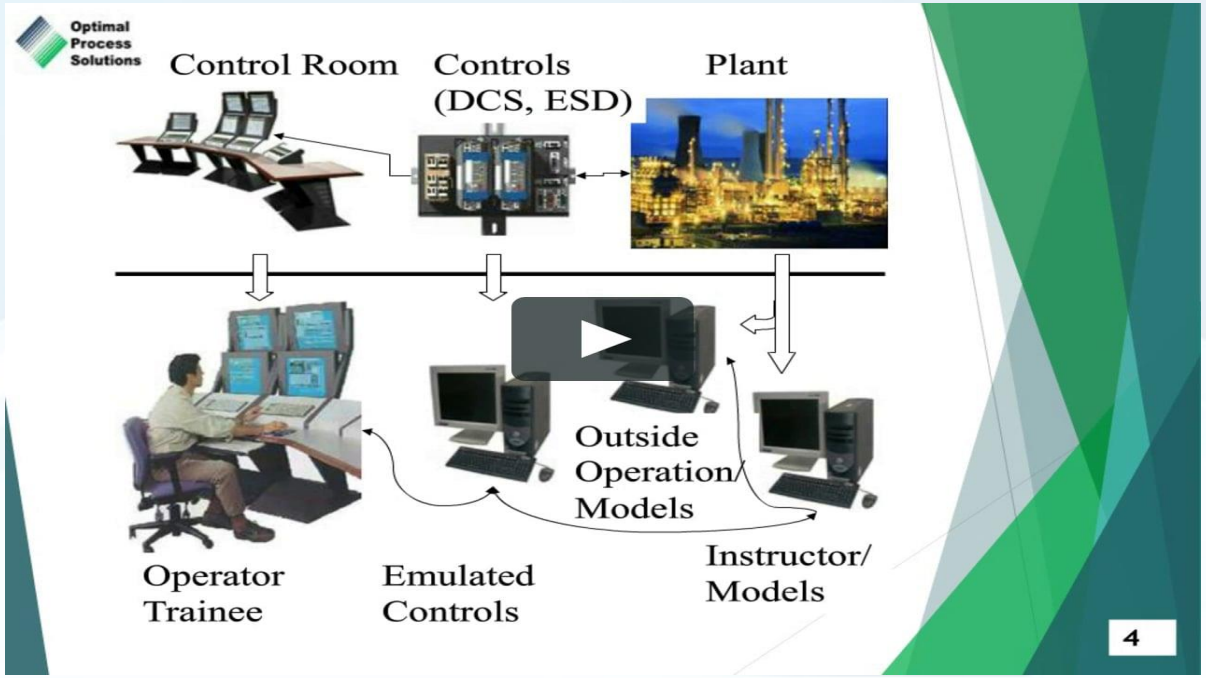


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(IT+OT) Systems: Process Control & ICS

- Controllers: OT systems involve specialized controllers such as:
  - SCADA (supervisory control & data acquisition)
  - DCS (distributed control system)
  - ICS (industrial control system)
  - ESD (emergency shutdown system)
  - PLC (programmable logic controllers)

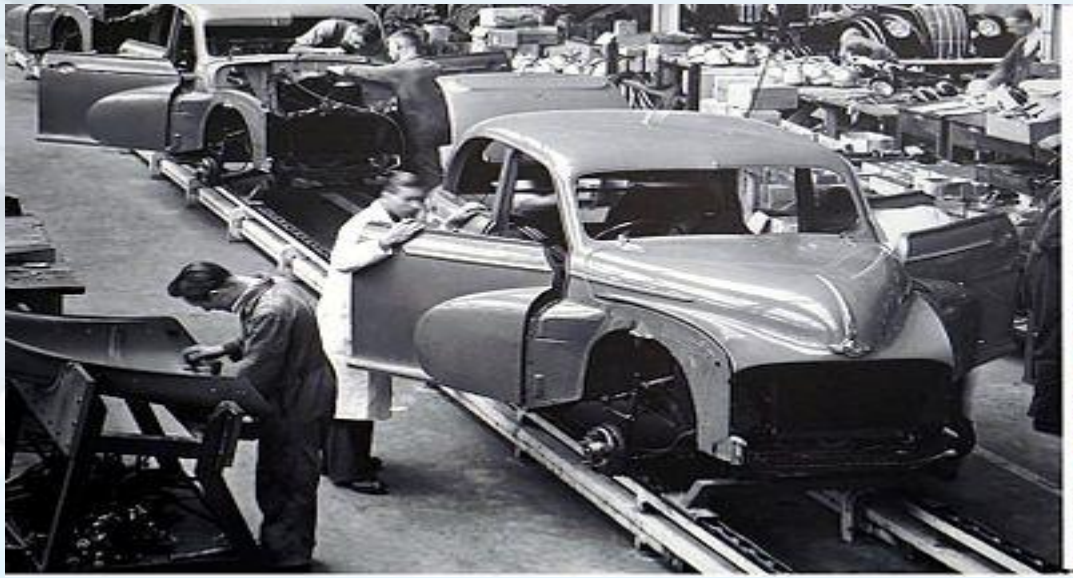
Figure depicts several components of an (IT+OT) system in the Oil & Gas industry.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(IT+OT) Systems: Manufacturing

- Involves assembling products from discrete components, e.g., a vehicle.
- The assembly could be:
  - Manual
  - Semi-automated
  - Fully automated: Robots, conveyors, ICS, SCADA, vision systems, PLC (programmable logic controllers) etc.

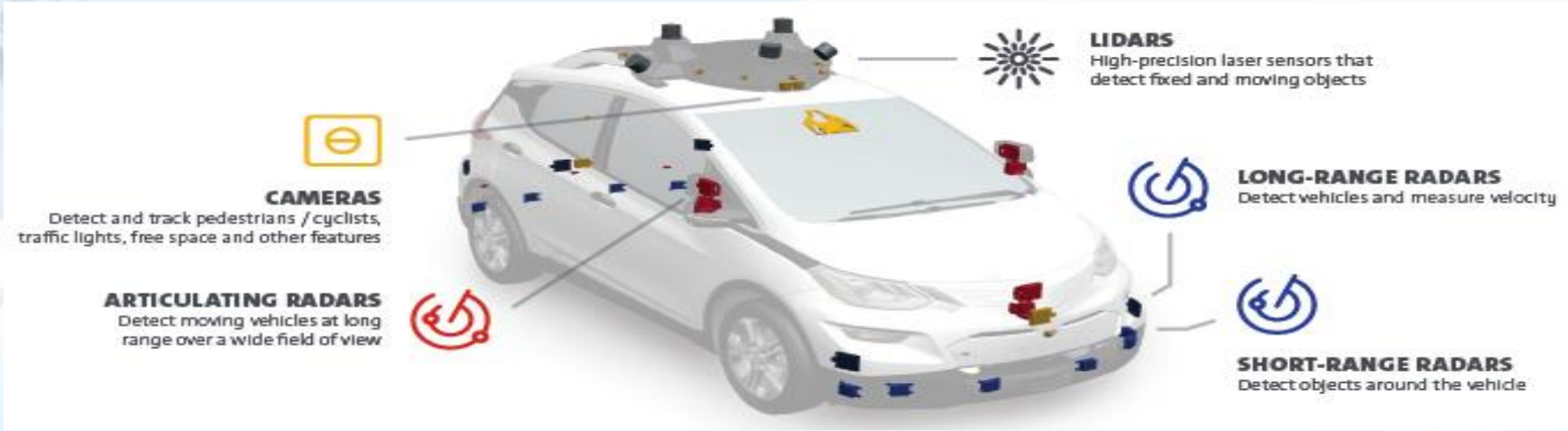




Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(IT+OT) Systems: Automotive

- Involves many sub-systems for proper vehicle operation:
  - Body
  - Powertrain
  - Chassis
  - Infotainment (Head Unit)
  - Safety-Critical subsystems (e.g., airbags)
- Relies on various technologies:
  - Embedded processors (ECUs, MCUs, etc.)
  - Sensors
  - Actuators
  - In-vehicle communications, protocols, and networks
  - Perception systems



Source: GM Safety Report, 2018

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Background of Cybersecurity

CONCEPT OF SAFETY

Protecting people from the world (vehicles, systems, plants, machines, etc.)

CONCEPT OF SECURITY

Protecting the world (assets, vehicles) from people (hackers, attackers, etc.)

DEFINITIONS

(ISO/SAE 21434) Road Vehicle Cybersecurity:

"Condition in which assets are sufficiently protected against threat scenarios to items of road vehicles, their functions and their electrical or electronic components"

(SAE J3061) Cybersecurity:

"Measures taken to protect a cyber-physical system against unauthorized access or attack. "





Top figure illustrates that accidents can be caused by cybersecurity attacks. Bottom figure shows a security team.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity: Risk-based Approach

- Cybersecurity is studied and practiced using a "***risk based approach.***"
- There is an initial risk that must be addressed using ***risk treatment*** methods. The system is then analyzed to determine its ***residual risk***.
- ISO/SAE 21434 provides methods to estimate risk levels for automotive cybersecurity. One important parameter in the risk estimation is "impact" of a successful cybersecurity attack.
- Main impact categories: **S,O,P,F**
  - **S:** Safety
  - **O:** Operational (related to availability)
  - **P:** Privacy (related to personal data)
  - **F:** Financial



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Main Past (IT + OT) Cybersecurity Attacks

- There have been many successful attacks to industrial plants or systems (IT + OT).
- Perhaps the most prominent IT+OT attacks are:
  - Stuxnet
  - Jeep Cherokee
- These were sophisticated attacks that required a high level of expertise and resources by the attackers.
- Nevertheless, they constitute examples that can be somewhat imitated by perpetrators requiring less expertise and resources in the future.
- The sophistication was due to complex attack paths used, which involved a combination of applications, controllers, industrial networks, communications (both wired and wireless), etc.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Attacks: Stuxnet

The world's first true remote cyberweapon.

- **Goal: "**Destroy" centrifuges used in the uranium enrichment process in a nuclear plant in Iran.
- **Tool:** Stuxnet — a worm using four zero-day vulnerabilities and infecting computer networks through USB flash drives.
- The worm identified specific SCADA controllers used in uranium enrichment and commanded the controllers to subject underlying electric motors (centrifuges) to a speed regime resulting in the failure (destruction) of these motors.

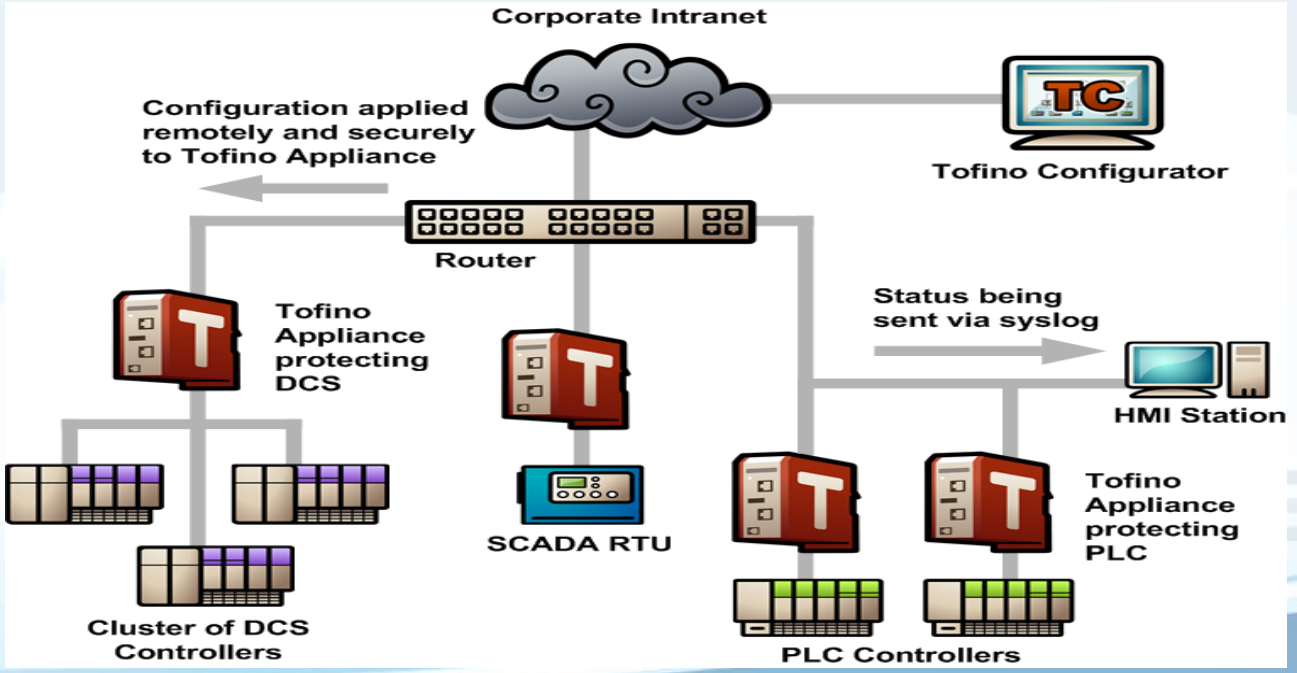


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Attacks: Stuxnet

- **Effects:** Physical damage to the centrifuges; modification or/and creation of cyberstrategies in the world; increase in awareness of cybersecurity issues.
- The figure below depicts the typical elements used in the Stuxnet attack, but it does not correspond to those in the actual attack.

PLC: Programmable Logic Controller
SCADA: Supervisory Control and Data Acquisition
RTU: Remote Transmission Unit
DCS: Distributed Control System
HMI: Man-Machine Interface



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Attacks: Jeep Cherokee

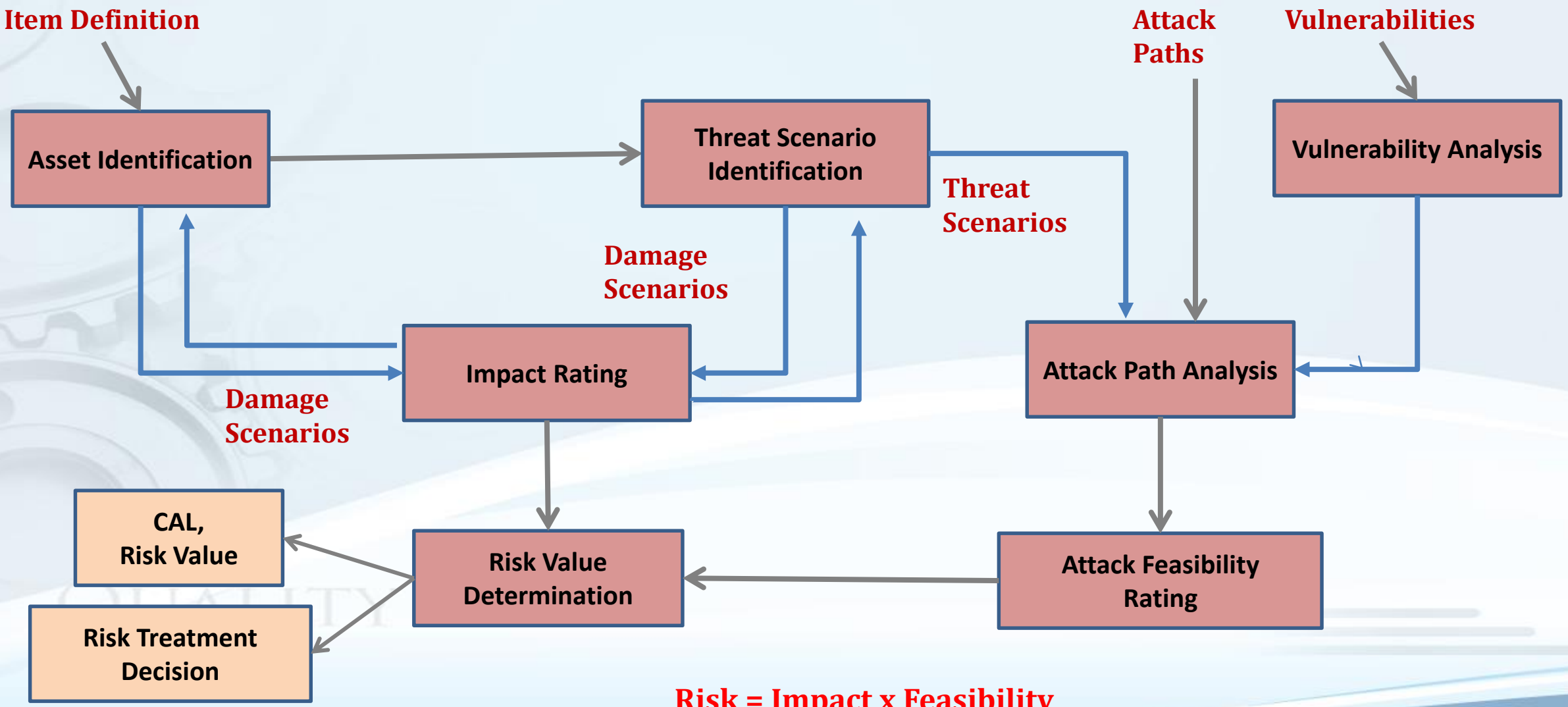
The world's first remote attack on a moving vehicle.

- **Goal:** Remotely take over the control of several vehicle functions, including powertrain and brakes.
- **Tool:** Zero-day exploit enabling wireless access to the head unit (Infotainment) of the entertainment system. From there, access is gained to the vehicle CAN bus network to issue commands to control the vehicle.
- **Effects:** Messed with the entertainment system, cut the transmission and disabled the powertrain.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

TARA (Threat Analysis & Risk Assessment) Structure



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity: Terminology and Concepts

- **Asset:** Object that has value, or contributes to value. An asset has one or more cybersecurity properties whose compromise can lead to one or more damage scenarios.
- **Vulnerability:** Weakness that can be exploited as part of an attack path.
- **Threat Scenario:** Potential cause of compromise of cybersecurity properties of one or more assets in order to realize a damage scenario.
- **Damage Scenario:** Adverse consequence involving a vehicle or vehicle function and affecting a road user.
- **Impact:** Estimate of magnitude of damage or physical harm from a damage scenario.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity: Terminology and Concepts

- **Attack:** Set of deliberate actions to realize a threat scenario.
- **Risk:** Effect of uncertainty on road vehicle cybersecurity expressed in terms of attack feasibility and impact.
  (**Older definition:** a combination of the impact and likelihood of an attack.)
- **CAL (Cybersecurity Assurance Level):** A specific set of 4 automotive risk levels: CAL1, CAL2, CAL3, and CAL4.
- **Risk Assessment:** Overall process of risk identification, risk analysis, and risk evaluation.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity: Terminology and Concepts

- **Risk Management:** Coordinated activities to direct and control an organization with regard to risk.
- **Risk Treatment**: Explicit mechanisms, measures, or **controls** that are implemented to reduce the current risk.
- **Cybersecurity Control:** Measure that is modifying risk.
- **Risk Treatment** options include (but are not limited to):
  - Risk modification
  - Risk sharing
  - Risk avoidance
  - Risk acceptance

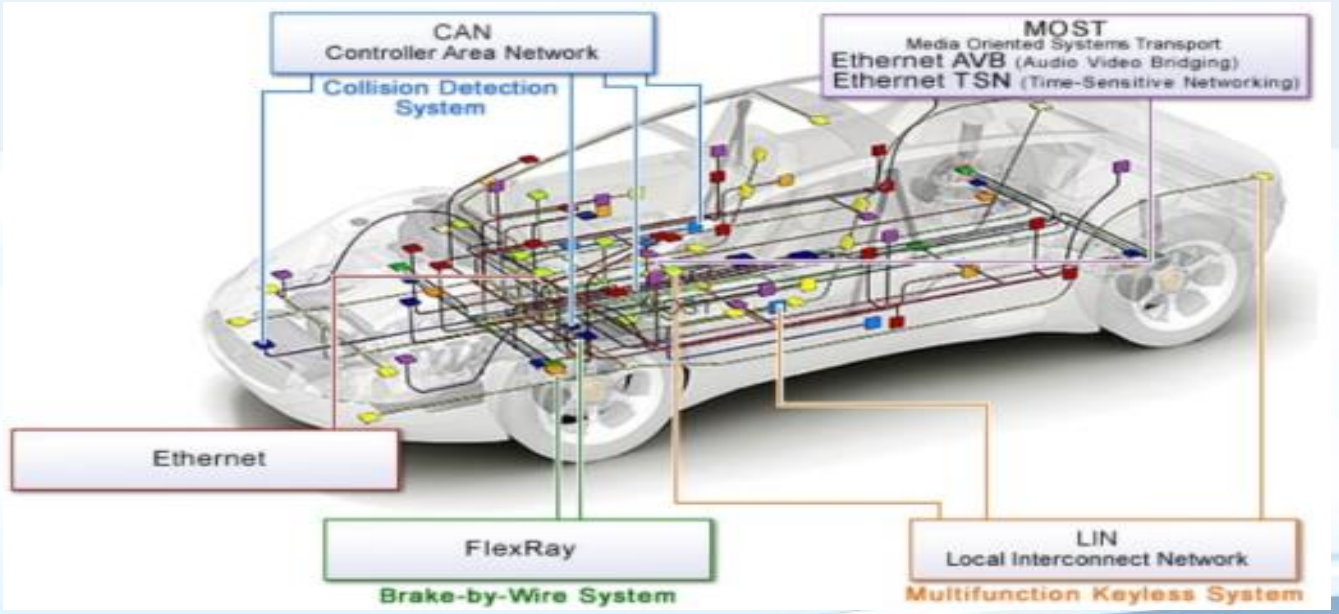
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Automotive Threats: Technologies

Threats are intimately related to the details of the technologies behind the assets to be protected.

For automotive, the main technologies are:

- Control units: ECU, MCU, PCU, ACU, etc.
- In-Vehicle networks: CAN,
  Automotive Ethernet
  (See figure)
- Sensors
- Wireless comm. and networks
- Infotainment sub-systems
- Telematic sub-systems
- Actuators



Source: Renesas

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Automotive Threats: Drive-by-Wire (DbW)

Vehicle driving functions (steering, braking, powertrain), can be controlled under:

- **Direct Control:** The driver manipulates the controls which are directly linked to the actuators.
- **Computer Control:** The driver manipulates the controls which are pre-processed by a computer before it goes to the actuators.
- **By-wire Control:** The driver manipulates the controls that are sent to computers for processing via a computer network before it goes to the actuators.

The primary network used is the CAN bus.

The driver can be a human or a robot (or computer).

The original CAN bus is inherently unsecure.
Modern CAN bus technologies include means to protect CAN messages from cyberattacks.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Future Threats and Vulnerabilities

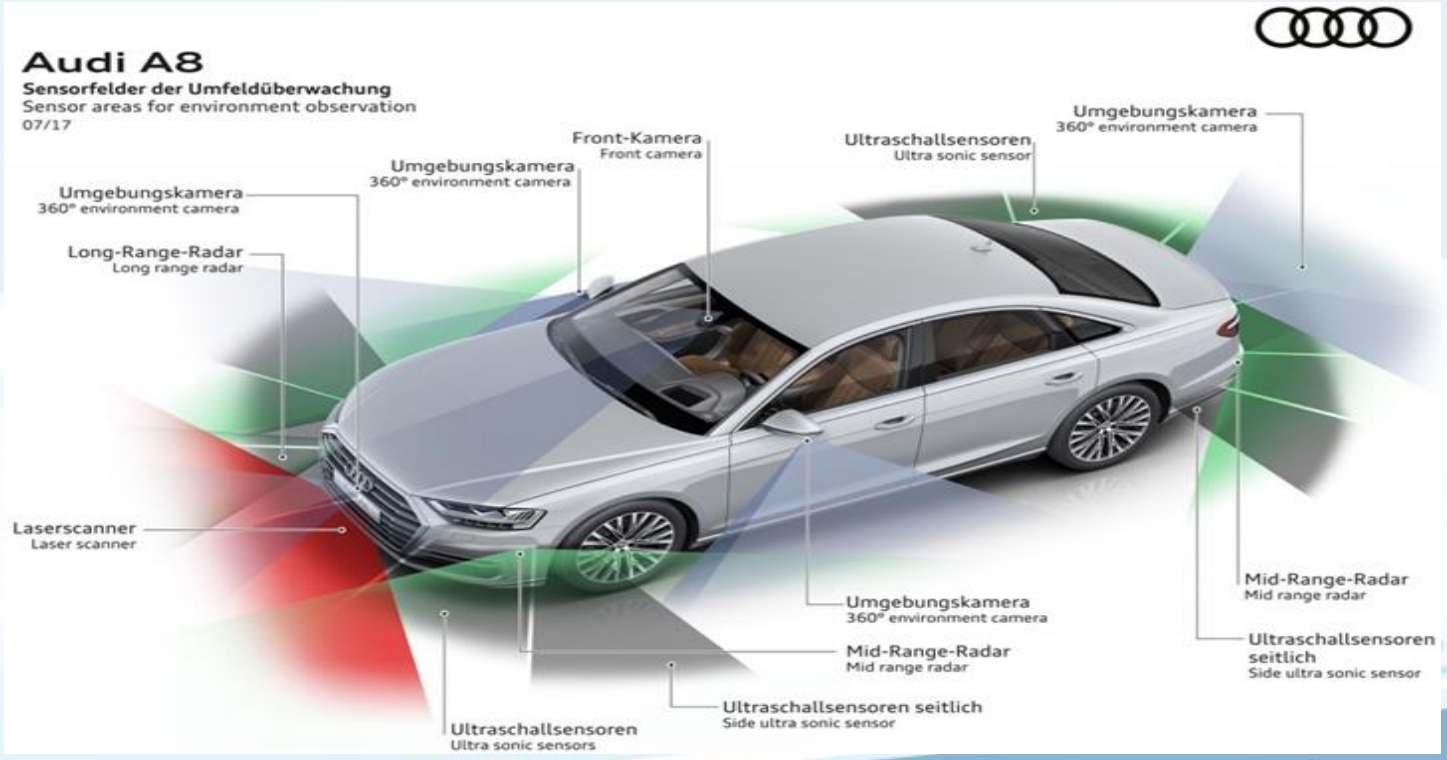
Automated Vehicles

- Radar sub-system: It is possible to send RF signals to mimic radar signals corresponding to rogue vehicles.

RF (radio frequency)

Threats

- Jamming
- Replay Attacks
- Evil-twin Attack
- Wardriving
- Sniffing



This figure displays possible attack surfaces.

Source: Audi

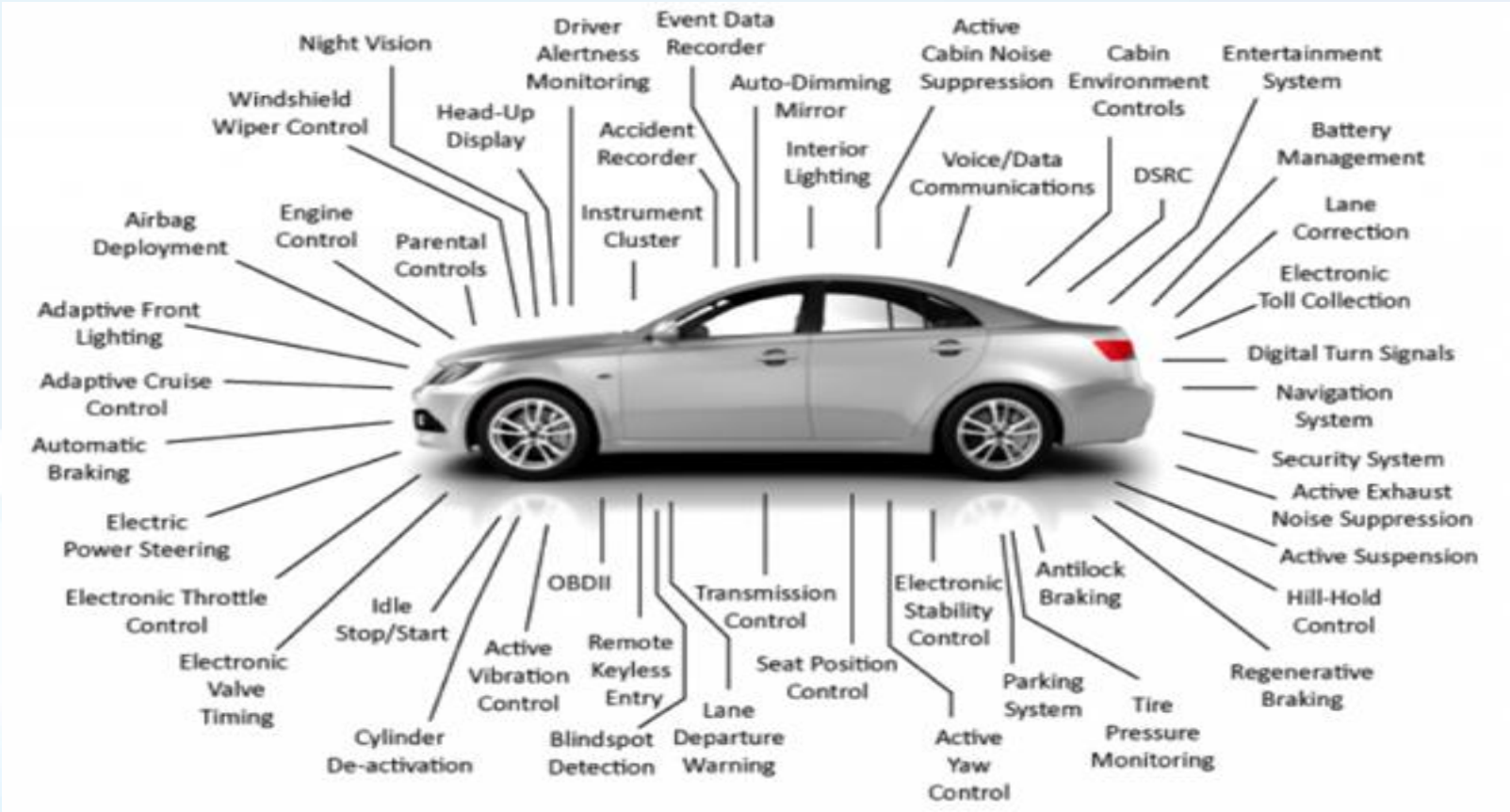
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Future Threats and Vulnerabilities

Internet of Radio (IoR) Vulnerabilities

These are a special type of vulnerabilities involving:

- Rogue cell towers
- Rogue Wi-Fi hotspot
- Vulnerable wireless devices
- Eavesdropping/surveillance devices
- Unapproved IoT emitters



This figure displays additional attack surfaces.

https://www.radiojitter.com/threat-modeling-for-automotive-part-2/

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434: Cybersecurity Management

Purpose of ISO/SAE 21434

- Cybersecurity is a key issue of automobile development.
- New functionalities and increasing content in electrical and electronics (E/E) and software requires increased focus on interface and interconnection issues.
- With the increase in technological complexity, software content and mechatronic implementations, there is an increase in vulnerabilities, threats, and attacks.

ISO/SAE 21434 provides a framework to enable Cybersecurity Management for E/E systems as well as other technologies.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Scope

The standard specifies engineering requirements for cybersecurity risk management regarding concept, product development, production, operation, maintenance and decommissioning of electrical and electronic (E/E) systems in road vehicles, including their components and interfaces.

- A framework is defined that includes requirements for cybersecurity processes and a common language for communicating and managing cybersecurity risk.
- ISO/SAE 21434 is applicable to series production road vehicle E/E systems, including their components and interfaces, whose development or modification began after the publication of ISO/SAE 21434.
- The document targets the "***inside vehicle perimeter.***"

However, ISO/SAE 21434 **does not prescribe** specific technology or solutions related to cybersecurity.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Framework

- Provides an automotive lifecycle that can be customized for your organization (**tailoring**).
- Provides an automotive-specific risk-based approach based on two measures of risk:
  a) **Cybersecurity Assurance Levels** (CAL) and
  b) **Risk Value**. O-M-N-E-X OET
  - The **Cybersecurity Assurance Levels** can be used to prioritize application of risk prevention techniques.
  - The **Risk Value** can be used to select cybersecurity controls.
- Provides requirements of validation and confirmation measures to ensure a sufficient and acceptable level of cybersecurity is being achieved.
- Provides requirements for supplier management / interface.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Structure: Main Clauses

5. Organizational Cybersecurity Management

6. Project-Dependent Cybersecurity Management

7. Distributed Cybersecurity Activities

8. Continual Cybersecurity Activities

9. Concept Phase

10, 11. Product Development Phase

- 10. Product Development
- 11. Cybersecurity Validation

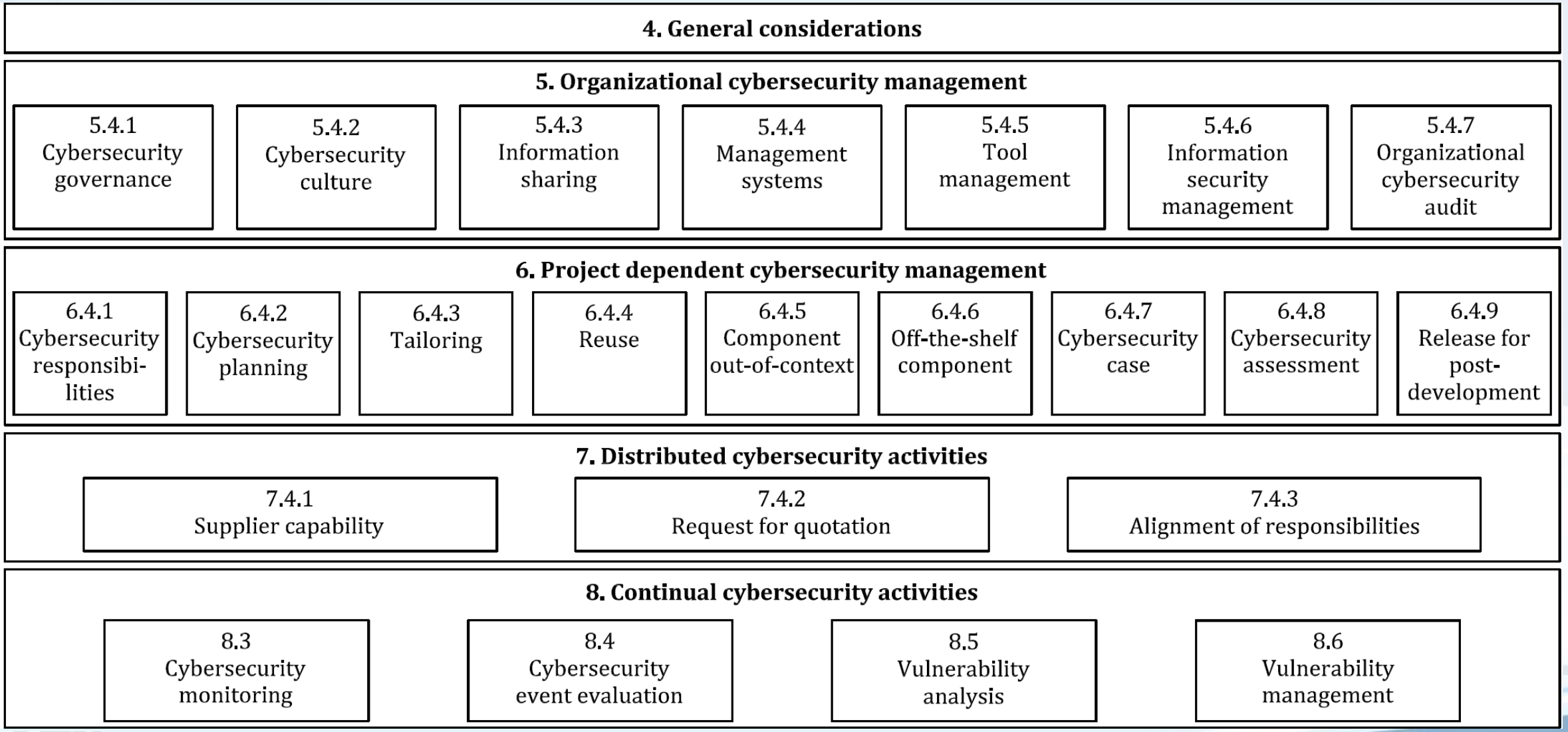
12, 13, 14. Post-Development Phases

15. Threat analysis and risk assessment methods

ISO/SAE 21434 does not use the V-Model for the product development phase.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

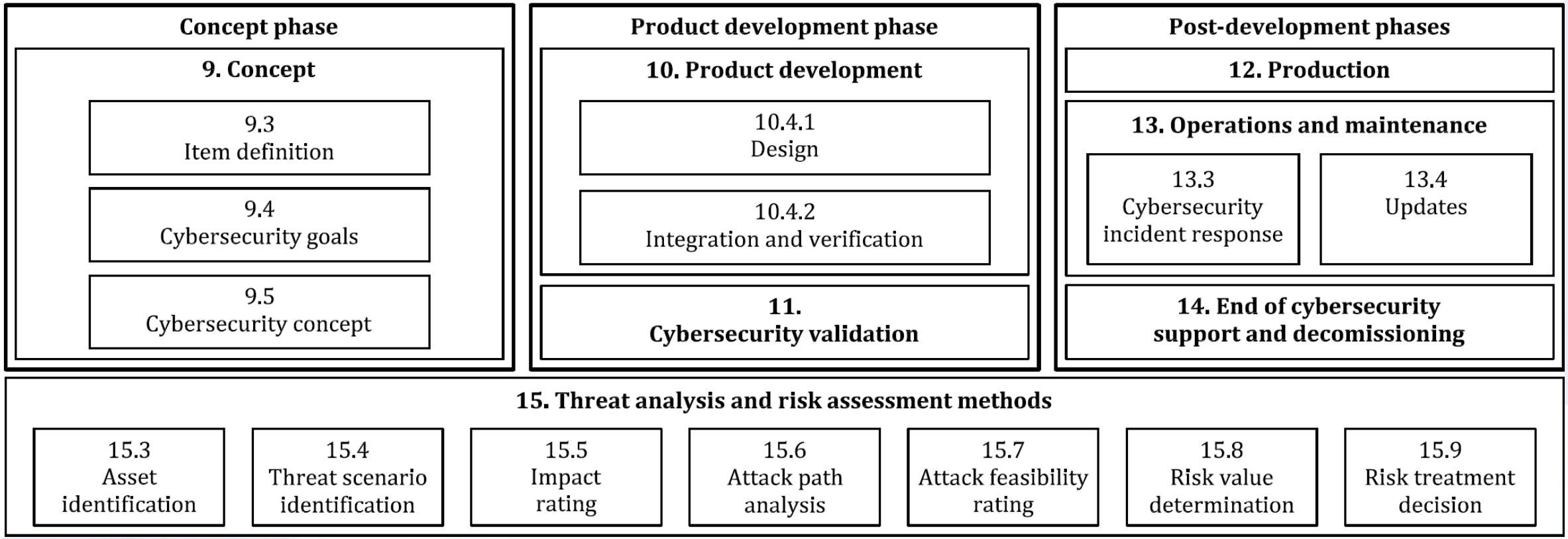
ISO/SAE 21434 Structure



source: ISO/SAE 21434, Figure 1

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

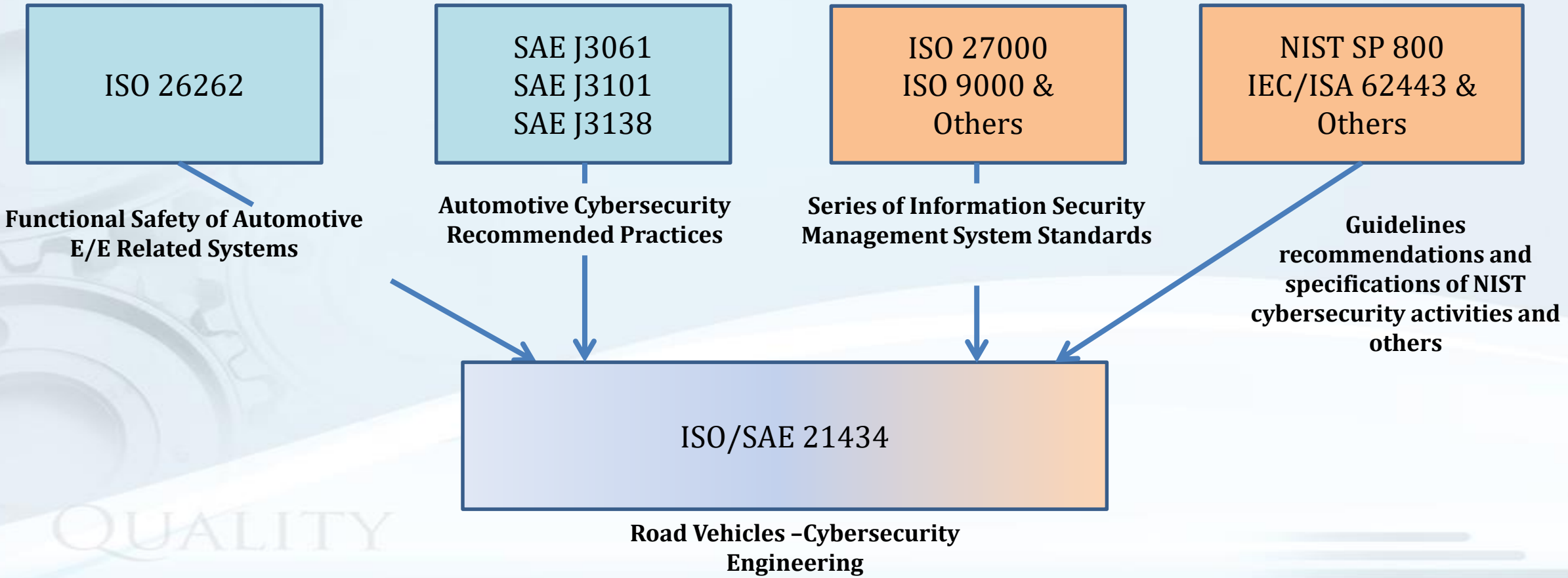
ISO/SAE 21434 Structure



source: ISO/SAE 21434, Figure 1

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Influences



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The Need for ISO/SAE 21434

Vehicle's E/E systems are complex and are growing rapidly

Platform Golf IV (1998)	Platform Golf V (2003)	Platform Golf VI (2010)
		
17 ECUs 2 CANs 147 CAN-Messages 434 CAN signals	Central Gateway 35 ECUs 5 CANs, 3 LINs 307 CAN-Messages 2669 CAN signals	Central Gateway 49 ECUs 5 CANs, 7 LINs 704 CAN-Messages 6516 CAN signals

Source: Lisa Whalen, *Making Products and Systems Functionally Safe*, 2012 CTi Conference on ISO 26262, Troy, MI

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The Need for ISO/SAE 21434

Complex Vehicle Software Size (lines of code)



F-22 Raptor
1.7 Million



F-35 Joint Strike Fighter
5.7 Million



Boeing 787 Dreamliner
6.5 Million
avionics and onboard support systems



2016 Ford GT
10 Million (mission critical)



2014 Mercedes S-Class
65 million lines of code



ADAS > 500 Million
(predicted future)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

General Requirements

First edition of ISO/SAE 21434 was published in Sept. 2021. Compliance is similar to that in the ISO 26262 series of standards. Each requirement shall be met, unless one of the following applies:

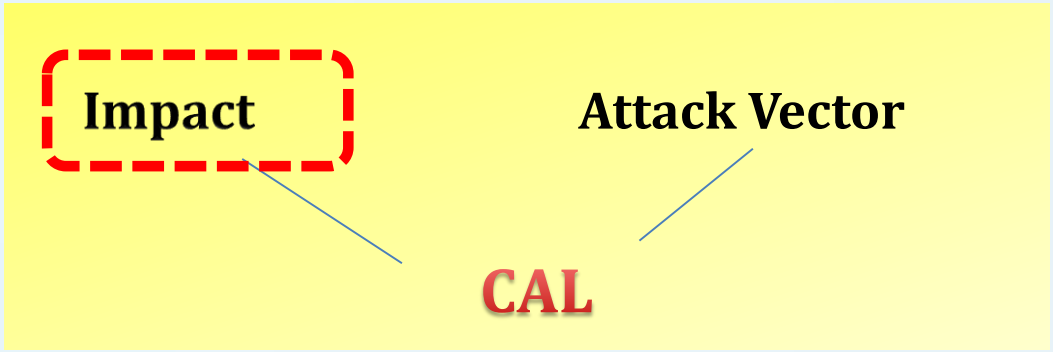
- Tailoring of the cybersecurity activities has been performed that shows that the requirement does not apply,

– or –

- A rationale is available that the non-compliance is acceptable and the rationale has been evaluated in accordance with ISO/SAE 21434.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

CAL: Cybersecurity Assurance Level



Impact

Class	Negligible	Moderate	Major	Severe
Impact Description	No damages	(Moderate) Causes distinct damages.	(Serious) Considerable damage.	(Severe) Severe damages.

Attack Vector

Physical	Local	Adjacent	Network
Physical Access to CPU (e.g., JTAG port)	In-vehicle network (e.g., CAN bus)	Bluetooth, OBD-II (physically)	E.g., cellular or WiFi network

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

CAL-driven Design & Development Activities

- Use of CAL is optional (a rationale is needed).
- CAL can be used to scale the depth and rigor of the activities in the Concept and Development Phases and the methods used for them.
- Some activities are dependent upon the CAL level (See **Table E.4** below).

Activity	Requirements	Testing parameters apply to				Scope
		CAL1	CAL2	CAL3	CAL4	
Functional Testing	[RC-10-12] [RQ-11-01]	T1	T1	T2	T2	Applies to the highest CAL among the cybersecurity requirements
Vulnerability Scanning	[RC-10-12] [RQ-11-01]	T1	T1	T1	T1	
Fuzz Testing	[RC-10-12] [RQ-11-01]	—	T1	T2	T2	
Penetration Testing	[RC-10-12] [RQ-11-01]	—	—	T1	T2	

T1 and T2 are testing parameters sets. T2 is more stringent than T1.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 1

Determine the Applicability of Automotive Cybersecurity and ISO/SAE 21434

Allotted Time: 90 minutes



Chapter 1: Overview of Automotive Cybersecurity and ISO/SAE 21434 — What We Covered

Competency 01: Determine the Relevance of Automotive Cybersecurity for Specific Products

- Learning Objective 01: List and describe some automotive cybersecurity issues
- Learning Objective 02: Determine the relevance of some automotive cybersecurity issues for specific products

Competency 02: Determine the Applicability of ISO/SAE 21434 in Your Organization and Current Products

- Learning Objective 03: Identify and describe some processes in your organization that might benefit from ISO/SAE 21434
- Learning Objective 04: Identify and describe some products/projects in your organization that might benefit from ISO/SAE 21434
- ***Breakout Exercise 1: Determine the Applicability of Automotive Cybersecurity and ISO/SAE 21434***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 2

Cybersecurity Management (Clauses 5 & 6)



Chapter 2: Cybersecurity Management (Clauses 5 & 6) — What We Will Cover

Competency 03: Plan and Perform Cybersecurity Management Activities

- Learning Objective 05: Plan and perform cybersecurity management activities at the Organizational Level
- Learning Objective 06: Plan and perform cybersecurity management activities at the Product/Project Level
- ***Breakout Exercise 2: Define the Cybersecurity Case***

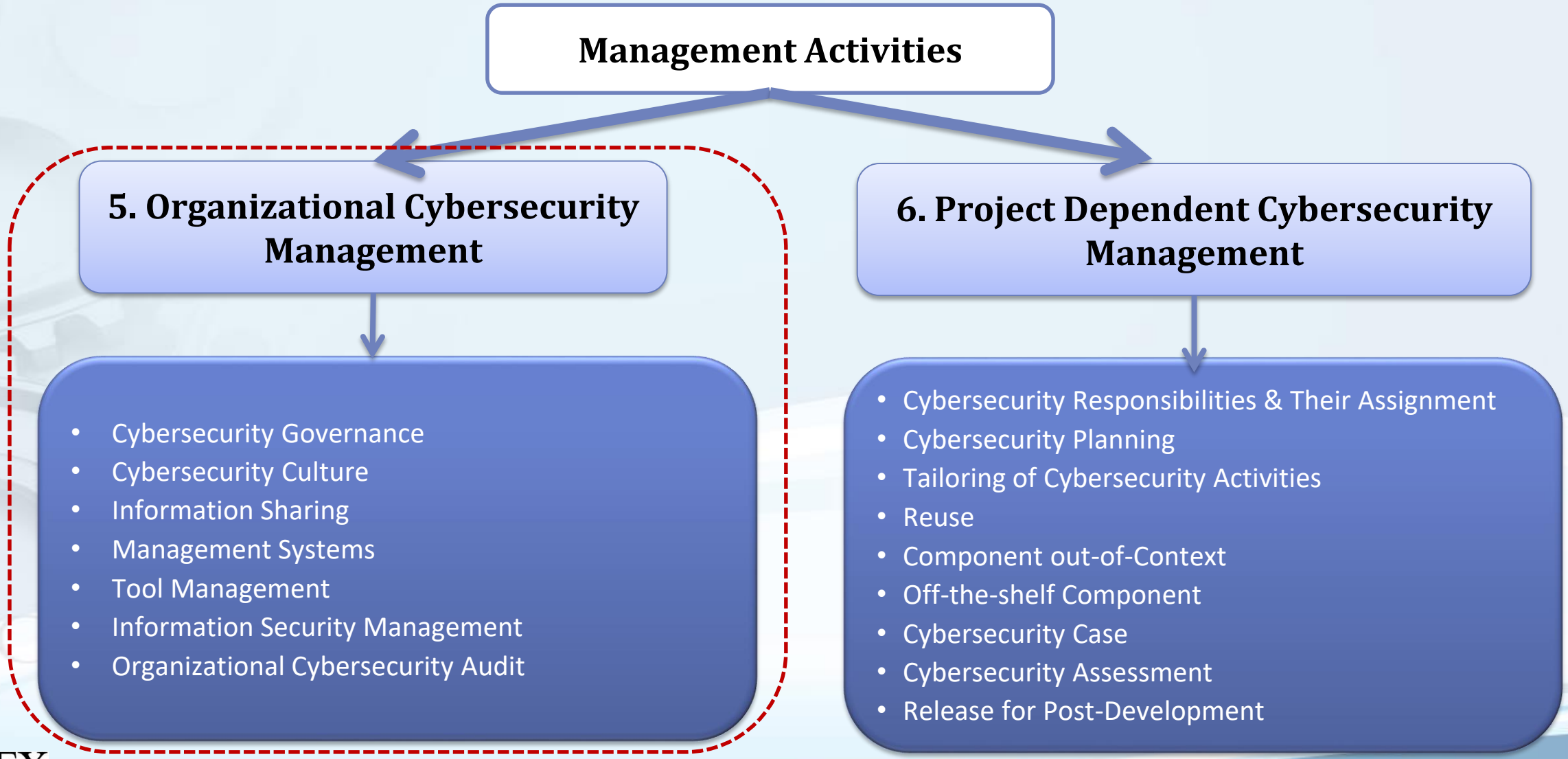
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ORGANIZATIONAL CYBERSECURITY MANAGEMENT

(Clause 5)



Cybersecurity Management Activities

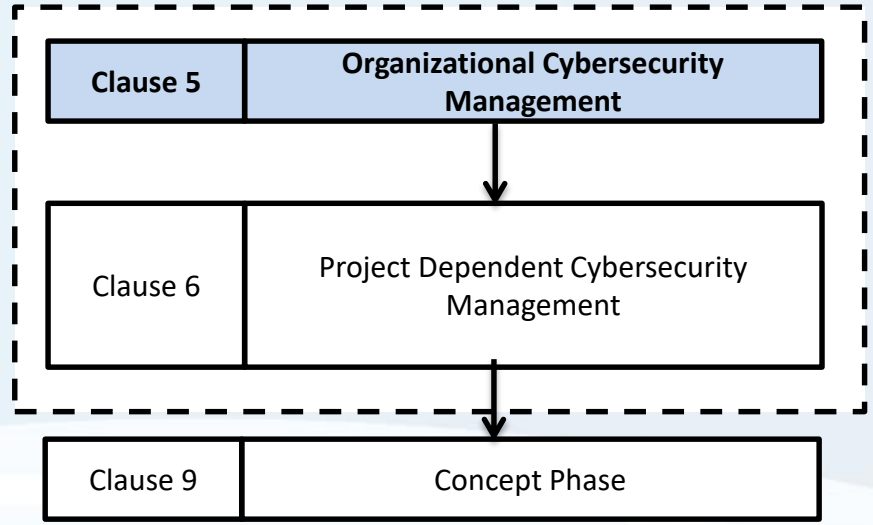


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Organizational Cybersecurity Management

Objectives

- Define the cybersecurity policy and the organizational rules and processes for cybersecurity.
- Assign the responsibilities and corresponding authorities.
- Support the implementation of cybersecurity.
- Manage the cybersecurity risk.
- Institute and maintain a cybersecurity culture, including competence and awareness management and continuous improvement.
- Support and manage the sharing of cybersecurity information.
- Institute and maintain management systems that support the maintenance of cybersecurity.
- Provide evidence that the use of tools does not adversely affect cybersecurity.
- Perform an organizational cybersecurity audit.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

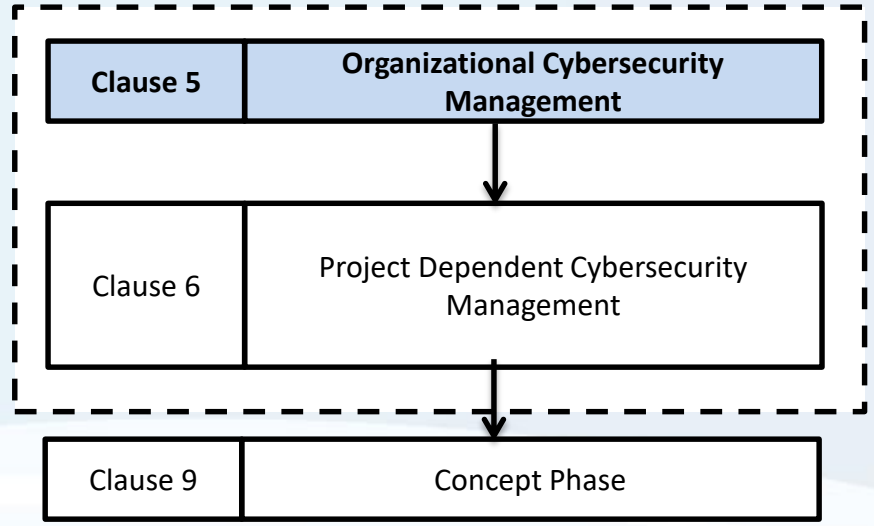
Organizational Cybersecurity Management

Prerequisites

- None

Work Products

- Cybersecurity policy, strategy, rules and processes
- Evidence of competence management, awareness management and continuous improvement
- Evidence of the organization's management systems
- Evidence of tool management
- Organizational cybersecurity audit report



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Work Products

- A result of one or more associated requirements of the cybersecurity plan / ISO/SAE 21434.
  - Evidence of compliance to one or more system cybersecurity requirements.
- A work product is not required to be a separate document.
  - The information can be included in existing documentation, or several work products can be included in one document.
- Be sure to create a “roadmap” of where all required work products are located.
- Often referred to as “mapping” from what you have, to what is required then noting the gaps to be filled.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Components of Organizational Cybersecurity Management



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Governance

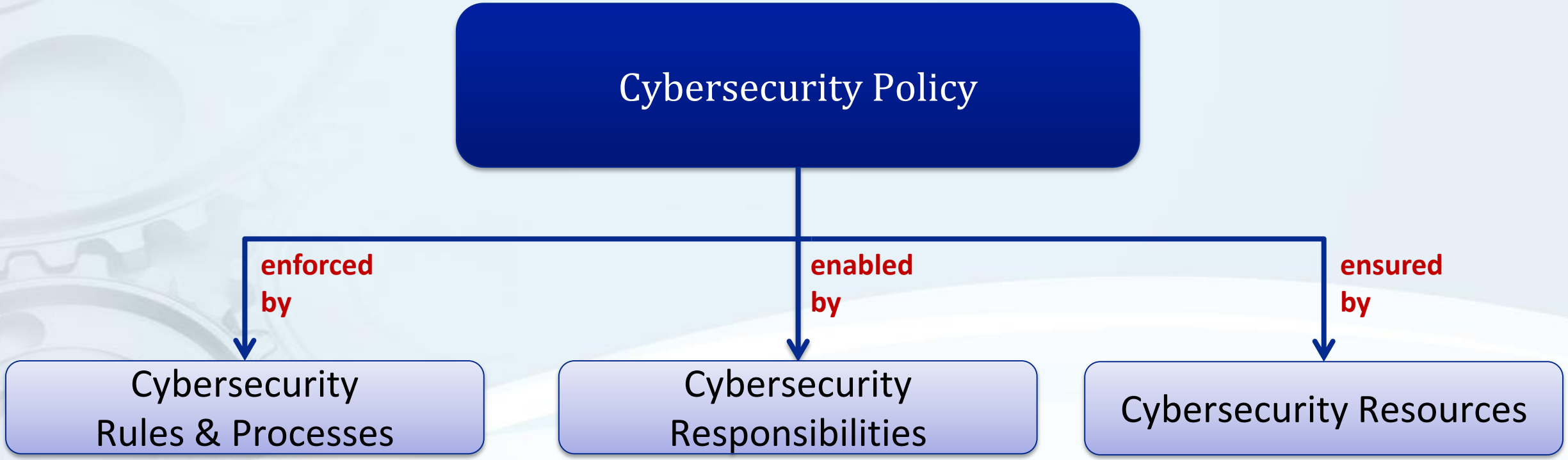
- The organization shall define a cybersecurity policy that includes:
  - Acknowledgement of road vehicle cybersecurity risks; and
  - The executive management's commitment to manage the corresponding risks.

NOTE 1: Links to the organization's objectives and other policies can be included in the cybersecurity policy.

NOTE 2: The cybersecurity policy can include a statement regarding the risk treatment of generic threat scenarios with respect to the organization's products or services portfolio, considering the context, either external or internal.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Governance



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Governance

- The organization shall establish and maintain organization-specific rules and processes to:
  - Enable the implementation of the requirements of ISO/SAE 21434; and
  - Support the execution of the corresponding activities.

EXAMPLE 1: Process definition, technical rules, guidelines, methods and templates.

NOTE 4: These rules and processes cover concept, development, production, operation, maintenance, and decommissioning, including cybersecurity risk management, information sharing, vulnerability disclosure, cybersecurity monitoring, incident response, and triggers.

NOTE 5: The rules and processes regarding vulnerability disclosure can be specified in accordance with ISO 29147.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Governance

- The organization shall identify disciplines related to, or interacting with, cybersecurity and establish and maintain communication channels between those disciplines in order to:
  - Determine if and how cybersecurity will be integrated into existing processes; and
  - Coordinate the exchange of relevant information.

NOTE 10: Disciplines include information technology security, functional safety, data protection, and privacy.

EXAMPLE 3: Interdisciplinary exchange of: threat scenarios and hazard information, cybersecurity goals and safety goals, or where a cybersecurity requirement might conflict or compete with a safety requirement.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Culture

- In order to be able to develop cybersecurity systems, ISO acknowledges the need for a **Cybersecurity Culture**.
- Your vision should encompass cybersecurity, such as:

"To reduce attacks and protect property"

Cybersecurity culture is hard to fully understand, but there are ways to see if a company will succeed.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Culture

- The organization shall foster and maintain a strong cybersecurity culture.
- The organization shall ensure the persons to which cybersecurity roles and responsibilities are assigned have the competences and awareness to fulfil these.

Competences can include:

- Organizational rules and processes regarding cybersecurity
- Organizational rules and processes regarding disciplines related to cybersecurity, such as functional security and privacy
- Domain knowledge
- Systems engineering
- Cybersecurity-related methods, tools and guidelines
- Known attack methods and cybersecurity controls
- **Etc…**

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The Quality Culture of Cybersecurity Management

Examples

1. **Cybersecurity as a Top Priority**
   - In every business decision, give cybersecurity a high status in the business objectives.
2. **Management Commitment to Cybersecurity**
   - Leadership by example; challenge behavior that can lead to violation of a cybersecurity goal.
3. **Increasing Visibility Around Cybersecurity**
   - Conduct cybersecurity audits and cybersecurity workarounds; demonstrates commitment.
4. **Report on Cybersecurity**
   - Frontline reporting of cybersecurity issues (e.g., threats, attacks, cybersecurity concerns).
   - Professional public relations management (if required) regarding actions taken.
   - Promptly react to incidents in a positive, learning way.
   - Take strong corrective actions; sends clear message to eliminating the next attack.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The Quality Culture of Cybersecurity Management

Examples

5. Staff Involvement

- Active employee participation is essential towards preventing and controlling threats.
- Provide effective training and forums to assist employees in personal cybersecurity contribution.
- Easy feedback mechanism to report concerns.

6. Create a Learning Curve: continuous improvement

- Learn what a good cybersecurity performance means in your job and contribute ideas for continuous improvement.

7. Provide Recognition

- Recognize the achievements of employees who improve cybersecurity in the organization.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The Quality Culture of Cybersecurity Management

Examples

8. Open Culture

- Encourage the reporting of issues or concerns without fear of personal blame.
- Create an open door policy for cybersecurity issues.

9. Effective Communication

- Clearly communicate the cybersecurity policy in a visible way.
- Communicate major incidents.

10. Cybersecurity Management System

- Assign a Cybersecurity Coordinator and Top Level Management Sponsor.
- Monitor performance and make it transparent.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Culture: Continuous Improvement

- The organization shall institute and maintain a continuous improvement process.

Examples include:

- Learning from previous cybersecurity experiences, including experiences gathered by field monitoring and observation of internal and external information;
- Learning from information obtained regarding products of similar application in the field;
- Deriving improvements to be applied during subsequent cybersecurity activities;
- Communicating lessons learned to the appropriate persons; and
- Checking the adequacy of its rules and processes.

Lessons Learned can be applied to:

- The Concept Phase;
- The product development;
- Activities concerning multiple phases of the lifecycle e.g., vulnerability assessment;
- Production;
- Incident response;
- **Etc…**

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Information Sharing

- The organization shall define the circumstances under which sharing is required, permitted, and prohibited, within and outside of the organization.

NOTE: This can include:

- A list of the types of cybersecurity information that can be shared; O$M$$NEX .OET
- Approval process for sharing;
- Requirements for redacting and sanitizing information;
- Rules for source attribution;
- Types of communications for specific parties;
- Vulnerability disclosure procedures; and/or
- Requirements for receiving party on handling of highly sensitive information.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Management Systems

- The organization shall institute and maintain a quality management system in accordance with international standards, or equivalent, to support cybersecurity engineering, addressing:
  a) Change management;
  b) Documentation management;
  c) Configuration management; and
  d) Requirements management.
- The configuration information regarding the cybersecurity of the products in the field shall remain available until the end of their support (e.g., bill of materials, binaries).
- A cybersecurity management system for the production processes should be established.

  EXAMPLE 4: IEC 62443 2-1

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Tool Management

- Tools that can impact the cybersecurity of an item, system, or component shall be managed.
- Such management can be established by:
  - Application of the user manual with errata;
  - Protection against unintended usage or action;
  - Access control for the tool users; or
  - Authentication of the tool.
- An appropriate environment to support remedial actions for cybersecurity incidents should be reproducible until the end of support for the product.

  Examples: Toolchain and compilers used for building the software of the product.

Tools Examples:

Product Development

- Model-based Development
- Static Checkers
- Verification Tools

Production

- Flash Writer
- End of Line Tester

Maintenance

- On-board Diagnostic Tool
- Reprogramming Tool

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Information Security Management

- The relevant information security properties of the work products required by the cybersecurity plan should be managed by an information security management system.

  EXAMPLE: Work products can be stored on a file server that protects them from unauthorized alteration or deletion.

Clause 5 Work Products

- **[WP-05-01]** Cybersecurity policy, rules and processes
- **[WP-05-02]** Evidence of competence management, awareness management and continuous improvement
- **[WP-05-03]** Evidence of the organization's management systems
- **[WP-05-04]** Evidence of tool management
- **[WP-05-05]** Organizational cybersecurity audit report

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Organizational Cybersecurity Audit

- A cybersecurity audit shall be performed independently to judge whether the organizational processes achieve the objectives of ISO/SAE 21434.

NOTE 1: Such a cybersecurity audit can be included in, or combined with, an audit according to a quality management system standard.

EXAMPLE: IATF 16949 in conjunction with ISO 9001.

NOTE 2: Independence can be based on, for example, the ISO 26262 series.

NOTE 3: The person that performs the audit can be internal or external to the organization.

NOTE 4: To ensure that organizational processes remain appropriate for cybersecurity, an audit can be performed periodically.

In ISO/SAE 21434, an audit is not an examination of an implemented process but rather an examination of processes at the organization in regards to the achievement of cybersecurity.

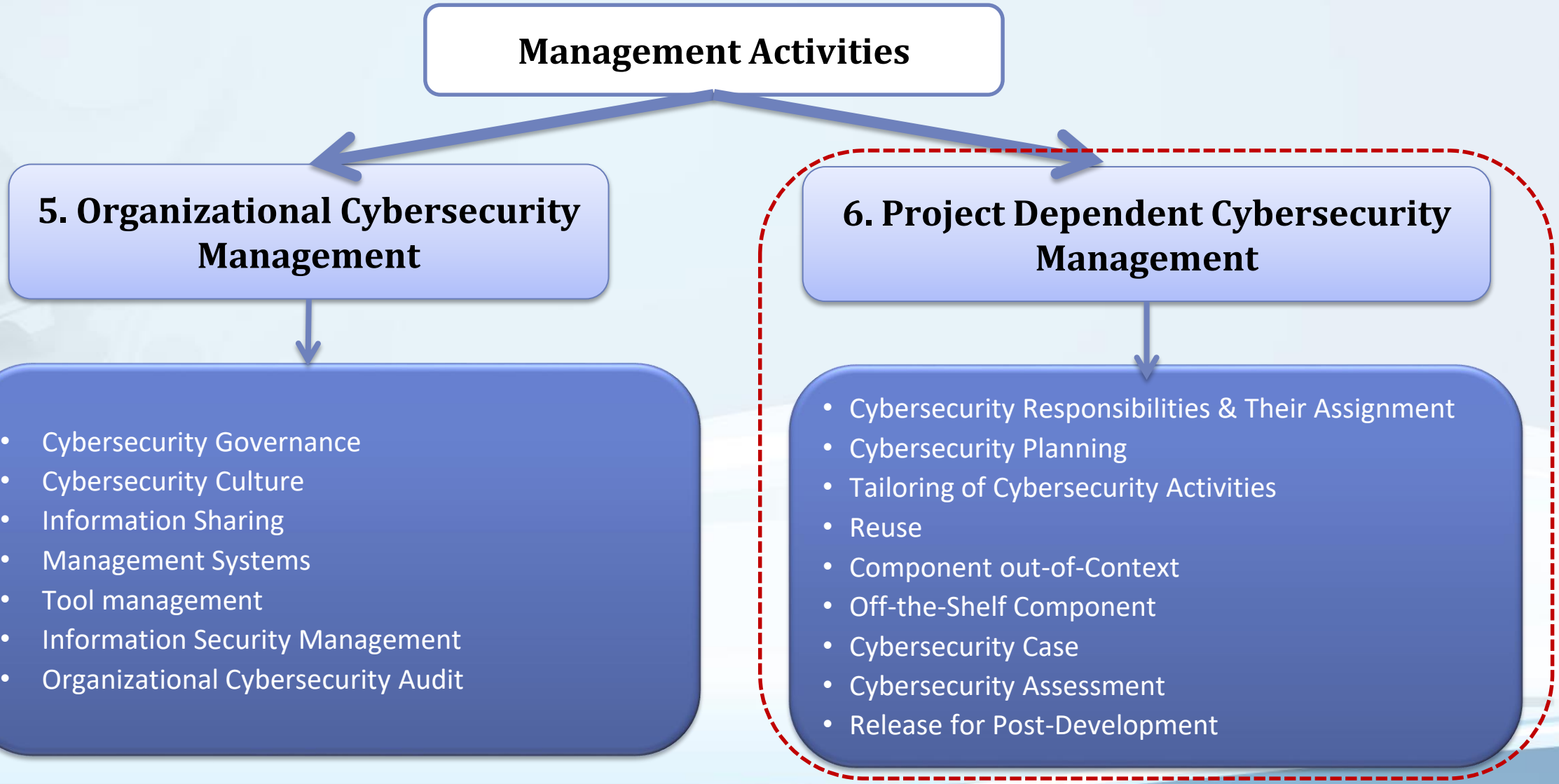
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

PROJECT DEPENDENT CYBERSECURITY MANAGEMENT

(Clause 6)



Functional Cybersecurity Management Activities

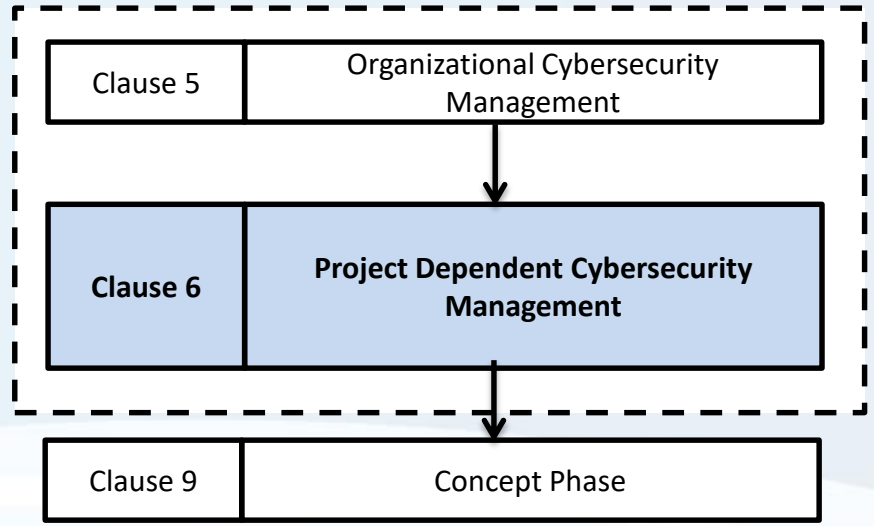


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Project Dependent Cybersecurity Management

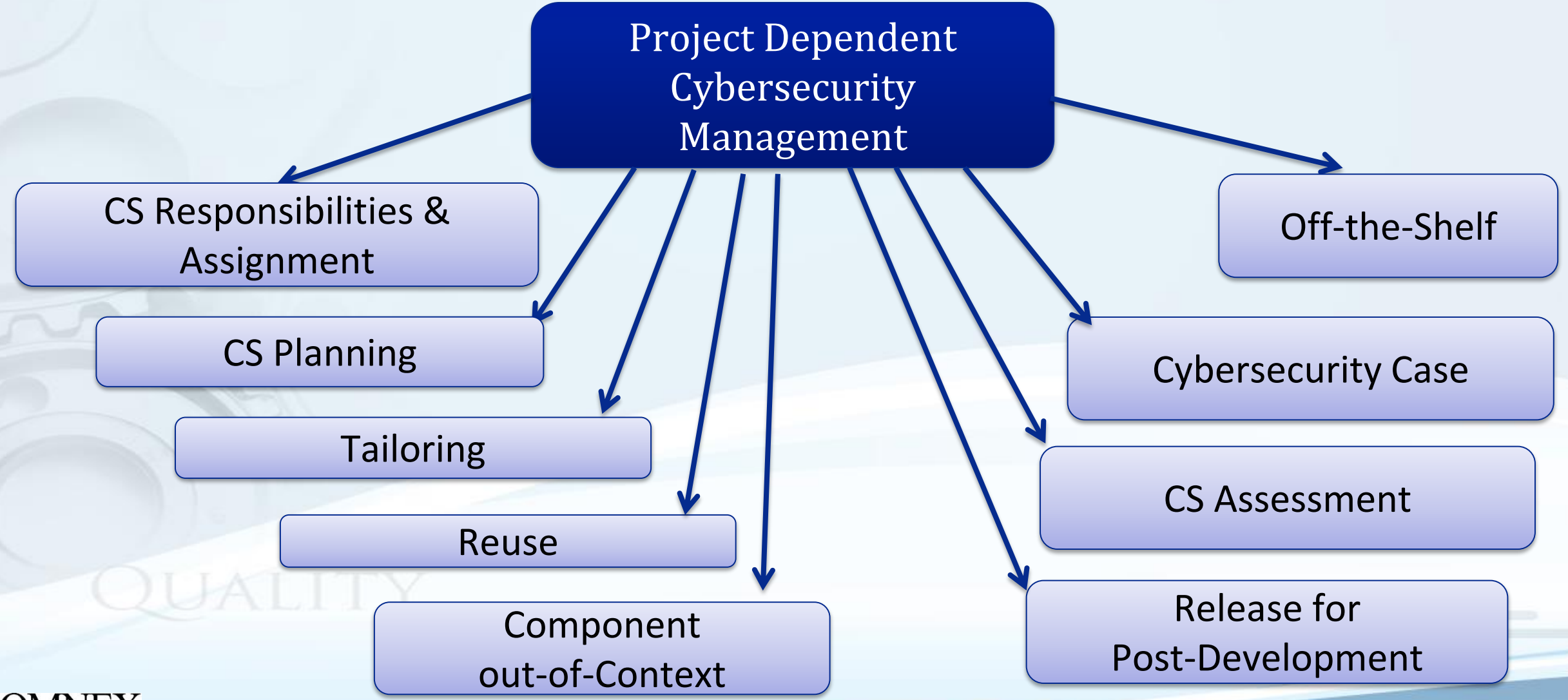
Objectives

- Assign the responsibilities regarding cybersecurity for the project.
- Plan the cybersecurity activities, including the definition of the tailored cybersecurity activities.
- Create a cybersecurity case.
- Perform a cybersecurity assessment, if applicable.
- Decide whether the item or component can be released for post-development from a cybersecurity perspective.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Components of Project Dependent Cybersecurity Management



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Responsibilities and Assignment

- The responsibilities regarding the project's cybersecurity activities shall be clearly assigned and communicated.

NOTE: Responsibilities for cybersecurity activities can be transferred provided that this is communicated and that the relevant information is made available.

NOTE:

- Responsibilities regarding cybersecurity activities can be transferred to other persons.
- This includes communicating the transfer of responsibility and a handover of pertinent information.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Responsibilities, Planning and Required Processes (Recommended)

- The organization should have policies and procedures for cybersecurity responsibilities during the production process.
  - Ensure that the cybersecurity specifications from development are implemented in the produced item.
  - Implement processes to prevent the introduction of additional cybersecurity vulnerabilities caused by the production process.

An assembly line is one place where threat agents can install software with malicious intent.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Planning

- In order to decide cybersecurity activities needed for the item or component, the item or component shall be analyzed to determine:
  - Whether the item or component is cybersecurity relevant;

    NOTE 1: Annex D provides a method and criteria that can be used to assess the cybersecurity relevance.

    NOTE 2: If the item or component is determined as not cybersecurity relevant, then there are no cybersecurity activities, thus cybersecurity planning is not continued.
  - If the item or component is cybersecurity relevant, whether the item or component is a new development or a reuse; and
  - Whether tailoring in accordance with **6.4.3** is applied.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Planning

- The cybersecurity plan shall include the:
  - Objective of an activity;
  - Dependencies on other activities or information;
  - Personnel responsible for performing an activity;
  - Required resources for performing an activity;
  - Starting point or end point, and the expected duration of an activity; and
  - Identification of the work products to be produced.
- The cybersecurity plan shall either be:
  - Referenced in the project plan for the development; or
  - Included in the project plan, such that the cybersecurity activities are distinguishable.

NOTE 3: The cybersecurity plan can incorporate cross-references to other plans (e.g., the project plan) which are also under configuration management (see also **[RQ-06-09]**).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

DIA Project Plan: An Example
(with integrated Cybersecurity Plan)

B	C	D	E	F	G	H	
Deliv	Deliverable Name	Sch. Start Date	Sch. Finish Date	Duration	Predece	Resources	Budget
1	Engineering Processes	2019-12-16T09:00:0	2020-3-5T17:30:0	81.00			688.5
2	Requirements management	2019-12-16T09:00	2019-12-20T17:30	5.00			42.5
3	Define requirements management with suppliers: description of work methods and proc	2019-12-16T09:(	2019-12-16T17:30	1.00		Jane Doe	8.5
4	Handover of requirements (including compilation of all applicable standards, regulations	2019-12-17T09:(	2019-12-17T17:30	1.00	3	Jane Doe	8.5
5	Supply general standards and guidelines	2019-12-18T09:(	2019-12-18T17:30	1.00	4	Jane Doe	8.5
6	Supply customer-specific standards	2019-12-19T09:(	2019-12-19T17:30	1.00	5	Jane Doe	8.5
7	Create components specification and verify against XXXX specifications	2019-12-20T09:(	2019-12-20T17:30	1.00	6	Jane Doe	8.5
8	Software development	2019-12-21T09:00	2019-12-21T17:30	1.00			8.5
40	Cybersecurity	2020-1-19T09:00:(	2020-2-12T17:30:(	25.00		John Doe	212.5
41	Agree on cybersecurity process in accordance to appropriate standards and install it. Tail	2020-1-19T09:0(	2020-1-19T17:30:(	1.00	39	John Doe	8.5
42	cybersecurity life cycles, internal & external interfaces and process plan to be defined	2020-1-20T09:0(	2020-1-20T17:30:(	1.00	41	John Doe	8.5
43	Name responsible cybersecurity Official/SAM	2020-1-21T09:0(	2020-1-21T17:30:(	1.00	42	John Doe	8.5
44	Establish a Cybersecurity Program Plan (CPP), fill it in, harmonize it (with XXXX), and work	2020-1-22T09:0(	2020-1-22T17:30:(	1.00	43	John Doe	8.5
45	Assessment to be planned for function cybersecurity and report results respectively with	2020-1-23T09:0(	2020-1-23T17:30:(	1.00	44	John Doe	8.5
46	Verification of working off of CPP for each phase of the cybersecurity life cycle	2020-1-24T09:0(	2020-1-24T17:30:(	1.00	45	John Doe	8.5
47	Establish cybersecurity evidence material (cybersecurity Case) in accordance with CPP	2020-1-25T09:0(	2020-1-25T17:30:(	1.00	46	John Doe	8.5
48	Results of the cybersecurity assessments for the respective phases/releases and all cyber	2020-1-26T09:0(	2020-1-26T17:30:(	1.00	47	John Doe	8.5
49	Draw up cybersecurity concept (cybersecurity requirements vis-à-vis hardware and softv	2020-1-27T09:0(	2020-1-27T17:30:(	1.00	48	John Doe	8.5
50	If necessary, draw up hardware draft with alternatives in accordance with the cybersecur	2020-1-28T09:0(	2020-1-28T17:30:(	1.00	49	John Doe	8.5
51	Determination of the hardware draft	2020-1-29T09:0(	2020-1-29T17:30:(	1.00	50	John Doe	8.5
52	Draw up technical cybersecurity concept and document by means of a cybersecurity spe	2020-1-30T09:0(	2020-1-30T17:30:(	1.00	51	John Doe	8.5
53	Retraceability of cybersecurity requirements to be ensured	2020-1-31T09:0(	2020-1-31T17:30:(	1.00	52	John Doe	8.5
54	Safeguard cybersecurity concepts at hardware level by means of cybersecurity analyses	2020-2-1T09:00:	2020-2-1T17:30:0(	1.00	53	John Doe	8.5
55	Define interface of analyses	2020-2-2T09:00:	2020-2-2T17:30:0(	1.00	54	John Doe	8.5
56	Write down measures/actions for HW safeguarding and implement these (CAL-depender	2020-2-3T09:00:	2020-2-3T17:30:0(	1.00	55	John Doe	8.5
57	Write down measures/actions for SW safeguarding and implement these (CAL-dependen	2020-2-4T09:00:	2020-2-4T17:30:0(	1.00	56	John Doe	8.5
58	Plan V&V activities and agree these; reference in terms of requirements (CAL-dependent	2020-2-5T09:00:	2020-2-5T17:30:0(	1.00	57	John Doe	8.5
59	Fulfilling of cybersecurity requirements relating to HW and SW, provide evidence	2020-2-6T09:00:	2020-2-6T17:30:0(	1.00	58	John Doe	8.5
60	Implement FMEA of the process; mark scope of cybersecurity activities	2020-2-7T09:00:	2020-2-7T17:30:0(	1.00	59	John Doe	8.5

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Planning

- For threat scenarios of risk value 1 that are determined from analysis, **Cybersecurity Concept (clause 9.5)**, **Product Development (clause 10)** and **Cybersecurity Validation (clause 11)** may be omitted.

NOTE 5: These threat scenarios can have consequences with regard to cybersecurity and if so, the corresponding risks are treated, albeit potentially with less rigor.

NOTE 6: The sufficiency of the treatment of such risks can be argued based on a rationale defined in the cybersecurity case. The rationale can be based on conformity with IATF 16949 in conjunction with ISO 9001, in combination with additional measures, for example:

- Cybersecurity awareness assurance;
- Cybersecurity training of quality personnel; and/or
- Cybersecurity specific measures defined in the organization's quality management system.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Planning

- In the case of distributed cybersecurity activities, both the customer and the supplier shall each define a cybersecurity plan regarding their respective cybersecurity activities and interfaces.
- The work products resulting from the cybersecurity activities defined in the cybersecurity plan shall be subject to configuration management, change management, requirements management, information security management and documentation.

For each activity, the planning shall include:

- The objective of the activity;
- The dependencies on other activities or information;
- The person responsible for performing the activity;
- The required resources for performing the activity;
- The starting point, or end point, in time and the duration e.g., the corresponding milestones;
- The identification of the corresponding work product.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Tailoring of the Cybersecurity Activities

- A cybersecurity activity may be tailored.
- If a cybersecurity activity is tailored, then a rationale why the tailoring is adequate and sufficient to achieve the relevant objectives of ISO/SAE 21434 shall be provided and reviewed.
- An activity is tailored if it is omitted or performed in a different manner compared to its description in ISO/SAE 21434.

NOTE: Activities that are not performed because they are performed by another entity in the supply chain are not considered as tailored, but as distributed cybersecurity activities. However, distribution of cybersecurity activities can lead to joint tailoring.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Tailoring of the Cybersecurity Activities

- The following are examples of tailoring:
  - Reuse
  - Component out-of-context (CooC)
  - The use of an off-the-shelf component
  - Update
- The tailoring, and its rationale, of a cybersecurity activity shall be specified in the cybersecurity plan.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Reuse

- Reuse of items and components is a possible development strategy that can be applied, with or without modifications to an item, component, or their operational environment.
- However, modifications can introduce vulnerabilities that might not have been considered for the original item or component.
- Furthermore, there might have been a change in known attacks, for example:
  - An evolution of attack techniques;
  - Newly emerged vulnerabilities, e.g., learned from cybersecurity monitoring and/or cybersecurity event evaluation; or
  - A change of the assets since the original development.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Reuse: Focus is on Item or Component

- If the original item or component was developed in accordance with ISO/SAE 21434, the reuse of that item or component is based on the existing work products.
- If the item or component was not originally developed in accordance with ISO/SAE 21434, the reuse can be based on the existing documentation with a rationale.



[a] can be changed as a result of the reuse analysis

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Reuse

- A reuse analysis shall be carried out if an item or component has been developed and:
  - Modifications are planned,
  - Is planned to be reused in another operational environment, or
  - It is planned to be reused without modification and there are relevant changes to the information concerning the item or component.

NOTE 1: Existing WPs are considered in determining whether a reuse is possible.

NOTE 2: Modifications include design modifications and implementation modifications:

- Design modifications can result from requirements modifications e.g., functional or performance enhancement.
- Implementation modifications can result from corrections of software, or the use of new production or maintenance tools, e.g., model based development.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Reuse

- The reuse analysis of an item or component shall:
  - Identify the modifications to the item or component and the modifications of its operational environment;
  - Analyze the cybersecurity implications of the modifications;
  - Identify the affected or missing work products; and

    EXAMPLE 4: TARA considering new or modified assets, threat scenarios or risk values.
  - Specify the cybersecurity activities necessary to conform with ISO/SAE 21434 in the cybersecurity plan.

Examples of cybersecurity implications on:

- Cybersecurity requirements
- Design and implementation
- Operational environment
- Validity of assumptions and operating modes
- Maintenance
- Susceptibility to known attacks
- Exposure of known vulnerabilities or assets.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

CYBERSECURITY SYSTEM OR COMPONENT OUT-OF-CONTEXT

(CooC)



Types of Elements

Elements (components) can be developed in one of three ways:

1. **Standard Component:** Development is independent of use as a cybersecurity element. If used as such, it must be qualified.
   - Qualification of components is to provide evidence of the suitability of intermediate level components and parts for their use as part of items, systems or elements, developed in compliance with ISO/SAE 21434, concerning their functional behavior and their operational limitations for the purposes of the cybersecurity concept.
2. Development of elements ***in context***; i.e., elements developed to satisfy specific cybersecurity requirements as provided or derived from the OEM development activities.
   - The context is the item to be supported.
3. Development of a component ***out of context (CooC)***; i.e., there is no specific OEM or item (context) that provides the specific cybersecurity requirements of the component.

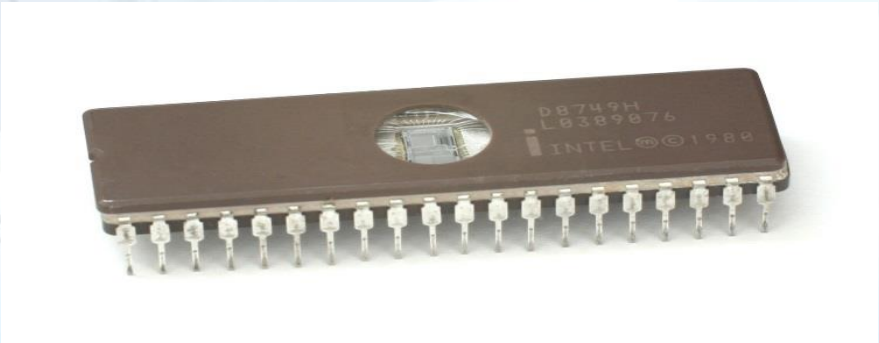
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

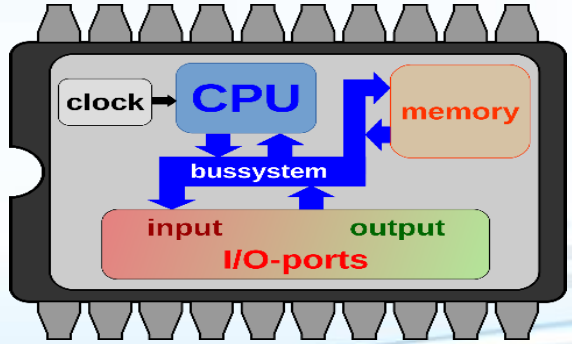
Component out-of-Context (CooC)

- CooCs differ from qualified components.
- The CooC concept deals with the **development** of elements in accordance with ISO/SAE 21434 that are intended to…
  1. Provide for cybersecurity requirements; and
  2. Be **reusable**

under specified assumptions documented by the supplier.







Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

Definition: A Component out-of-Context (CooC) is a cybersecurity system for which an item does not exist at the time of its development.

Essential Observations:

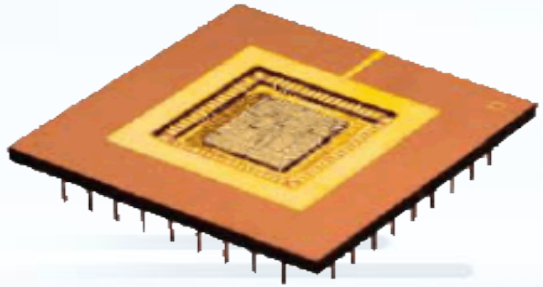
- Typically, the correct **implementation** of the assumed requirements is **verified** during development of the CooC, but the **validation** takes place during the item development.
- The development of an CooC starts at a certain level of requirements and design, and all information on requirements or design prerequisites is pre-determined with the status “assumed”.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

Some typical examples of a Cybersecurity System out-of-Context include:

- **A hardware ECU** (Engine Control Unit) developed for certain types of Engine Management Systems (EMS) applications (low-end, medium or high-end vehicles) with the corresponding basic software that includes hardware build-in tests.
- **An ASIC** (Application Specific Integrated Circuit) that implements ECU monitoring functions and ensures the cut-off of essential actuators in case of severe failure.
- **A module** that provides the ECU with the engine synchronization.

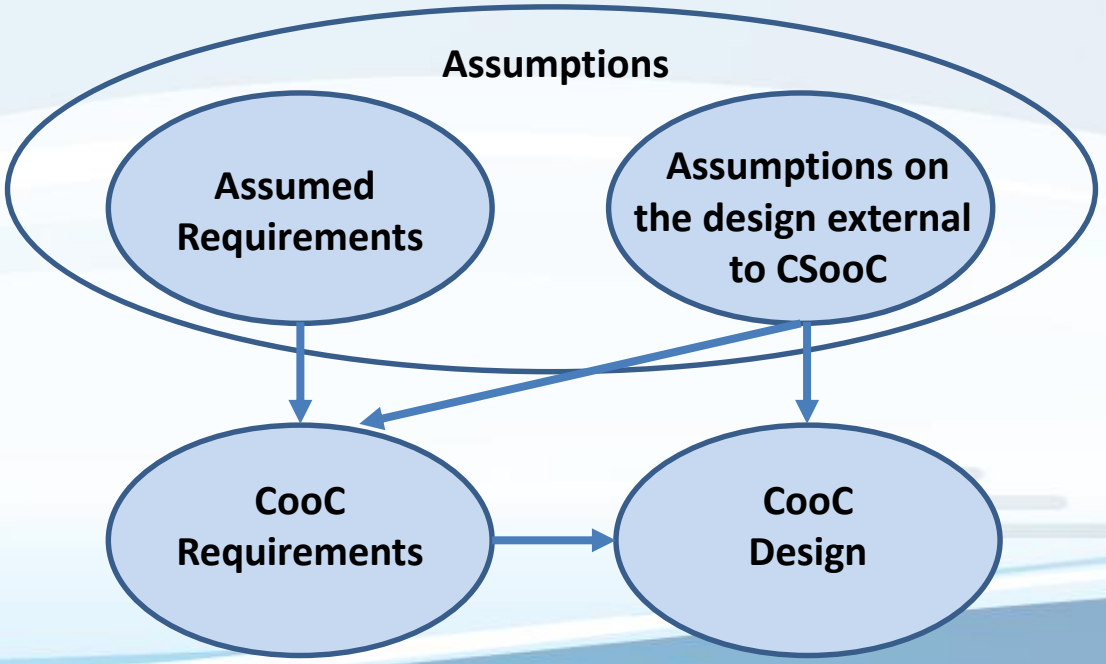


An ASIC is a typical CSooC

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

- The development of a CooC involves making assumptions on the prerequisites of the corresponding phase in the product development.
- It might not be necessary to make assumptions on all prerequisites, e.g., cybersecurity plan.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Development of a CooC

System Development

By Supplier

- Step 1a – Assumptions on the Scope of CooC and its Related Item
- Step 1b – Assumption on Functional Cybersecurity Requirement of the CooC
- Step 2 – Execution of CooC Development
- Step 3 – Provision of Work Products to System Integrator

By Customer

- Step 4 – Establish Validity of Assumptions
- Step 5 – CooC Integration in the Item

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Requirements & Caution

Remember: Cybersecurity is a System Level Property.

A CooC is *not* a black box!

- The CooC developer needs to:
  - Document assumptions on intended use and context;
  - Develop requirements based on assumptions;
  - Validate cybersecurity claims and assumptions.
- The item developer needs to:
  - Validate assumptions and work products;
  - Provide feedback to the CooC developer.

A CooC must be transparent with respect to integration.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

Organizations that develop or produce components for the automotive industry often develop generic components for different applications and for different customers.

- These generic components can be developed independently prior to engagement with a customer.
- If those components are developed based on assumed requirements, e.g., prior to a commercial agreement and in accordance with the relevant requirements of ISO/SAE 21434, such components are developed out-of-context.
- When a component out of context is developed, tailoring of a cybersecurity activity can be applied since the activity is performed based on assumptions.

  EXAMPLE: A microcontroller developed as a CooC.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

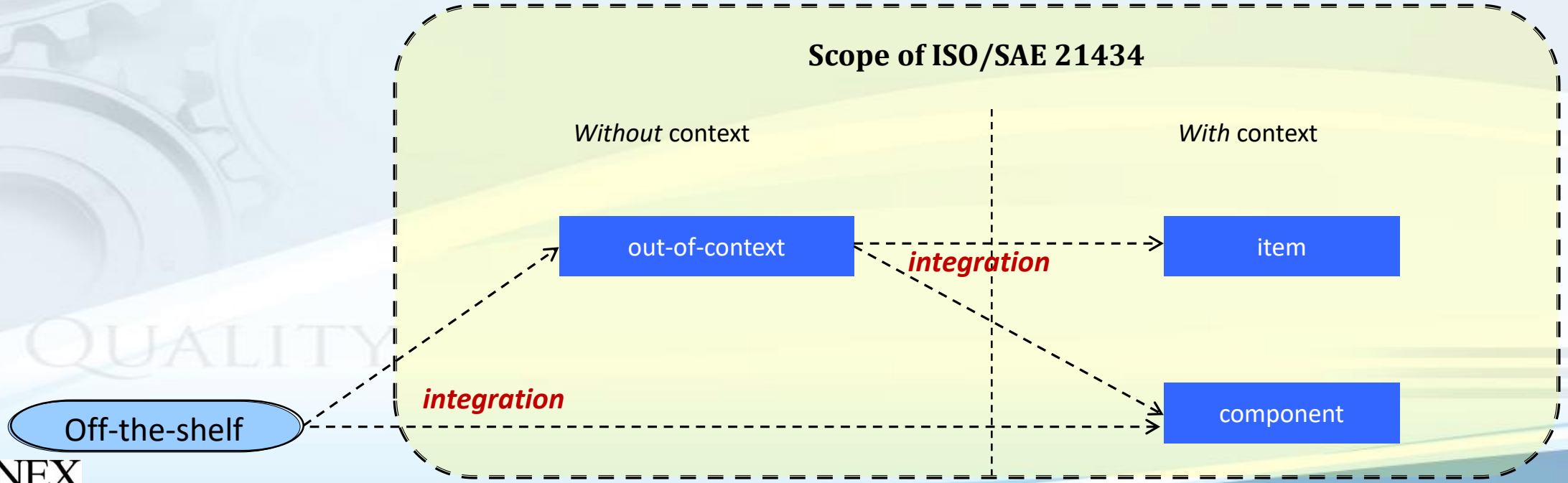
- If cybersecurity activities are tailored because an item or component is developed out-of-context then:
  - Assumptions on the intended use and context, including the external interfaces, shall be documented in the corresponding work products.
  - The out-of-context development shall be based on cybersecurity requirements that are derived from the assumptions.
  - For the integration of a component developed out-of-context, the cybersecurity claims and assumptions shall be validated.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Component out-of-Context (CooC)

- The figure below shows that both an off-the-shelf component and an out-of-context component can be integrated into an item or component in accordance with ISO/SAE 21434.
- The integration can involve activities similar to reuse analysis.

Figure 5 – Integration of off-the-shelf and out-of-context components



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Off-the-Shelf (OTS)

- An OTS is a component that is not developed on behalf of a specific customer and that can be used without modification of its design or implementation, e.g., a third-party software library, or an open source software component.
- An off-the-shelf component is not assumed to have been developed in accordance with ISO/SAE 21434.
- When integrating an OTS component, the cybersecurity-related information shall be gathered, analyzed, and evaluated whether:
  a) Allocated cybersecurity requirements can be fulfilled;
  b) The component is suitable for the specific application context of the intended use; and
  c) Existing documentation is sufficient to support the cybersecurity activities.
- If the existing documentation is insufficient to support the integration of the OTS component, then the cybersecurity activities to comply with ISO/SAE 21434 shall be identified and performed.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

CYBERSECURITY CASE

ISO/SAE 21434



3rd Party Certification

Most management standards required by the OEMs include 3rd party certification. That is a supplier's implementation is required to be recognized by independent, third-party agency, as demonstrating that a product or service complies with all standard requirements.

Why Do Companies Seek / Require 3rd Party Certification?

- To demonstrate compliance with national or international standards and regulations.
- To demonstrate independent validation and verification of their commitment to cybersecurity and quality.
- To increase credibility and acceptance with retailers, consumers and regulators.

➔ Benefit from enhanced product quality and cybersecurity.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case

- ISO/SAE 21434 does ***NOT*** include provisions for 3rd party registration or certification.
- Instead, the standard requires the development of a cybersecurity case.
  - A cybersecurity case shall be created to provide the argument for the achieved cybersecurity.
  - The argument can be implicit, i.e., if the argument is evident from the compiled set of work products, an explicit argument can be omitted.
  - The cybersecurity case is a structured document that provides a basis for judgement and confidence of cybersecurity.
  - A cybersecurity case requires communicating a clear, comprehensive and defensible argument (supported by evidence) that a system is free of unreasonable risk to operate in a particular context.

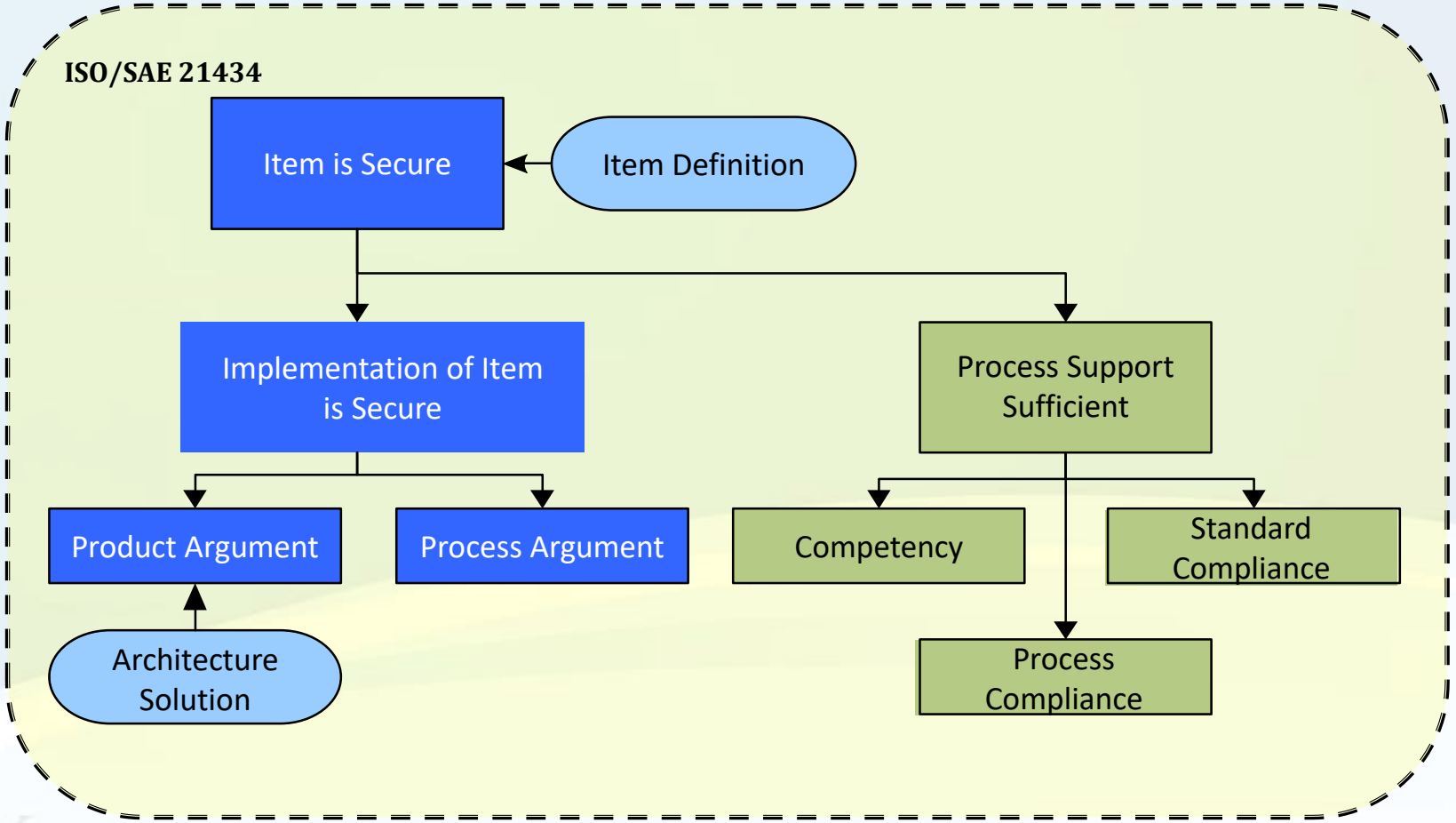
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case

- The following are important considerations for the purpose of developing a cybersecurity case:
  - Above all, the cybersecurity case exists to communicate an argument.
  - It is used to demonstrate how it is possible to ***reasonably*** conclude that a system is free of ***unreasonable*** **risk** based on the available evidence.
  - A cybersecurity case is a device for communicating ideas and information, usually to a third party.
- There are three principal elements of a cybersecurity case, namely:
  - The requirements;
  - The argument; and
  - The evidence.
- The cybersecurity case should progressively compile the work products that are generated during the cybersecurity lifecycle.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case



Cybersecurity

3.1.9 Road Vehicle Cybersecurity

Condition in which assets are sufficiently protected against *threat scenarios* to *items* of road vehicles, their functions and their electrical or electronic *components*.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case

Common Types of Cybersecurity Arguments

- **Product Argument:** direct appeal to features of the implemented product (e.g., the behavior of a timing watchdog).
- **Process Argument:** appeal to features of the development and assessment process (e.g., the design notation adopted).

- The cybersecurity case development can not be left as an activity to be performed towards the end of the cybersecurity lifecycle.
  - e.g., Behavior of user might change over time because of widespread use and familiarity to new cybersecurity systems.
- Cybersecurity cases are, by their nature, often **subjective**; the objective of the cybersecurity case development, therefore, is to obtain mutual acceptance of this subjective position.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

AUDITS, ASSESSMENTS AND REVIEWS



Reviews, Audits and Assessments (Recommended)

- **Review:** Examination of a ***work product***, for achievement of the intended work product goal, according to the requirements of ISO/SAE 21434.

  NOTE: Reviews can be supported by checklists.

- **Audit:** A cybersecurity audit shall be performed to independently judge whether the organizational processes achieve the objectives of ISO/SAE 21434.
  - Thus, an audit is at the **Organizational Level** rather than an implemented process as is the case with ISO 26262. (see **5.4.4**)

- **Assessment:** Examination of *the **achieved cybersecurity*** of an item or element.

  NOTE: A level of independence, of the party or parties performing the assessment, is associated with each assessment. (see **6.4.8**)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Recommended Approach (from ISO 26262:2018)

Confirmation Measures	Degree of Independency applies to:					Scope
		CAL				
	QM	1	2	3	4	
Impact Analysis at Item Level	I3					Judgment of whether the impact correctly identified the item status
Threat Analysis and Risk Assessment	I3					The scope of this review shall include the correctness of the determined CALs, and QM ratings of the identified Threats for the item, and a review of the cybersecurity goals
Cybersecurity Plan	-	-	I1	I2	I3	Applies to the highest CAL among the cybersecurity goals of the item
Cybersecurity Concept	-	I0	I1	I2	I2	
Technical Cybersecurity Concept (Cybersecurity Controls)		I0	I1	I2	I2	
Item Integration and Test Strategy	-	I1	I1	I2	I3	
Cybersecurity Validation Specification	-	-	I0	I1	I1	
Cybersecurity Analyses and the Dependent Failure Analyses	-	I0	I1	I2	I3	
Cybersecurity Case	-	I0	I1	I2	I3	
Functional Cybersecurity Audit	-	-	I0	I2	I3	
Functional Cybersecurity Assessment	-	-	I0	I2	I3	

Adapted from: ISO 26262 Part 2

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by QET

Confirmation Review

source: ISO 26262 Part 2

The notations: --, I0, I1, I2 and I3 are defined as:

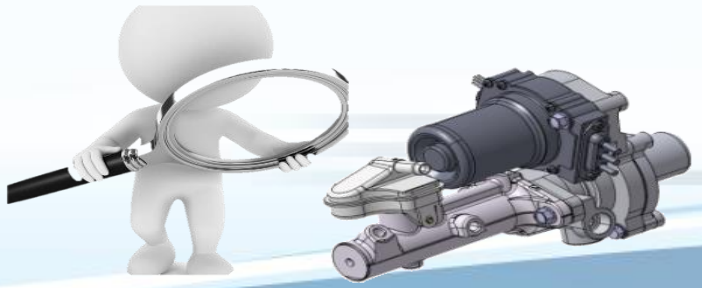
-	no requirement and no recommendation for or against regarding this confirmation measure;
I0	the confirmation measure ***should*** be performed; however, if the confirmation measure is performed, it shall be performed by a *different person*;
I1	the confirmation measure ***shall*** be performed, by a *different person*;
I2	the confirmation measure **shall** be performed, by a *person from a different team*, i.e., not reporting to the same direct superior;
I3	the confirmation measure **shall** be performed, by a *person from a different department or organization*, i.e., independent from the department responsible for the considered work product(s) regarding management, resources and release authority.

Note: software tool development is outside the item's cybersecurity lifecycle whereas the qualification of such a tool is an activity of the cybersecurity lifecycle.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Assessment

- If a cybersecurity assessment is performed, this assessment shall judge whether the available evidence provides sufficient confidence in the achieved cybersecurity of the item, or of the contribution to the achievement of cybersecurity by the components.
  - The available evidence is provided by the documented results of the cybersecurity activities, i.e., the work products. (see **Annex A**)
  - The cybersecurity assessment can be performed progressively to facilitate an early resolution of identified issues.
  - The assessment might be repeated or supplemented, e.g., due to a vulnerability discovered post-development.
- A cybersecurity assessment report shall be available at the latest by the release for post-development.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Assessment

Cybersecurity Assessment in relation to other activities

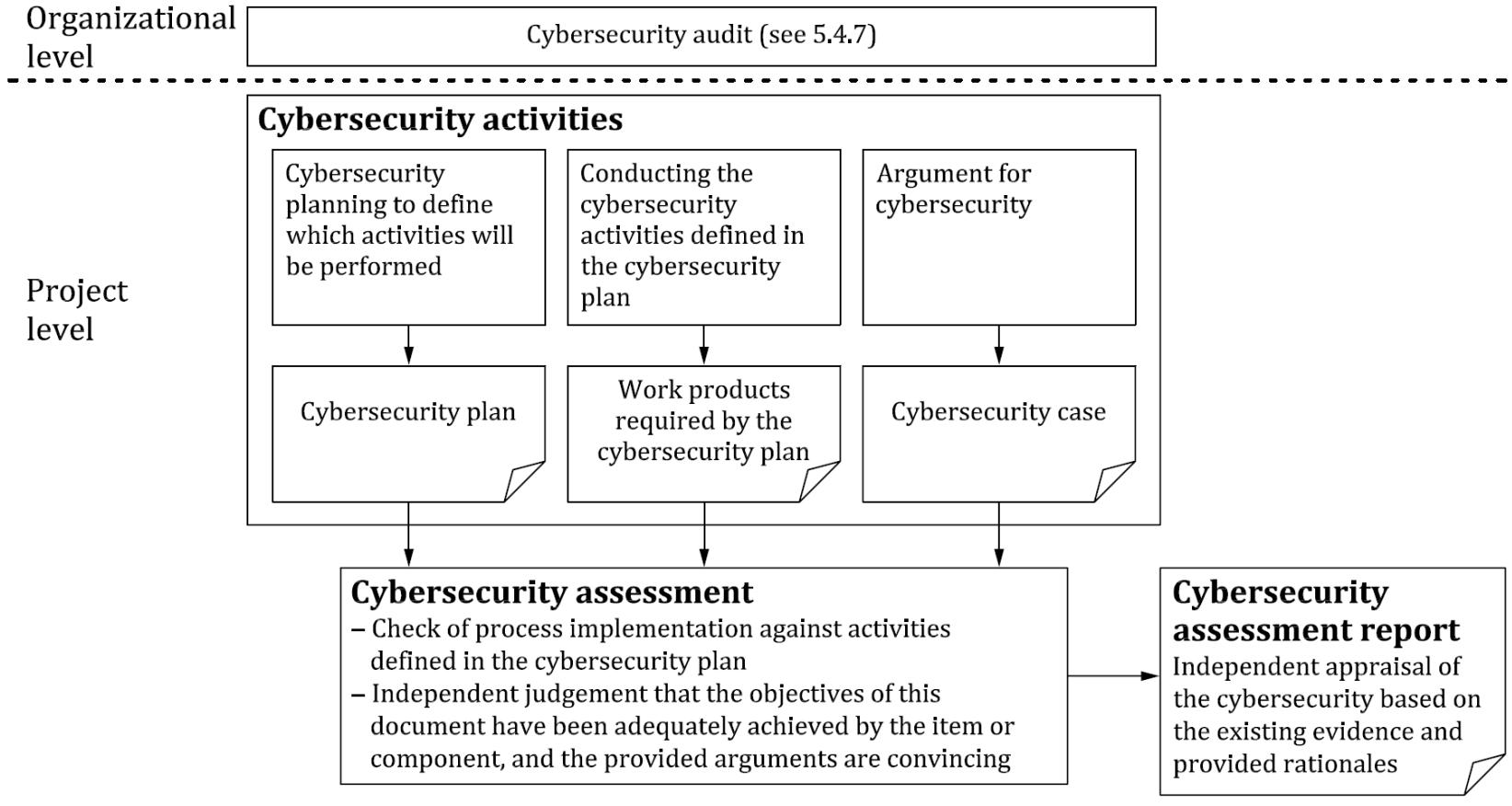


Figure 7 — Cybersecurity assessment in relation to other cybersecurity activities

source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Assessment

- A person responsible to plan and independently perform the cybersecurity assessment shall be appointed.

  NOTE 1: The independence scheme can be based on Automotive SPICE®3, IATF 16949[16] in conjunction with ISO 9001[3], or ISO 26262.

  EXAMPLE: A person of a quality assurance department within the organization, a person from a different team or department, or a person from an independent third party.

  NOTE 2: The person who carries out a cybersecurity assessment is subject to competence management.

- A cybersecurity assessment may be based on a judgement of whether the objectives of ISO/SAE 21434 are achieved.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Assessment

- A cybersecurity assessment report shall include a recommendation for acceptance, conditional acceptance, or rejection.

  NOTE: The assessment report can also include recommendations for improvement.

- A cybersecurity assessment report may include a recommendation for conditional acceptance provided the cybersecurity of the item contribution is achieved, subject to the resolution of the identified conditions for acceptance.

Scope of a CS Assessment:

a) The cybersecurity plan and all work products identified in the cybersecurity plan;
b) The treatment of the cybersecurity risks;
c) The appropriateness and effectiveness of implemented cybersecurity controls and cybersecurity activities performed for the project; and
d) The rationales, if provided, that demonstrate the achievement of the objectives of ISO/SAE 21434.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Confirmation Measure Reports (Recommended)

Reports are useful for the three types of Confirmation Measures (i.e., Reviews, Audits, Assessments).

As part of **Overall Cybersecurity Management (clause 5) and Project Dependent Cybersecurity Management (clause 6)**, a comprehensive review, audit, and report of the functional cybersecurity assessment, including the cybersecurity case, is specified.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Release for Post-Development

Objectives

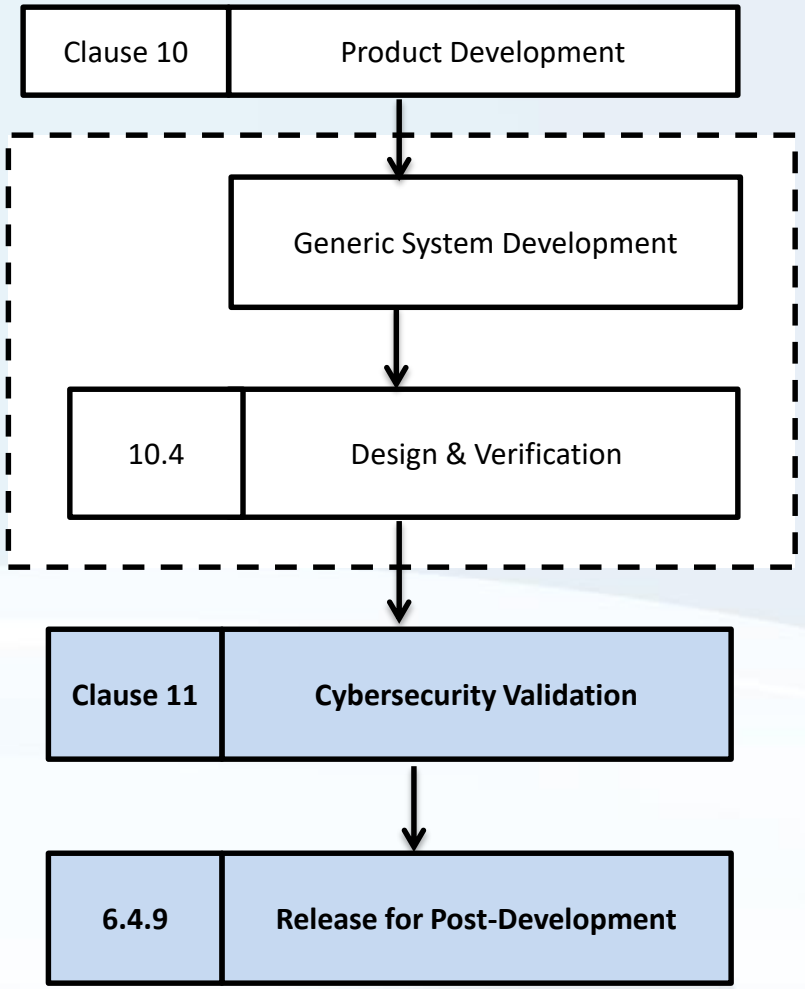
- Decide whether the item or component can be released for post-development from a cybersecurity perspective.

Prerequisites

- Cybersecurity case
- If applicable, cybersecurity assessment report
- Cybersecurity requirements for post-development

Work Products

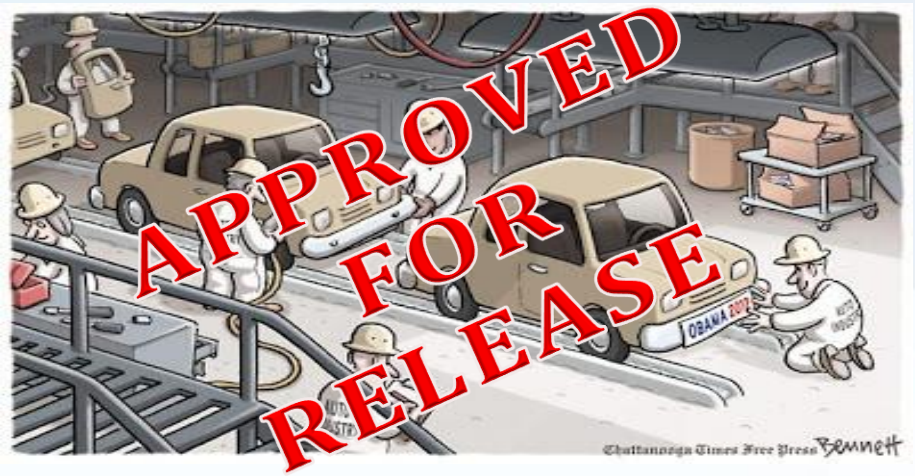
- Release for post-development report



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Release for Post-Development

- The last part of the Product Development Phase is Release for Post-Development.
- This is the conformation that the item complies with the requirements for cybersecurity at the Vehicle Level and confirms that the item is ready for mass production and operation.
  - **Remember, ISO/SAE 21434 does not concern itself with other characteristics!**



- ISO/SAE 21434 is clear about certain criteria:
  - There must be a **Release for Post-Development Report;**
  - Software and hardware **baseline shall be available and documented** (Configuration and Version information);
  - **Release date;**
  - Any identified **cybersecurity anomalies** addressed and documented.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Release for Post-Development

- The following WPs shall be available prior to the release for post-development:
  a) The cybersecurity case [**WP-06-02**];
  b) If applicable, the cybersecurity assessment report [**WP-06-03**]; and
  c) The cybersecurity requirements for post-development [**WP-10-02**]. O*M*N*E*X* OET

- The following conditions shall be fulfilled for the release for post-development:
  a) The argument for cybersecurity provided by the cybersecurity case is convincing;
  b) The cybersecurity case is confirmed by the cybersecurity assessment, if applicable; and
  c) The cybersecurity requirements for the Post-Development Phases are accepted.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 2

Define the Cybersecurity Case

Allotted Time: 90 minutes



Chapter 2: Cybersecurity Management (Clauses 5 & 6) — What We Covered

Competency 03: Plan and Perform Cybersecurity Management Activities

- Learning Objective 05: Plan and perform cybersecurity management activities at the Organizational Level
- Learning Objective 06: Plan and perform cybersecurity management activities at the Product/Project Level
- ***Breakout Exercise 2: Define the Cybersecurity Case***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 3

TARA and the Cybersecurity Concept Phase (Clauses 15 & 9)



OMNEX

Chapter 3: TARA and the Cybersecurity Concept Phase (Clauses 15 & 9) — What We Will Cover

Competency 04: Perform Activities of the Concept Phase, including a Basic TARA

- Learning Objective 07: Develop the Item Definition for a typical project
- ***Breakout Exercise 3: Create the Item Definition***
- Learning Objective 08: Perform an automotive TARA for a typical project
- ***Breakout Exercise 4: Perform a TARA***
- Learning Objective 09: Define cybersecurity goals for a typical project
- Learning Objective 10: Develop the cybersecurity concept for a typical project
- ***Breakout Exercise 5: Develop the Cybersecurity Goal, Cybersecurity Requirements, and Cybersecurity Concept***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

General Interactions In The Concept Phase

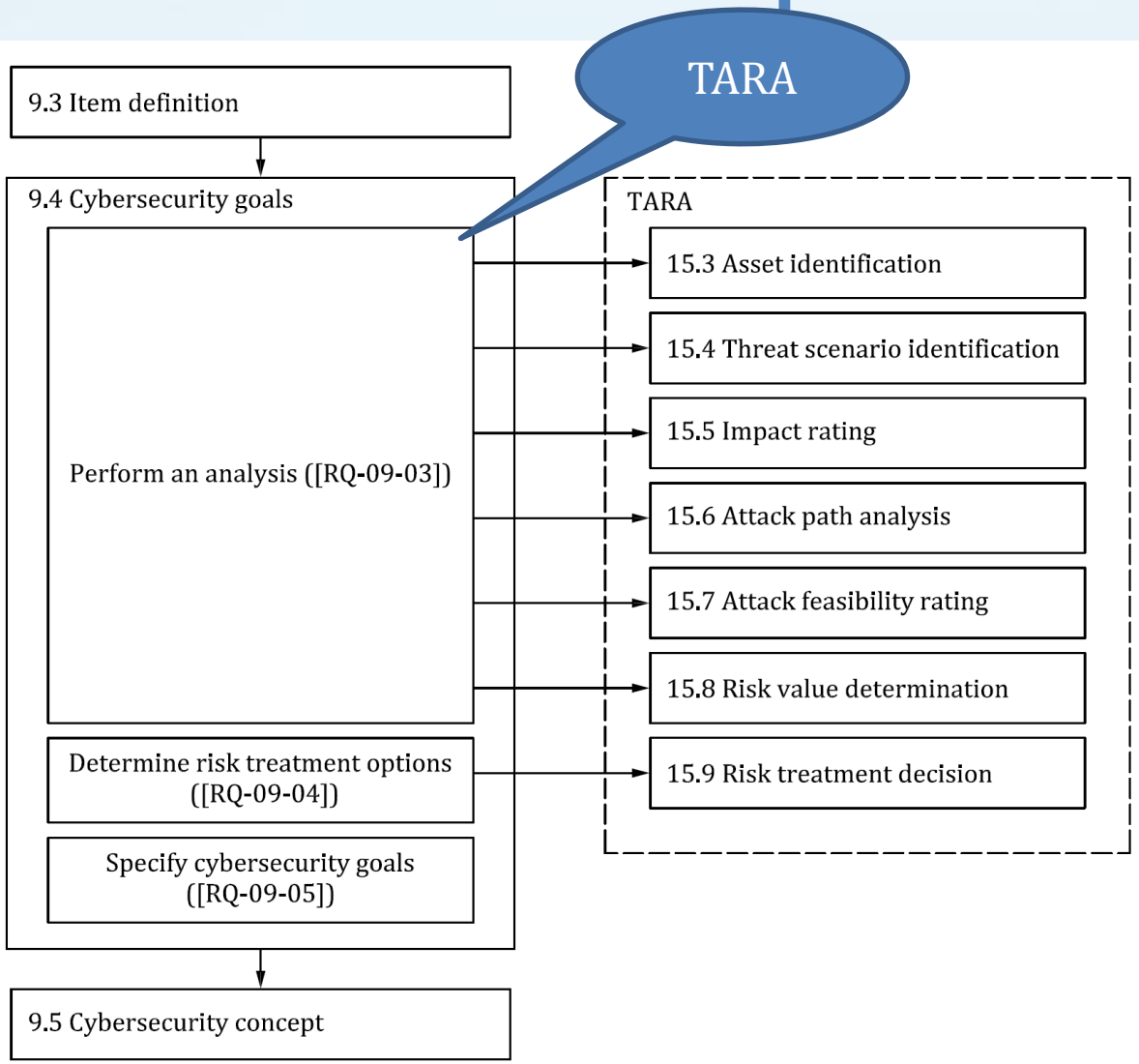


Figure H.1 — Interactions in concept phase

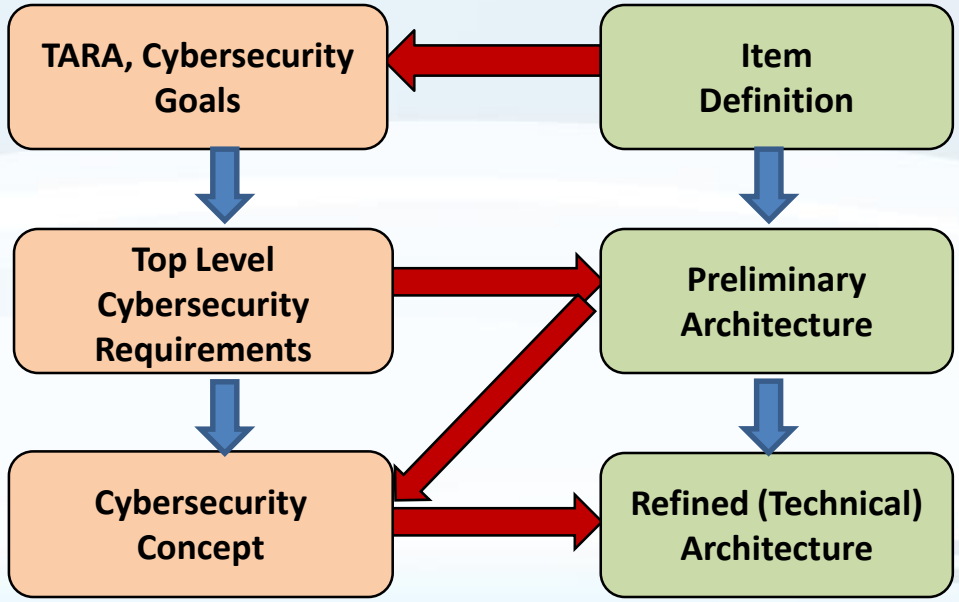
source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

9.3 Item Definition – Terminology

- An **item** is component or set of components that implements a function **at the Vehicle Level.**
  - Can involve sensors, controllers, and actuators related with each other.
- A system can be an item if it implements a function at the Vehicle Level, otherwise it is a component.

The base functionalities of the Item does not include Cybersecurity Controls.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Item Definition

A system is a set of **elements** that relate.

- An **element** is any sub-unit of an item, and might or might not be further divided into constituent elements.
  - An element that cannot be divided into further elements is a hardware part of software unit.
  - A divisible element can be labelled as a system, a subsystem, or a component.
- A component is a non-system level, logically and technically separable element.
  - Often the term component is applied to an element that is only comprised of parts and units.

- The following minimal information on the item shall be identified:
  - Item boundary;
  - Item functions;
  - Preliminary architecture; and
  - Descriptive information.

Additional Item information:

- Operational environment
- Internal interfaces to other item components
- External interfaces to other items
- Additional nonfunctional constraints
- Legal requirements

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Item Definition

(Systems Perspective)

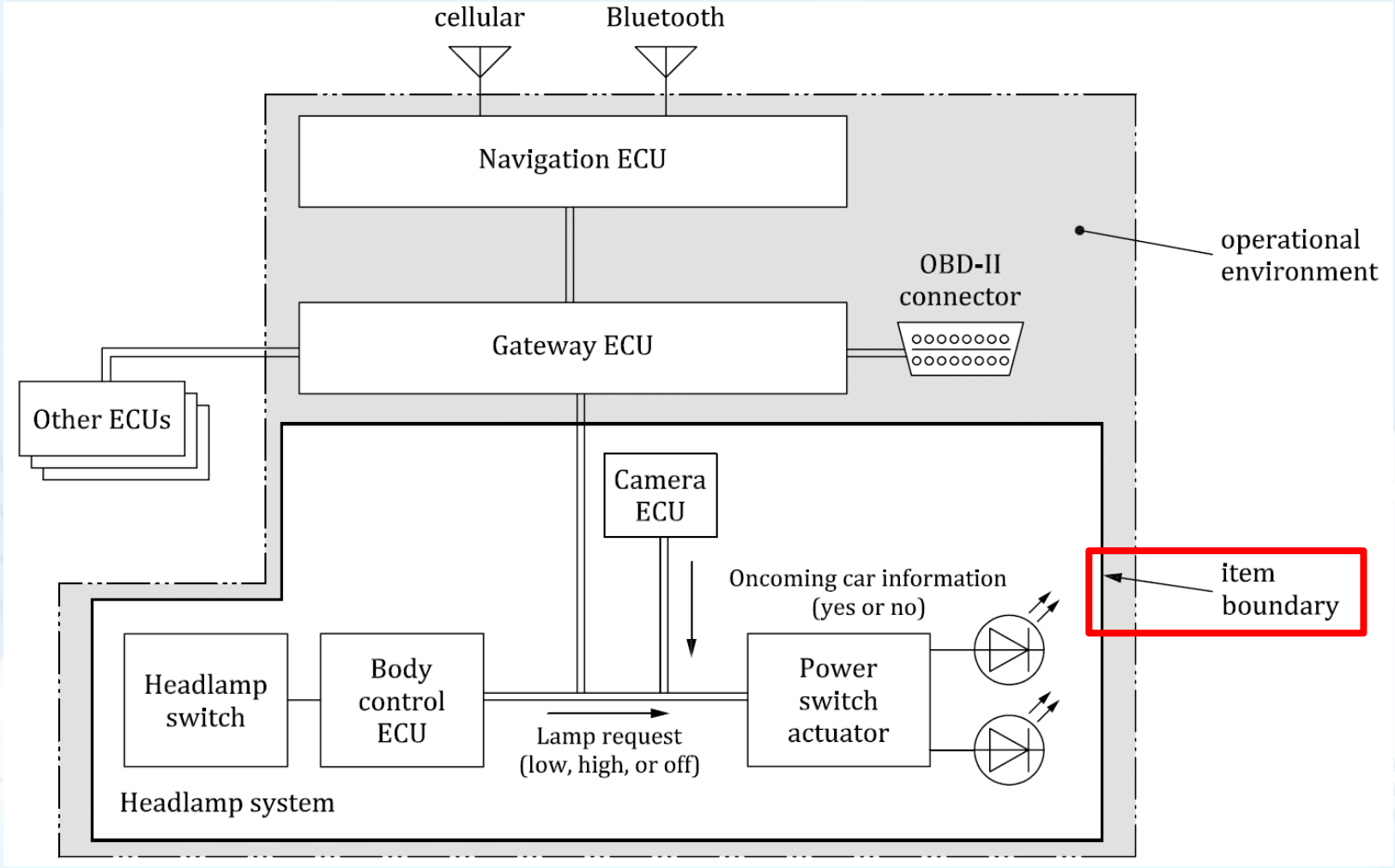
The boundary of the item, its interfaces, and the assumptions concerning its **interaction with other items** and elements, shall be defined considering:

- The elements of the item.

  NOTE: The elements could also be based on other technology.
- The assumptions concerning the effects of the item's behavior on **other items or elements**, that is the environment of the item.
- **Interactions** of the item with other items or elements.
- Functionality required by **other items**, elements and the environment.
- Functionality required from **other items**, elements and the environment.
- The use of functions among the involved systems and **allocation and distribution** elements.
- The operating scenarios which impact the functionality of the item.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example from Annex H: Headlamp System Boundary Diagram: Preliminary Architecture



source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 3

Create the Item Definition

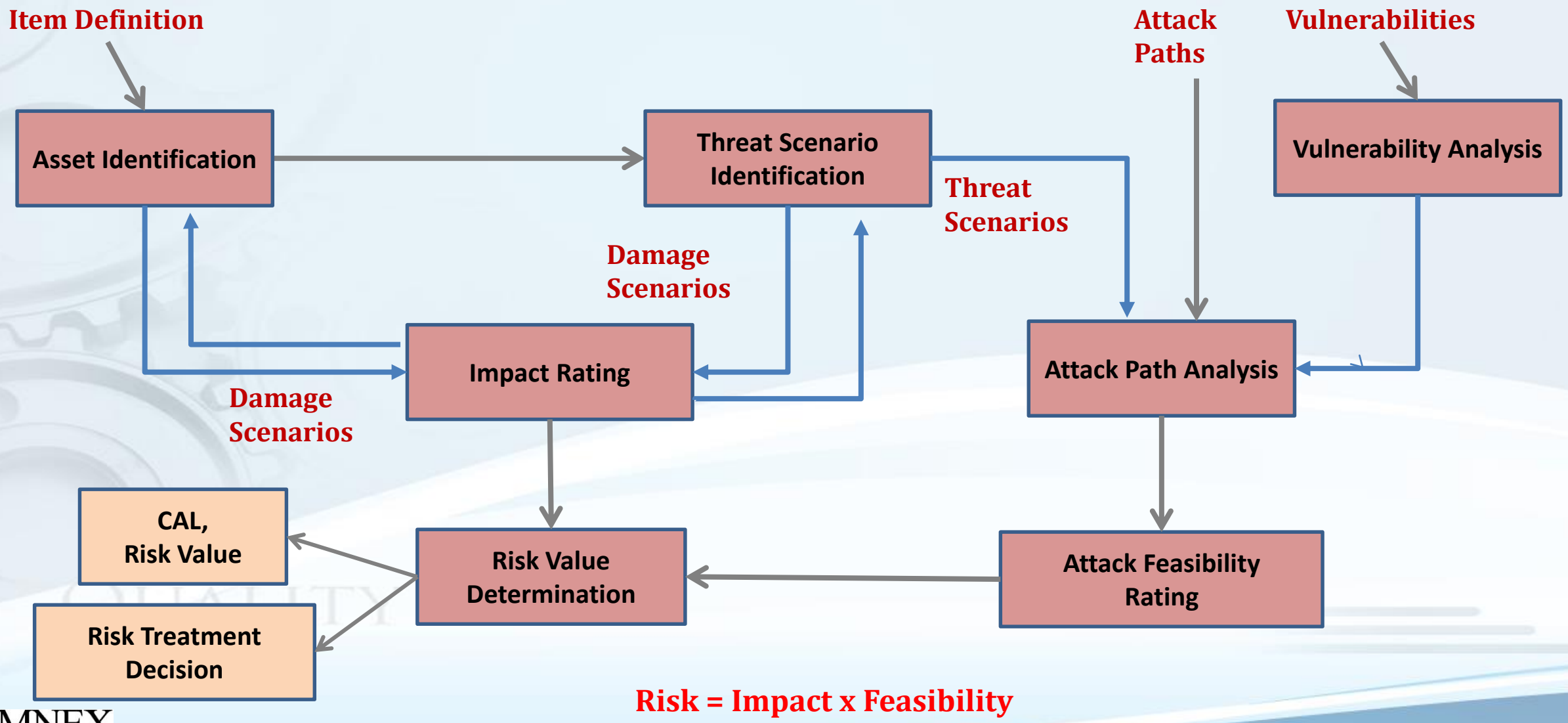
Allotted Time: 90 minutes



THREAT ANALYSIS AND RISK ASSESSMENT (TARA)



TARA (Threat Analysis & Risk Assessment) Structure

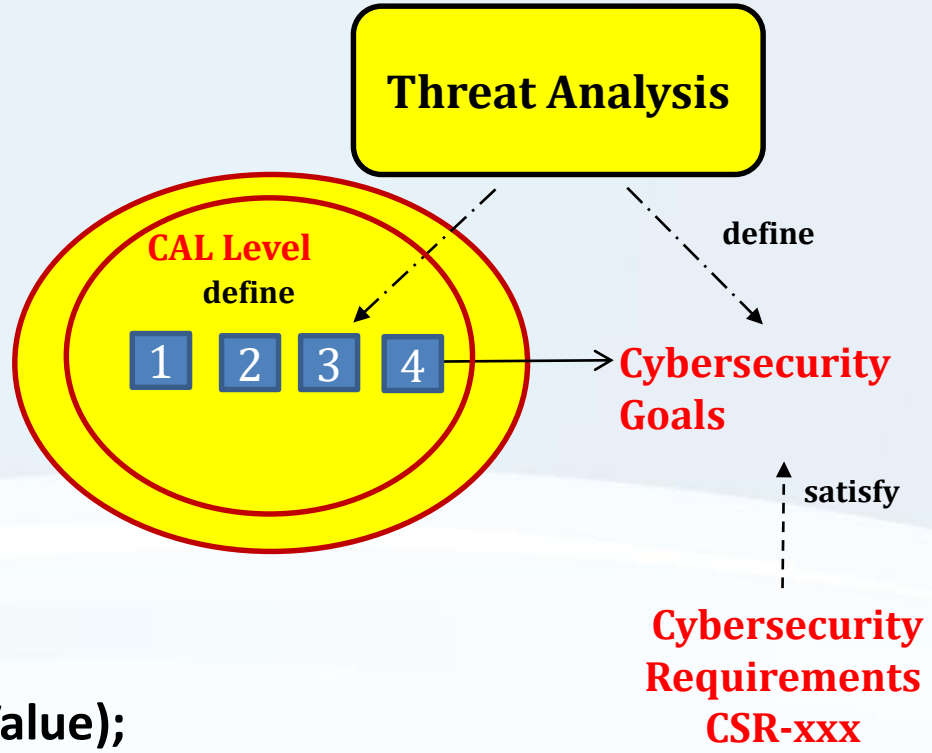


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

TARA Objectives

Threat Analysis and Risk Assessment (TARA) consists of three fundamental steps:

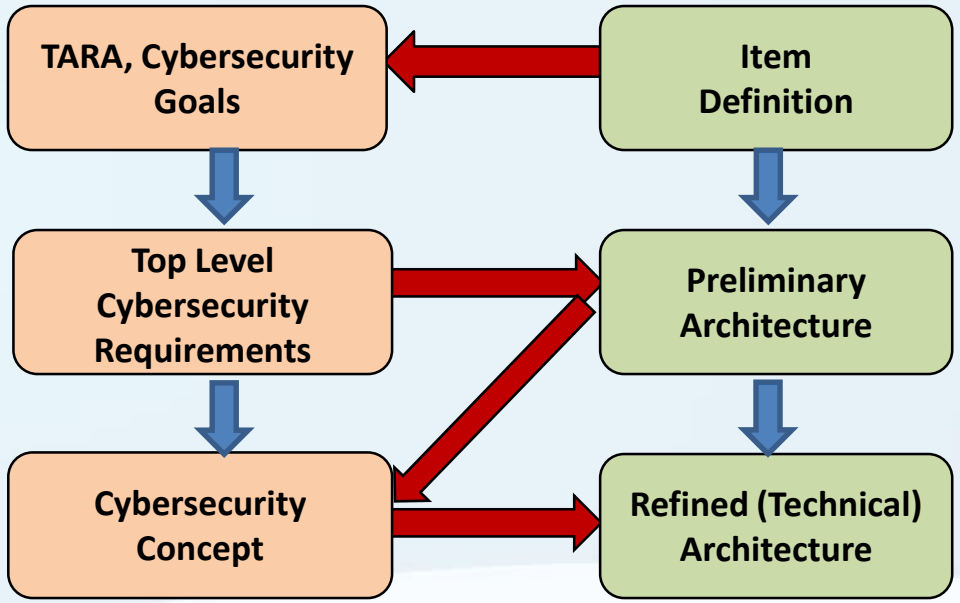
1. **Attack Feasibility**
   - Determine the possible threats for the item.
   - Vulnerability Analysis: Identify the potential vulnerabilities of the item that could lead to an attack.
2. **Risk Evaluation**
   - Determine the **Impact (I)** from the Impact Assessment, and **Damage Scenarios**.
3. **Estimation of Two Risk Levels**
   - Determine the **estimated dynamic levels of Risk and (Risk Value);**
   - **Cybersecurity Assurance Level (CAL).**



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Initiation of the TARA

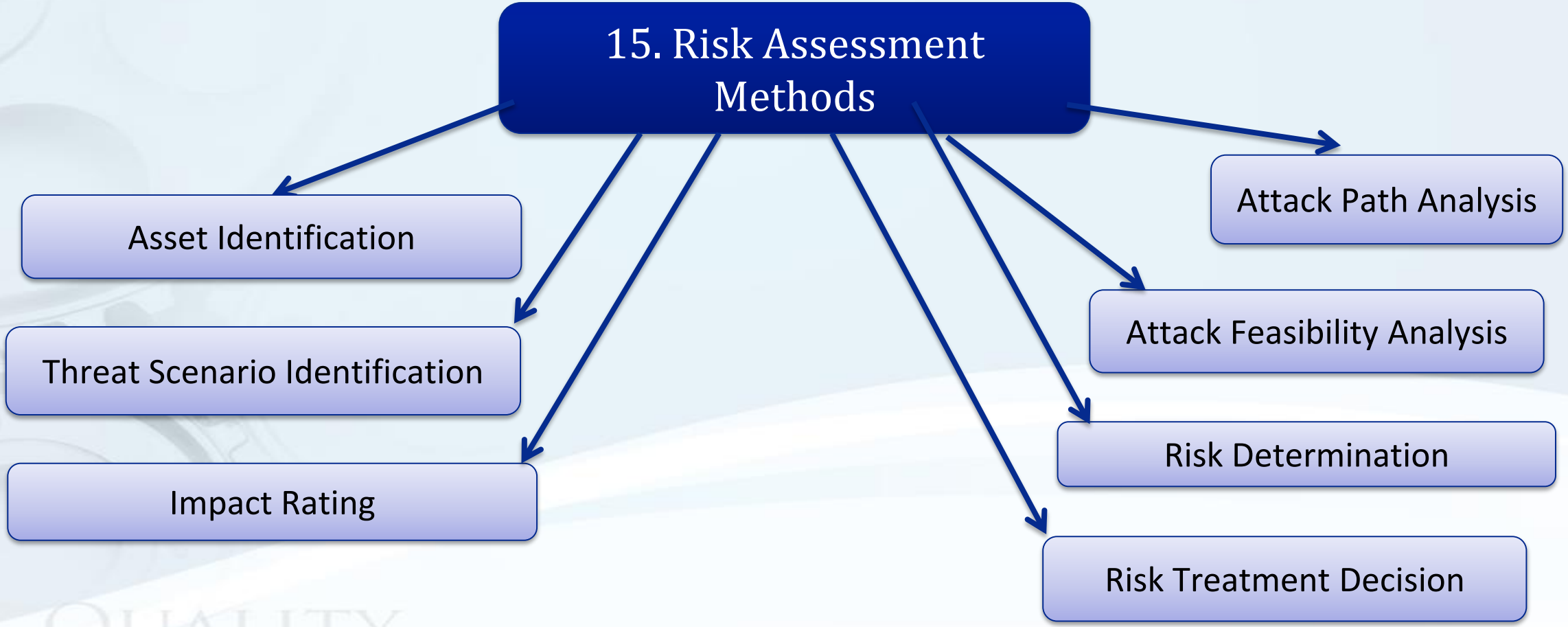
- The **Threat Analysis and Risk Assessment** (TARA) shall be based on the item definition.
- The item ***without internal cybersecurity mechanisms*** shall be evaluated during the threat analysis and risk assessment.
  - i.e., cybersecurity mechanisms intended to be implemented or that have already been implemented in predecessor items shall **not** be considered in the Threat Analysis and Risk Assessment.



If there are threats identified in this clause that are outside of the scope of ISO/SAE 21434, these threats shall be addressed according to organization-specific procedures.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Components of Risk Assessment Methods



All these methods are used throughout the cybersecurity lifecycle.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.3 Asset Identification

Objectives

The objective of this clause is the identification of:

- Assets;
- Their security properties (e.g., CIA);
- Damage scenarios (e.g., a safety, financial, operational or financial impact) in the event of the loss of their security properties.

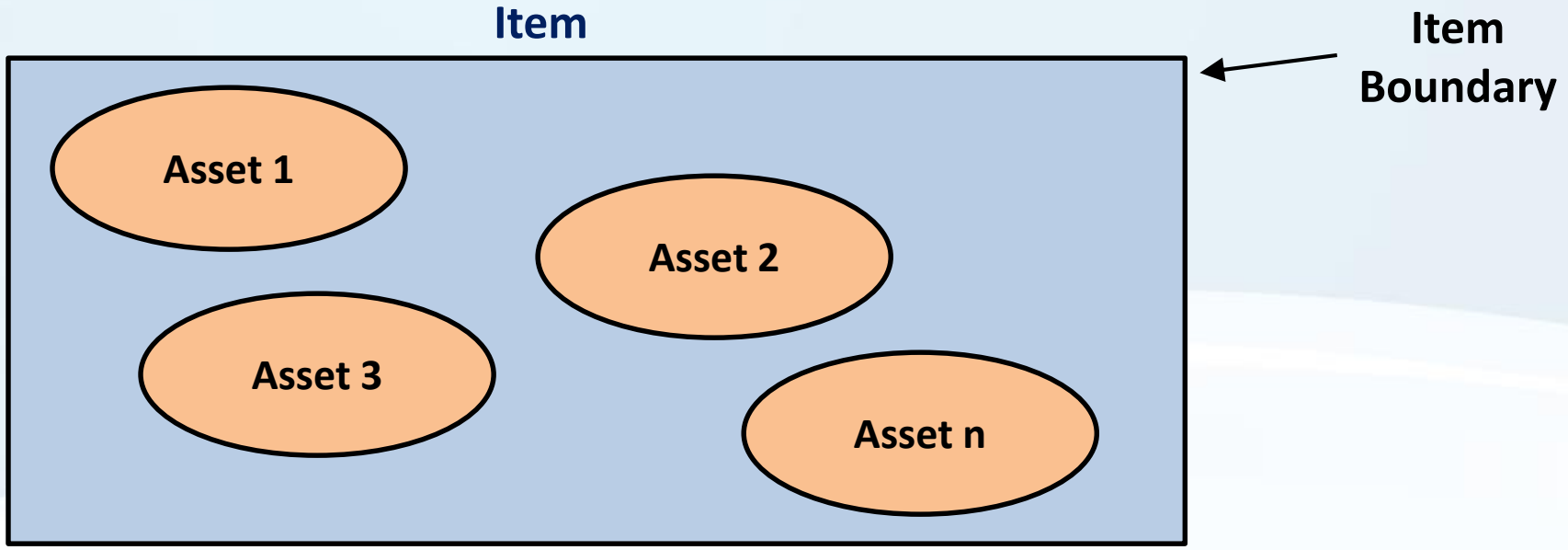
General

- Asset assessment is an activity for identification of assets in an item.
- A thing or a unit of value is an asset in the cybersecurity context only if loss of any of its security properties leads to damages to the item's stakeholders.
- Asset identification is the process of determining if a candidate asset is truly an asset.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.3 Asset Identification

Assets are tangible or intangible things or units of value within a defined item as depicted in the figure below. Assets are contained in an item. It is feasible for the item to be the actual asset.



Assets are similar to elements in Functional Safety.
Assets can be decomposed systematically using block diagrams (for example) for requirements allocation purposes.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

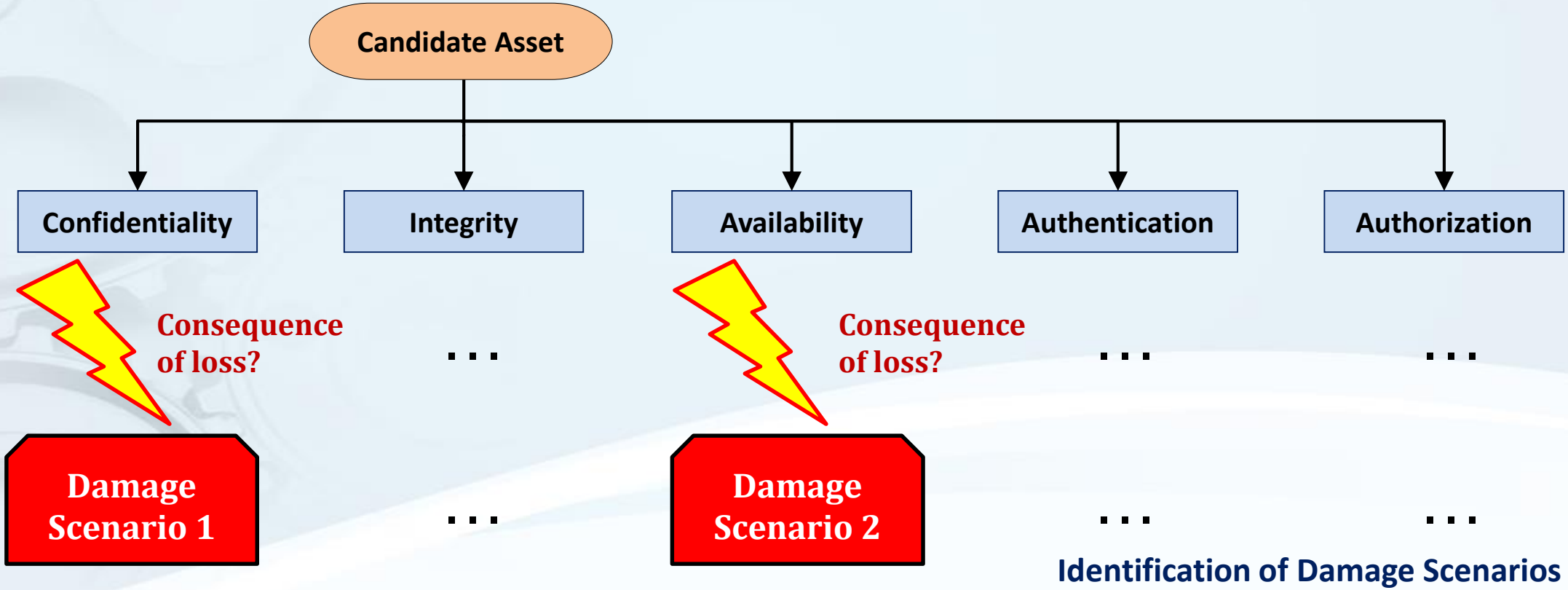
15.3 Asset Identification

- Asset identification performs the following:
  - The security properties of candidate assets are identified.
  - The damage scenarios that could occur due to the loss of any security property (or properties) of the candidate assets (or group of candidate assets) are identified.
  - Impact assessment further analyzes the damage scenarios to establish the extent of damage.

- Any candidate asset whose loss of a security property could potentially lead to a damage scenario with a non-negligible impact rating (i.e., severe, serious, and moderate) is classified as an asset.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.3 Asset Identification



Candidate Asset = Asset

because loss of Confidentiality causes Damage Scenario 1, and because loss of Availability causes Damage Scenario 2 for stakeholders.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.3 Asset Identification

Inputs

- Item definition and information regarding operational environment.

Requirements and Recommendations

- Candidate assets shall be identified.
- Potential damage scenarios shall be identified.
- An impact analysis shall be performed on the potential damage scenarios.
- Candidate assets with security properties whose loss leads to non-negligible impacts, per an impact analysis, shall be identified as assets.

Characteristics of an Asset:

- Something to be protected;
- Has a relevant security property, e.g., integrity, authentication;
- Involves a damage scenario;
- It is a starting point for risk management (e.g., TARA).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.3 Asset Identification

Work Products

- Damage scenarios
- Assets with cybersecurity properties

EXAMPLE 1:

(Asset 1, relevant security property, damage scenario) =

(braking ECU messages, Integrity, Physical harm to passengers)

EXAMPLE 2:

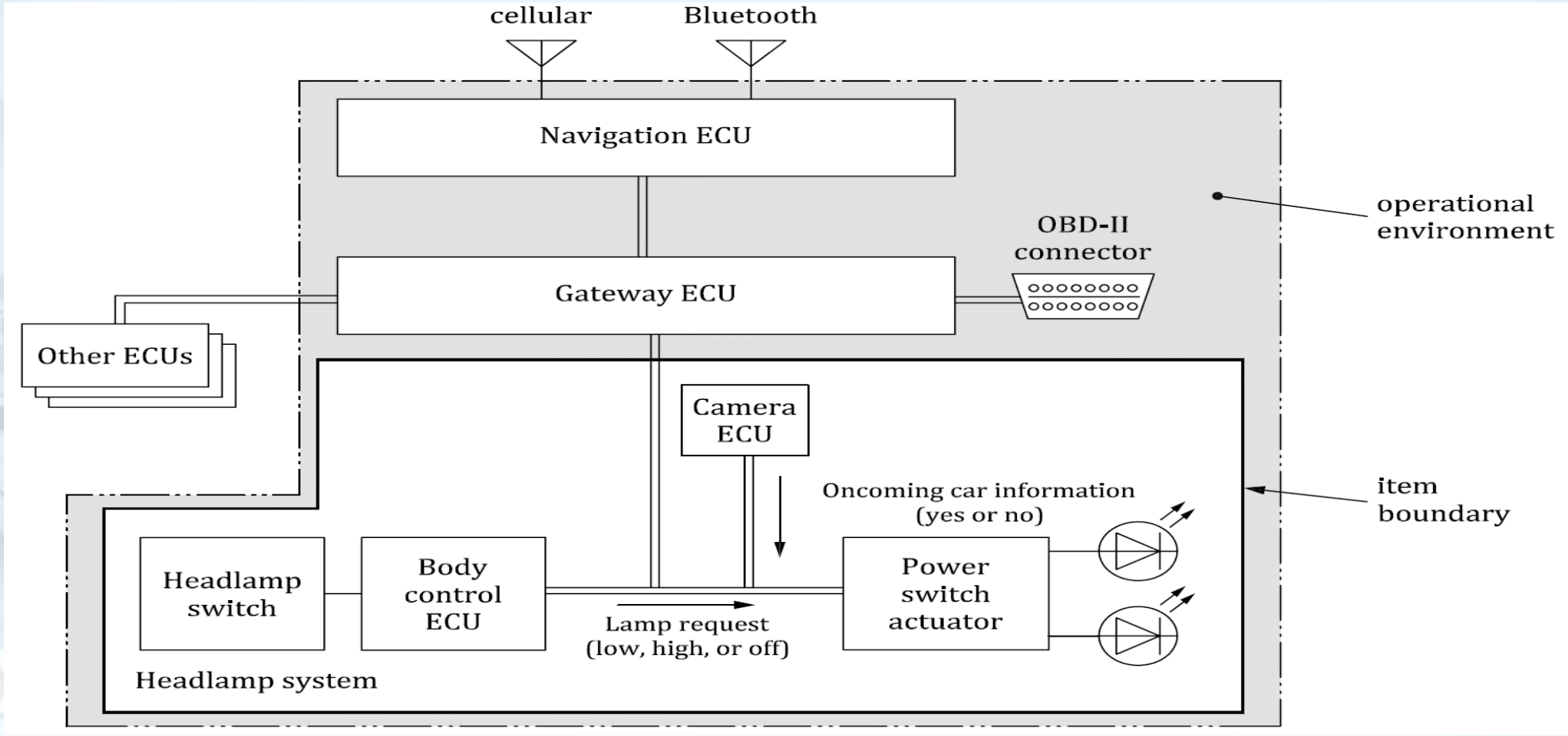
(Asset 2, relevant security property, damage scenario) =

(customer personal preferences, Confidentiality, Loss of individual privacy, problems for individual in personal sphere that could lead to financial losses, or reputation losses, regulatory breach for the business)

NOTE: cybersecurity properties include at least confidentiality (C), integrity (I), and Availability (A).
Others: Authentication(A), Authorization (A).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Annex H: Example Use Case – Headlamp System



source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example from Annex H: Headlamp System Boundary Diagram

Table H.2 — Example List of Assets and Damage Scenarios

Asset	Cybersecurity Property			Damage Scenario
	C	I	A	
Data communication (lamp request)	—	X	X	Vehicle cannot be driven at night because (the driver perceives) the headlamp function was inhibited while parked.
	—	X	—	Front collision with a narrow stationary object (e.g., a tree) caused by unintended turning-off of headlamp during night driving at medium speed.
Data Communication (oncoming car information)	—	X	—	Drivers of oncoming vehicles are blinded, it is caused by not being able to change to low beam during night driving.
	—	—	X	Malfunctioning automatic high beam caused by headlamp always remaining at low beam during night driving.
Firmware of body control ECU	X	X	—	…

C: Confidentiality I: Integrity A: Availability

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.4 Threat Scenario Identification

Objectives

- The objective of this subclause is to identify threat scenarios that can potentially compromise the cybersecurity properties of the identified assets.

General

- Threat scenario identification is an activity that systematically identifies threat scenarios to the cybersecurity properties of the assets under analysis.
- If more information about a threat scenario is available, such as the threat agent who initiates action, the method, tools, entry points, it can be documented to provide further information to the risk assessment process (e.g., attack path analysis, attack feasibility).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.4 Threat Scenario Identification

Inputs

- Item definition
- Cybersecurity specifications
- Damage scenarios
- Assets with cybersecurity properties

Work Products

- Threat scenarios

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.4 Threat Scenario Identification

Requirements and Recommendations

- Threat scenarios shall be identified and include:
  - Targeted asset;
  - Compromised cybersecurity property of the asset; and
  - Cause of compromise of the cybersecurity property.

EXAMPLE 1:

Threat scenario: Unauthorized disclosure of crash data stored in the data crash leading to rejection by insurance company of insurance claim made by the vehicle owner.

EXAMPLE 2:

Spoofing of CAN (Controller Area Network) messages for the powertrain ECU (Electronic Control Unit) causing uncontrollable acceleration of the vehicle leading to loss of passenger safety causing physical harm to the vehicle user.

Threat scenarios are analogous to safety hazards in Functional Safety (ISO 26262).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Impact

- Impact estimates of magnitude of harm originating from a threat and/or attack.
- The objective is to assess the impact or the extent of damage of a given damage scenario.
- Impact is a property of the asset under analysis, i.e., the impact of a damage scenario remains the same irrespective of whether:
  - The attack path that leads to the damage, or
  - A particular threat agent, or
  - The way the threat scenario is accomplished.



Road User



Security



Personal Data

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Core Impact Categories

The damage scenarios shall be assessed against potential adverse consequences in the impact categories of (**S, F, O, P**) for road users:



- **S** = Safety
- **F** = Financial
- **O** = Operational
- **P** = Privacy

NOTE: An adverse harm could result in impacts in more than one of these categories (**S, F, O, P**), e.g., a damage scenario has both a safety and a financial impact to the road user; or a damage scenario has both a privacy and financial impact to the road user.

Impact categories (**S, F, O, P**) may be extended with optional categories that consider the adverse harm to business, and those optional categories parameters shall be documented.

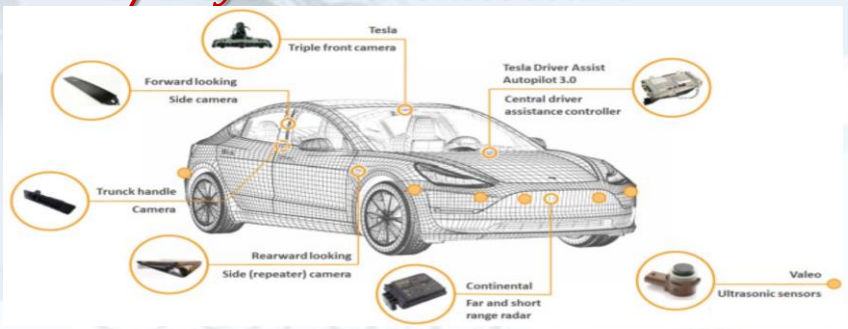
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Operational Environment

Existing information regarding the item and the operational environment can be considered:

- In-vehicle E/E system architecture including in-vehicle network;
- Networks external to the vehicle;
- Functions of the item; and/or
- Reference model(s) and the documentation of earlier developments/lessons learned.

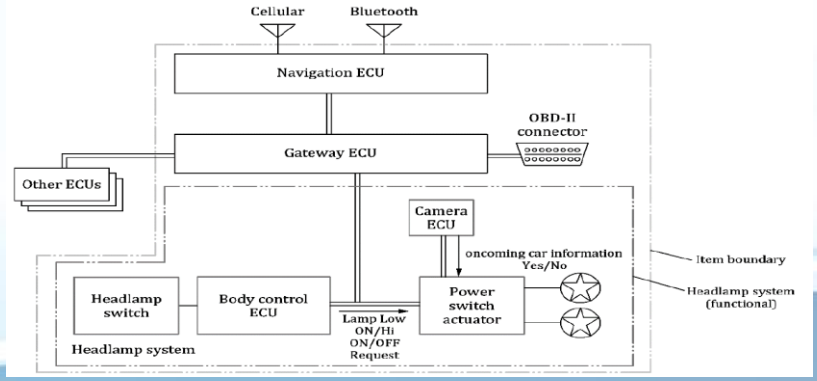
E/E system architecture



Networks external to the vehicle



Functions of the Item



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.5 Impact Rating

Objectives

- To rate the impact of the identified damage scenarios.

General

- Impact rating estimates the magnitude of damage or physical harm due to compromise of cybersecurity property of the asset. The impact of a damage scenario is the same regardless of:
  - The attack path that leads to the damage, or
  - A particular threat agent.
- Potential impacts are assessed relative to:
  - Road users (i.e., the primary stakeholders);
  - Other persons who could be harmed;
  - Other entities (i.e., business may include other entities as stakeholders).
- Impact is assessed in the core categories of:
  Safety, Financial, Operational, and Privacy (**S, F, O, P**).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Estimating Impact

- The organization shall ensure the persons involved in vehicle cybersecurity are aware of the potential impact of cybersecurity threats.

  EXAMPLE: Through an awareness and training program.

- The organization needs to utilize specified parameters and organization-specific extensions to complete impact assessment.
- Impact assessment analyzes the damage scenarios to establish the extent of damage.
- Any candidate asset whose loss of a security property could potentially lead to a damage scenario with a non-negligible impact rating (i.e., severe, serious, moderate and negligible) is classified as an asset.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.5 Impact Rating: Safety

- The impact of damage scenarios shall be evaluated based on rationale.
- Impacts shall be classified to a generic impact level: “Severe”, “Major”, “Moderate”, or Negligible”.
- Additional tables for the other categories are provided in Annex F.

Table F.1 — Example Safety Impact Rating Criteria

Impact Rating	Criteria for Safety Impact Rating
Severe	S3: Life-threatening injuries (survival uncertain), fatal injuries
Major	S2: Severe and life-threatening injuries (survival probable)
Moderate	S1: Light and moderate injuries
Negligible	S0: No injuries [a]
A Rating for **S0** can be based on **ISO 26262-3:2018, Table B.1**.	

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.5 Impact Rating: Financial

Table F.2 — Example Financial Impact Rating Criteria

Impact Rating	Criteria for Financial Impact Rating
Severe	The financial damage leads to catastrophic consequences which the affected road user might not overcome.
Major	The financial damage leads to substantial consequences which the affected road user will be able to overcome.
Moderate	The financial damage leads to inconvenient consequences which the affected road user will be able to overcome with limited resources.
Negligible	The financial damage leads to no effect, negligible consequences or is irrelevant to the road user.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.5 Impact Rating: Operational

Table F.3 — Example Operational Impact Rating Criteria

Impact Rating.	Criteria for Operational Impact Rating
Severe	The operational damage leads to the loss or impairment of a core vehicle function. EXAMPLE 1: Vehicle not working or showing unexpected behavior of core functions such as enabling of limp home mode or autonomous driving to an unintended location.
Major	The operational damage leads to the loss or impairment of an important vehicle function. EXAMPLE 2: Significant annoyance of the driver.
Moderate	The operational damage leads to partial degradation of a vehicle function. EXAMPLE 3: User satisfaction negatively affected.
Negligible	The operational damage leads to no impairment or non-perceivable impairment of a vehicle function.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.5 Impact Rating: Privacy Damage

Table F.4 — Example Privacy Impact Rating Criteria

Impact Rating	Criteria for Privacy Rating
Severe	The privacy damage leads to significant or even irreversible impact to the road user. The information regarding the road user is highly sensitive and easy to link to a PII principal.
Major	The privacy damage leads to serious impact to the road user. The information regarding the road user is: a) highly sensitive and difficult to link to a PII principal; or b) sensitive and easy to link to a PII principal.
Moderate	The privacy damage leads to inconvenient consequences to the road user. The information regarding the road user is: a) sensitive but difficult to link to a PII principal; or b) not sensitive but easy to link to a PII principal.
Negligible	The privacy damage leads to no effect, or negligible consequences or is irrelevant to the road user. The information regarding the road user is not sensitive and difficult to link to a PII principal.

Personally identifiable information (PII) and PII principal can be defined in accordance with ISO/IEC 29100.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Application of Impact, Interest, and Accessibility

Example: Cruise Control

- **Threat:** *"Unintended Acceleration: Cruise Control is not deactivated when the driver is braking due to a cyber attack"*



- **Operational Situation:** speed > 30 mph on two-lane suburban roads
- **Threat Effect:** Collision with vehicle in front
  - Impact ➔ **Major (S2)= Severe injuries, possibly life-threatening**
  - Attack Vector ➔ **Network (cellular interface to IVI (in-vehicle entertainment) to vehicle gateway to cruise controller)**

Risk = CAL4

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.6 Attack Path Analysis

Objectives

- The objective of attack path analysis is to identify and/or update the attack paths to realize a threat scenario.

General

- This subclause describes the process of identifying and linking potential attack paths to threat scenario.
- This is done systematically using details of the applicable architecture, as well as design and implementation information as product development progresses.
- Attack paths form the basis for the assessment of attack feasibility.
- They are also used for the refinement of cybersecurity goals to cybersecurity requirements and support the selection of appropriate controls.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.6 Attack Path Analysis

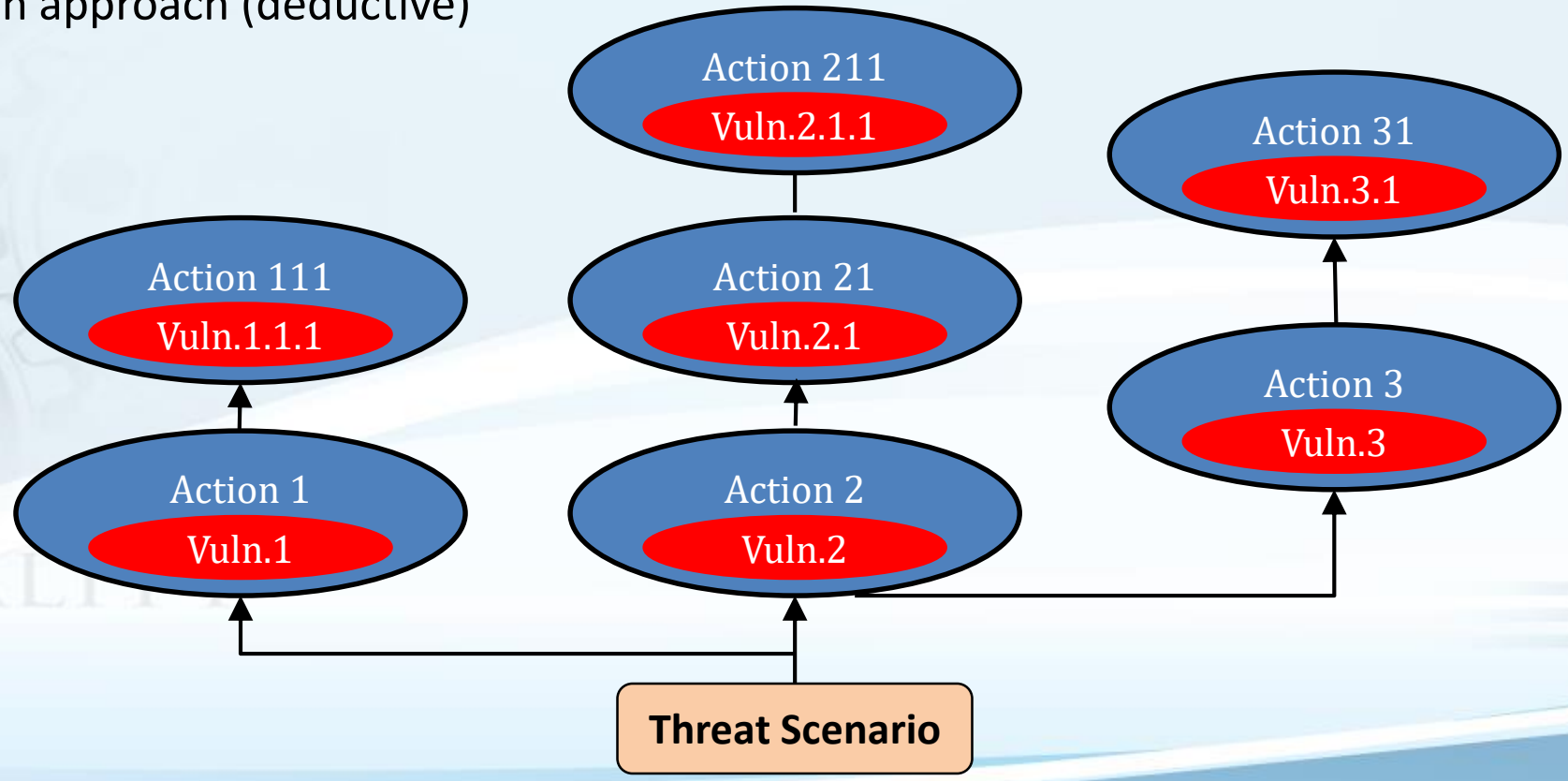
Bottom-up Approach (inductive)

- Attack paths are built for the target-of-analysis from the cybersecurity vulnerabilities identified. Each action in the attack path is based on an “exploitable flaw or weakness”.
- The top-down approach is most commonly used when an implementation of the target-of-analysis is available, or when hypothesis of attack model are to be confirmed.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.6 Attack Path Analysis

- The threat scenarios shall be analyzed using a defined attack analysis approach to describe possible attack paths:
  - Bottom-up approach (inductive)
  - Top-down approach (deductive)



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

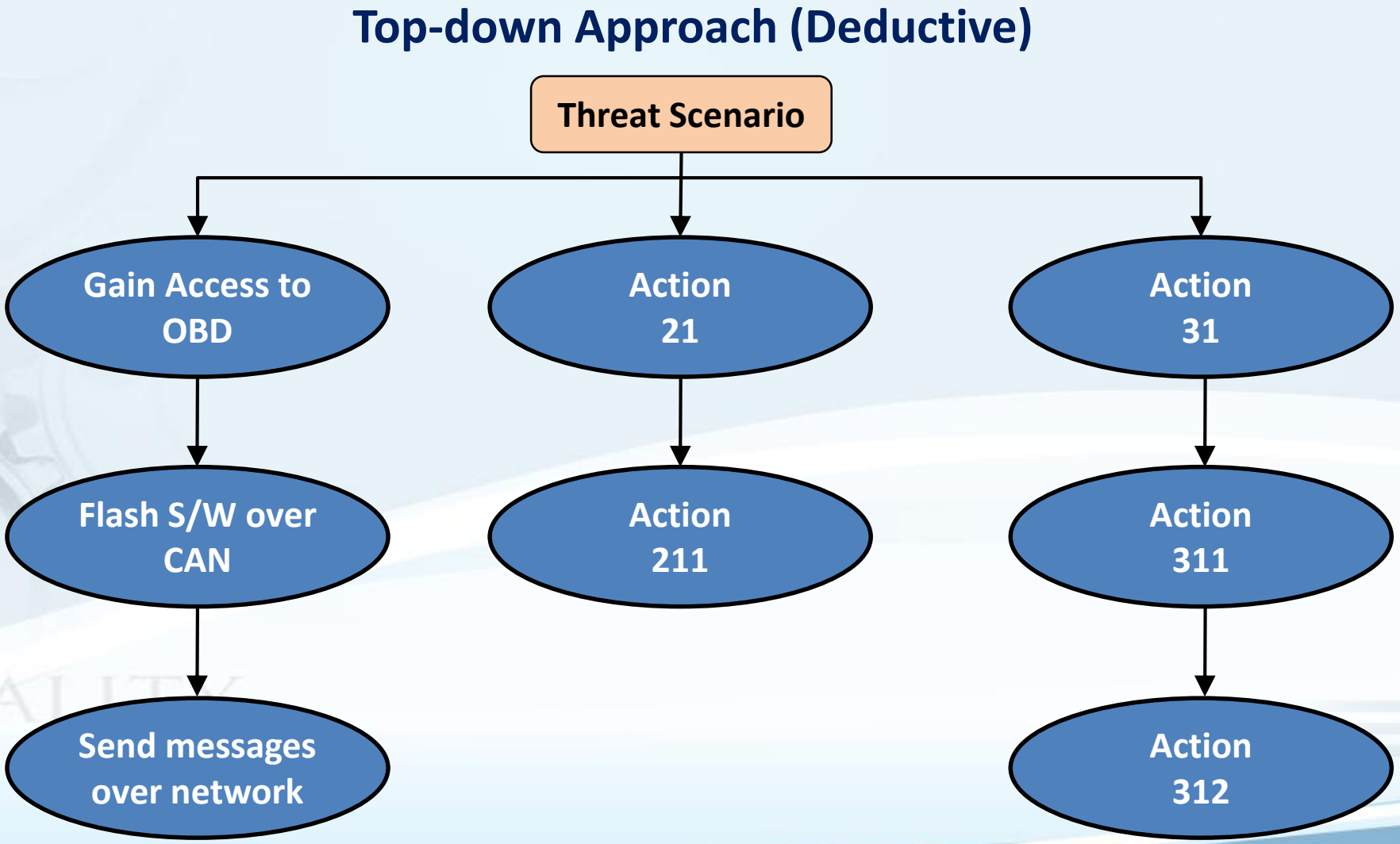
15.6 Attack Path Analysis

Top-down Approach (Deductive)

- Attack paths are deduced (i.e., theorized, inferred, reasoned, conjectured) for the target-of-analysis based on historical knowledge of vulnerabilities in similar systems and technologies.
- The top-down approach is useful in the conceptual and design phases when an implementation of the current target-of-analysis is not available, or when effort is directed toward building attack hypothesis or attack path models.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.6 Attack Path Analysis



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.6 Attack Path Analysis

Requirements and Recommendations

An attack path shall be associated with the threat scenarios that can be realized by the attack path.

EXAMPLE: Attack path description:

Threat Scenario:

"spoofing of CAN messages for the braking ECU leads to loss of integrity of the CAN messages and thereby to loss of integrity of the braking function."

Attack Path realizing the above threat scenario:

i. The telematics ECU is compromised via the cellular interface;

ii. The gateway ECU is compromised via CAN communication from the telematics ECU;

iii. The gateway ECU forwards malicious braking request signals (unwanted rapid deceleration).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.7 Attack Feasibility Rating

Objectives

- The objective of the attack feasibility assessment is to assess the ease with which identified attack paths may be exploited.

General

- This clause specifies requirements and recommendations for rating the feasibility of attack paths based on the ease of exploitation.
- It is intended to be able to handle information at different abstraction levels during an attack feasibility rating. For example, a high-level attack path description might be available from the Concept Phase, and a more concrete attack path description might be available in the later phases.
- An attack feasibility rating is possible in both cases.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Attack Feasibility Rating

Requirements and Recommendations

- For each attack path, the attack feasibility rating shall be determined as described in the table below.

Table 1 — Attack Feasibility Ratings and Respective Descriptions

Attack Feasibility Rating	Description
High	The attack path can be accomplished utilizing low effort.
Medium	The attack path can be accomplished utilizing medium effort.
Low	The attack path can be accomplished utilizing high effort.
Very Low	The attack path can be accomplished utilizing very high effort.

- The attack feasibility rating method should be defined based on one of the following approaches:
  - Attack potential-based approach;
  - CVSS-based approach; or
  - Attack vector-based approach.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Attack Feasibility Rating

Requirements and Recommendations

- If an attack potential-based approach is used, the attack feasibility rating should be determined based on core factors including:
  - Elapsed time,
  - Specialist expertise,
  - Knowledge of the item or component,
  - Window of opportunity,
  - Equipment.

NOTE 2: The core attack potential factors can be derived from ISO/IEC 18045.

NOTE 3: G.2 provides guidelines on determining attack feasibility based on attack potential.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Attack Feasibility Rating

- If a CVSS-based approach is used, the attack feasibility rating should be determined based on the exploitability metrics of the base metric group, including:
  - Attack vector;
  - Attack complexity;
  - Privileges required; and
  - User interaction.
- If an attack vector-based approach is used, the attack feasibility rating should be determined based on evaluating the predominant attack vector of the attack path.

NOTE 6: During the early stages of development (e.g., Concept Phase), when there is insufficient information to identify specific attack paths, an attack vector-based approach can be suitable to estimate attack feasibility.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

RISK VALUE DETERMINATION



15.8 Risk Value Determination

Objectives

- The objective is to determine the risk value of a threat scenario.

General

- For each threat scenario, the risk value shall be determined.
- Risk value is determined as a function of:
  - The **impact rating** of the associated damage scenario;
  - The **attack feasibility rating** of the corresponding attack paths.
- Generally, a risk determination follows a threat analysis.
- The result is a relatively ordered set of threats with the corresponding risk level(s), which forms the basis for risk treatment decisions.

NOTE: *ISO/SAE 21434 uses two ways to estimate risk: CAL and Risk Value*.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Assurance Levels (Annex E)

Objectives

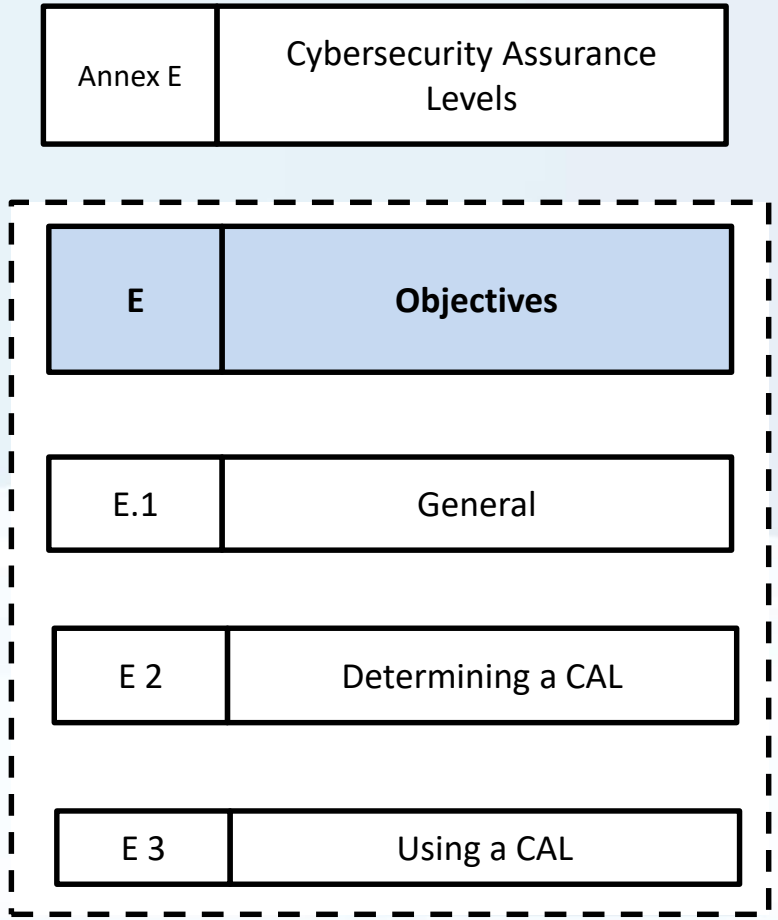
- Define the Cybersecurity Assurance Level (CAL) and how it may be used as a common language for communicating cybersecurity assurance requirements among organizations.

Prerequisites

- The cybersecurity requirements at the System, Hardware, or Software Levels
- The architectural information at the level at which the CAL is to be applied

Work Products

- Update of architectural information
- Update of CAL as attribute of cybersecurity requirements and elements



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.1 General

- Annex E describes a **Cybersecurity Assurance Level** (CAL) classification scheme that can be used to specify and communicate a set of assurance requirements, in terms of levels of rigor to provide confidence that protection of the assets of an item or component is adequately developed.
- This CAL classification scheme does not specify technical requirements for cybersecurity controls.
- However it can be used to drive the cybersecurity engineering, providing a common language for communicating cybersecurity assurance requirements among the organizations involved.
- A CAL can be determined by the organization developing an item or assumed by an organization developing a component out-of-context.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

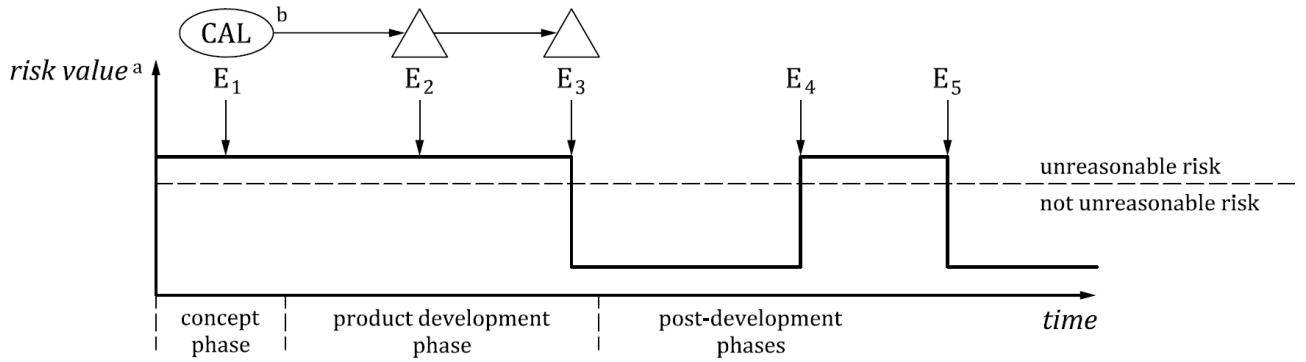
E.2 Determining a CAL

- Once determined, a CAL specifies the amount of rigor required in the subsequent product development activities to address threat scenarios requiring risk reduction. This can be achieved by assigning the CAL as an attribute of a cybersecurity goal, which is inherited by refined cybersecurity requirements.
- A CAL is indirectly related to risk; however, it cannot be directly determined from a risk value.
- This is because the risk value is dynamic, varying over time depending on the evolving specification, design, implementation and operational environment of the item or component, whereas the CAL expresses a level of assurance that is to remain fixed over time (see figure on next slide).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.2 Determining a CAL

Relationship between CAL and Risk



Key

E_1	Event 1: cybersecurity requirement is specified.
E_2	Event 2: cybersecurity control is implemented.
E_3	Event 3: test shows cybersecurity control is effective.
E_4	Event 4: vulnerability is discovered in the field.
E_5	Event 5: vulnerability is fixed.
⬭	CAL is determined and assigned.
△	CAL is applied in cybersecurity activities.
a	Risk value is dynamic and can vary depending on current specification, design or implementation.
b	The expected level of assurance determined at E_1 given the criticality of the assets to be protected prescribes the rigour of subsequent cybersecurity activities at E_2, E_3.

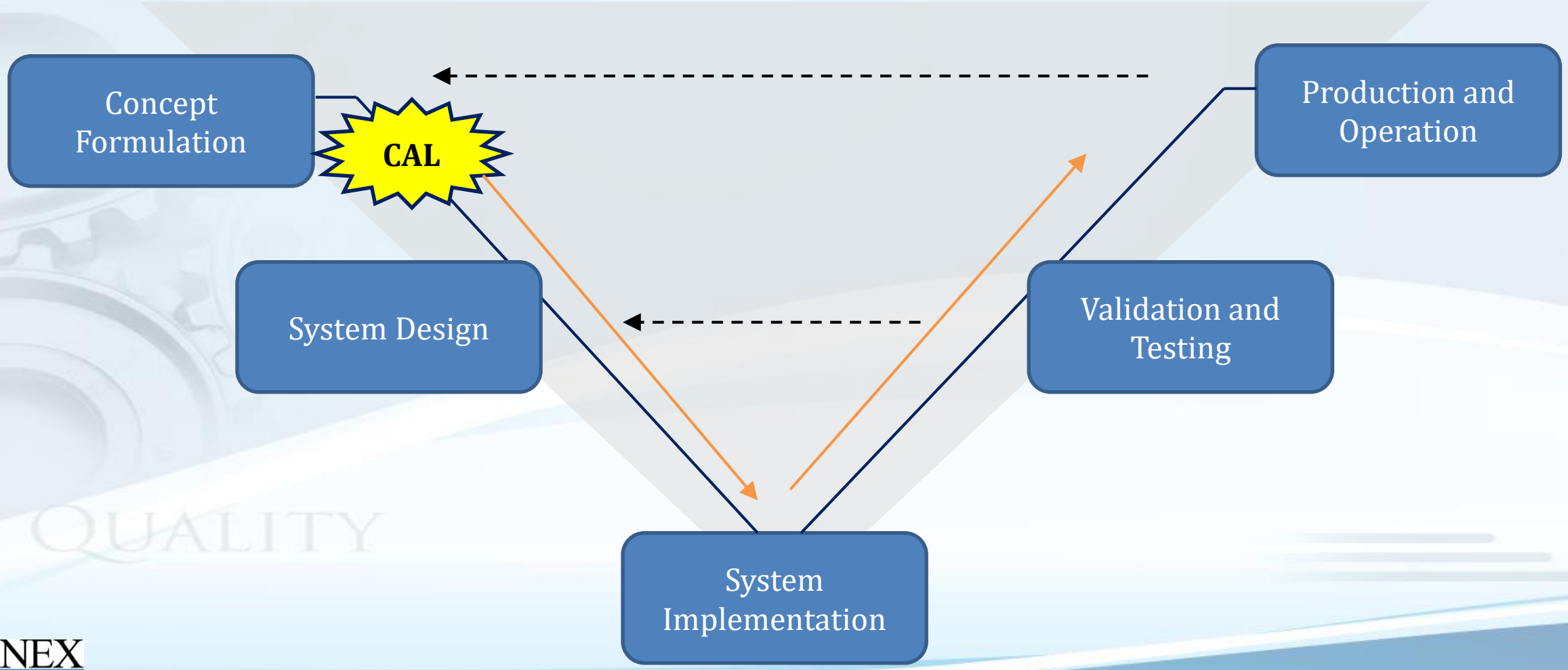
Figure E.1 — Relationship between a CAL and risk

source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.2 Determining a CAL

Use of CAL to Drive Subsequent Lifecycle Activities



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.2 Determining a CAL

- A CAL can be determined based on consideration of the identified threat scenarios.
- Four CALs are defined.
- A CAL classification scheme and determined CALs can also be part of the Cybersecurity Interface Agreement between customer and supplier.

CAL	Required Assurance
CAL1	Basic
CAL2	Medium
CAL3	High
CAL4	Very High

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.2 Determining a CAL

Table E.1 gives an example based on four CALs, each corresponding to an increasing level of assurance based on the cybersecurity engineering methods used.

Table E.1 — Example CAL Determination based on Impact and Attack Vector Parameters

		Attack Vector [b]			
		Physical	Local	Adjacent	Network
IMPACT	Severe	CAL2	CAL3	CAL4	CAL4
	Major	CAL1	CAL2	CAL3	CAL4
	Moderate	CAL1	CAL1	CAL2	CAL3
	Negligible	--- [a]	--- [a]	--- [a]	--- [a]

[a] See [PM-06-08]
[b] Attack vector is a static parameter of attack feasibility

NOTE: A single CAL may be assigned to all cybersecurity goals of an item or different CALs may be assigned to each cybersecurity goal.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Two Ways to Characterize Risk: CAL & Risk Value

CAL (Cybersecurity Assurance Level)

		Attack Vector [b]			
		Physical	Local	Adjacent	Network
IMPACT	Severe	CAL2	CAL3	CAL4	CAL4
	Major	CAL1	CAL2	CAL3	CAL4
	Moderate	CAL1	CAL1	CAL2	CAL3
	Negligible	--- [a]	--- [a]	--- [a]	--- [a]

Risk Value (Table H.8 – Risk Matrix Example)

		Attack Feasibility Rating			
		Very Low	Low	Medium	High
IMPACT RATING	Severe	2	3	4	5
	Major	1	2	3	4
	Moderate	1	2	2	3
	Negligible	1	1	1	1

Risk conveys the notion of a combination of attack probability and impact.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL

- A CAL classification scheme can be used to determine the level of rigor with which cybersecurity activities are performed, in terms of the effort necessary to provide the required assurance.
- A CAL can be used to select:
  - Methods used for development and verification;
  - Methods to identify weaknesses and analyze vulnerabilities; and
  - Approaches for cybersecurity assessment.
- **Table E.2** (next slide) provides an example of a number of CALs and guidance for their usage during the Concept and the Product Development Phases.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL

Table E.2 — Example Number of CALs and Expected Rigor in CS Assurance Measures

CAL	Description	a) Methods to provide confidence that cybersecurity activities are performed with appropriate rigor	b) Methods to provide confidence that unmanaged vulnerabilities do not remain	c) Independence scheme to provide confidence that the cybersecurity activities performed are appropriate
CAL 1	Low to moderate cybersecurity assurance is required	Requirement based testing	Activities such as analysis and/or testing to search for vulnerabilities based on known information	Not needed
CAL2	Moderate cybersecurity assurance is required			Cybersecurity assessments are carried out by a different person than the originator
CAL3	Moderate to high cybersecurity assurance is required	All interactions between components are tested	Activities such as analysis and/or testing to search for vulnerabilities by exploratory methods	Cybersecurity assessments are carried out by a person in a different team than the originator
CAL4	High cybersecurity assurance is required	All combinations of interactions between components are tested		Cybersecurity assessments are carried out by a person who is independent regarding management, resources and release authority from the originating department

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL: at the Concept Phase

- With the definition of the cybersecurity concept and the allocation of cybersecurity requirements to components of the preliminary architecture, CALs can be used as follows as an extension to **[RQ-09-10]**:
  - Cybersecurity requirements derived from a cybersecurity goal inherit the CAL from that cybersecurity goal;
  - If multiple cybersecurity requirements with different CALs inherited from multiple cybersecurity goals are allocated to an architectural component, the highest CAL is assigned to the component;
  - If the component is confirmed as protected from the other components in the architecture, the CAL assigned to the component can be reduced or rendered unnecessary, based on a rationale.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL: at the Development Phase

- An application of a CAL classification scheme in product development can be to use CAL-dependent methods and measures.
- In product development, if cybersecurity requirements are allocated to components, and isolation from other components cannot be confirmed, then the components can be developed in accordance with the highest CAL.
- **Tables E.3** and **E.4** provide examples of how CAL can be applied to a sample of cybersecurity activities; further cybersecurity activities can be addressed in a similar way.
- **Table E.3** provides an example of how CAL can be used to determine the level of independence with which the respective activities are performed.
- **Table E.4** provides an example of how CALs can be used to determine parameters that influence the rigor of testing methods used for verification and validation.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL: at the Development Phase

Table E.3 — Example of Level of Independence of Cybersecurity Activities

Activity	Requirements	Level of Independence applies to				Scope
		CAL1	CAL2	CAL3	CAL4	
Verification of cybersecurity concept and design activities	[RQ-09-11] [RQ-10-08]	I1	I1	I2	I2	Applies to the highest CAL among the cybersecurity requirements
Verification of the implementation and integration of components	[RQ-10-09]	I1	I1	I2	I2	
Cybersecurity validation	[RQ-11-01]	I1	I1	I2	I2	
Cybersecurity assessment	[RQ-06-27]	—	I1	I2	I3	

— No suggestion regarding the independence of this activity;

I1 The activity is performed by a different person in relation to the person(s) responsible for the creation of the considered work product(s);

I2 The activity is performed by a different person in relation to the person(s) who is independent from the team that is responsible for the creation of the considered work product(s), i.e., by a person reporting to a different direct superior; and

I3 The activity is performed by a person who is independent, regarding management, resources and release authority, from the department responsible for the creation of the considered work product(s).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

E.3 Using a CAL: at the Development Phase

Table E.4 — Example of Parameters of Testing Methods

Activity	Requirements	Testing parameters apply to				Scope
		CAL1	CAL2	CAL3	CAL4	
Functional Testing	[RC-10-12] [RQ-11-01]	T1	T1	T2	T2	Applies to the highest CAL among the cybersecurity requirements
Vulnerability Scanning	[RC-10-12] [RQ-11-01]	T1	T1	T1	T1	
Fuzz Testing	[RC-10-12] [RQ-11-01]	—	T1	T2	T2	
Penetration Testing	[RC-10-12] [RQ-11-01]	—	—	T1	T2	

— No suggestion regarding testing parameters of this activity;

T1 Testing parameter set 1:
- Functional testing based on requirements;
- Vulnerability scanning for known vulnerabilities;
- Fuzz testing with random of selection of inputs;
- Penetration testing assuming moderate attacker expertise, knowledge of the item or component and/or resources.

T2 Testing parameter set 2:
- Functional testing based on requirements and interactions between components;
- Vulnerability scanning for known vulnerabilities;
- Fuzz testing with an increased number of test case iterations and/or adaptive selection of inputs;
- Penetration testing assuming higher attacker expertise, knowledge of the item or component and/or resources.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Using Risk Value

- A **Risk Value** is a more detailed measure than CAL to estimate risk.
- For each threat scenario, the risk value shall be determined.
- The purpose of the determination of a risk value can be:
  - To support criteria for decisions on risk treatment, including the selection of controls;
  - Prioritization of risks for treatment;
  - Report to stakeholders; and
  - Monitoring of risk.
- The organization can define appropriate formulas for risk matrices.

Table H.8 — Risk Matrix Example

		Very Low	Low	Medium	High
Impact Rating	Severe	2	3	4	5
	Major	1	2	3	4
	Moderate	1	2	2	3
	Negligible	1	1	1	1

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Using Risk Value

- Risk values may also be determined by a risk formula defined by the organization. An example is shown in the below formula and **Table H.10.**

$$R = Floor\ \{1 + I \times F\}$$

Table H.10 — Example Translation of Impact and Attack Feasibility to Numerical Values

Impact Rating	Numerical Value *I* for Impact
Negligible	0
Moderate	1
Major	1.5
Severe	2

Attack Feasibility Rating	Numerical Value *F* for Attack Feasibility
Very Low	0
Low	1
Medium	1.5
High	2

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Using a CAL & Risk Value

- Applicable stakeholders to provide correct context: for CAL & Risk Value.
- Established context defines the risk rating metric for cybersecurity.
  - Adding appropriate detail: Impact, Attack Feasibility, and Risk Levels.
  - Extensions to the system defined as necessary.
- Choose the math that works best for the context.

Risk Value

		Very Low	Low	Medium	High
Impact Rating	Severe	2	3	4	5
	Major	1	2	3	4
	Moderate	1	2	2	3
	Negligible	1	1	1	1

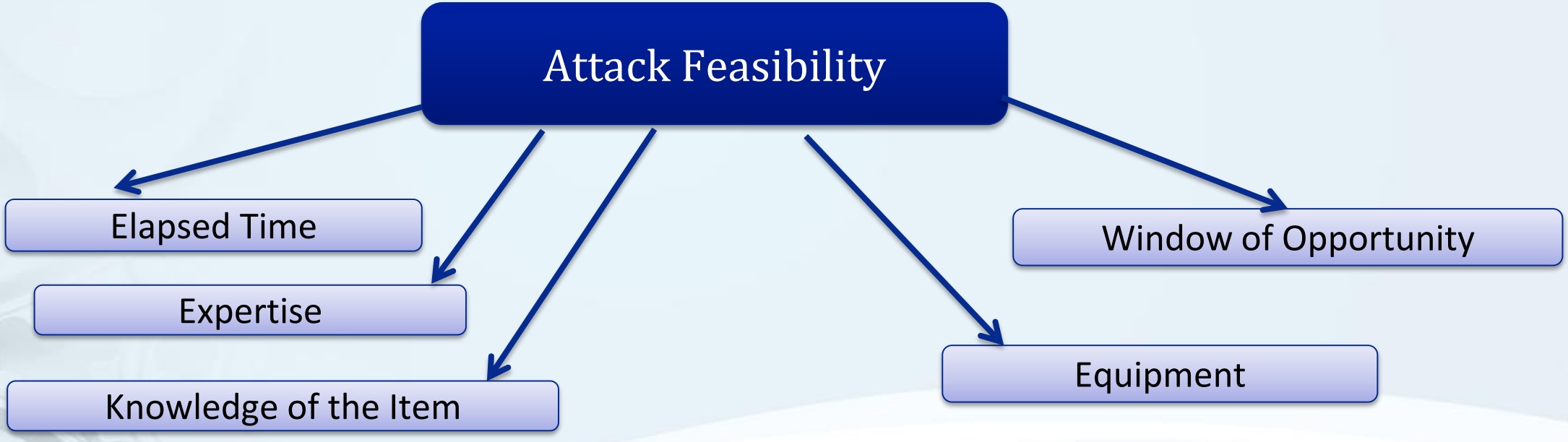
CAL

	Attack Vector				
Impact		**Physical**	**Local**	**Adjacent**	**Network**
	Negligible	…[1]	…[1]	…[1]	…[1]
	Moderate	CAL1	CAL1	CAL2	CAL3
	Major	CAL1	CAL2	CAL3	CAL4
	Severe	CAL2	CAL3	CAL4	CAL4

[1] NOTE: See [PM-08-01].

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Risk Value Determination: Attack Potential



- Five parameters are associated with the attack feasibility.
- For each parameter, numerical values are assigned (See tables in following slides).
- The five parameter values are added together to determine the level of attack feasibility: **High, Medium, Low, or Very Low**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Risk Value Determination: Attack Potential

- The elapsed time scale includes the time to identify a vulnerability, and develop and (successfully) apply an exploit. Therefore, this rating is based on the state of expert knowledge at the time of rating: Range: **days to years**.
- The expertise is related to the capabilities of the attacker, relative to their skill and experience: **layman, proficient, expert, multiple experts**.
- The knowledge of the item or component is related to the amount of information the attacker has acquired about the item or component: **public, restricted, confidential, strictly confidential**.
- The window of opportunity is related to the possible success when mounting an attack. it combines access type (e.g., logical and physical) and access duration (e.g., unlimited and limited). Depending on the type of attack this might include: discovery and access to a target, exploit works on the target, time to perform attack, circumventing detections and countermeasures: **unlimited, easy, moderate, difficult/none**.
- The equipment is related to the tools the attacker has available to execute the attack: **standard, specialized, bespoke, multiple bespoke**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Risk Value Determination: Attack Potential

Table G.6 — Example Aggregation of Attack Potential

Elapsed Time		Specliast Expertise		Knowledge of the Item or Component		Window of Opportunity		Equipment	
Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value
≤ 1 day	0	Layman	0	Public	0	Unlimited	0	Standard	0
≤ 1 week	1	Proficient	3	Restricted	3	Easy	1	Specialized	4
≤ 1 month	4	Expert	6	Confidential	7	Moderate	4	Bespoke	7
≤ 6 months	17	Multiple Experts	8	Strictly Confidential	11	Difficult / None	10	Multiple Bespoke	9
> 6 months	19								

Table G.7 — Example Attack Potential Mapping

Attack Feasibility Rating	Values
High	0 - 9
	10 - 13
Medium	14 - 19
Low	20 - 24
Very Low	≥ 25

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

15.9 Risk Treatment Decision

Objectives

- The objective of this subclause is to select the appropriate risk treatment options.

General

- Risk treatment is an activity that evaluates and treats identified unacceptable risks.
- Decisions how to manage unacceptable risks are determined by stakeholders through an analysis of treatment options.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Risk Treatment Decision

- Risk treatment options shall be identified, considering the results from risk determination.
  - Avoiding the risk by removing the risk sources, deciding not to start or continue with the activity that gives rise to the risk;
  - Reducing the risk;
  - Sharing or transferring the risk (e.g., through contracts, buying insurance); and/or
  - Retaining (or accepting) the risk.

NOTE: The rationales for retaining the risk and sharing the risk are recorded as cybersecurity claims and are subject to cybersecurity monitoring and vulnerability management.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 4

Perform a TARA

Allotted Time: 90 minutes

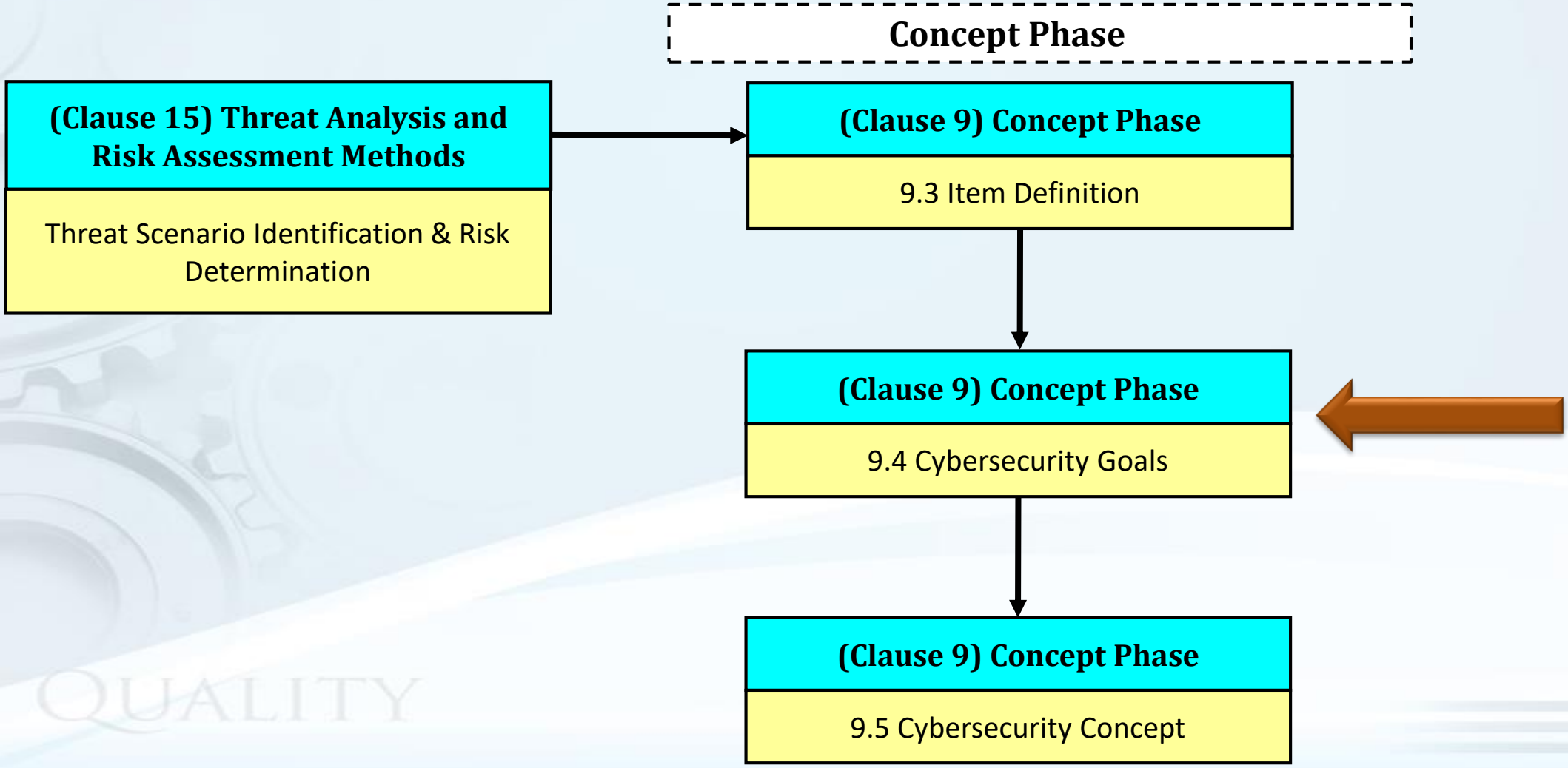


OMNEX

CYBERSECURITY GOALS AND CYBERSECURITY CLAIMS



Cybersecurity Goals



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(Clause 9.4) Cybersecurity Goals

- Cybersecurity goals are top-level cybersecurity requirements for the item.
  - The concept of a cybersecurity goal is expressed in terms of functional objectives, ***not technological solutions***.
- A cybersecurity goal is determined for each threat scenario and, if applicable, associated with a CAL.
- If similar cybersecurity goals are determined, they may be combined into a single cybersecurity goal.
- If similar cybersecurity goals are combined into a single one, the highest CAL shall be assigned to the combined cybersecurity goal.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(Clause 9.4) Cybersecurity Goals

- In order to identify cybersecurity goals, an analysis of the item shall be performed that involves:
  - Asset identification in accordance with **15.3**;
  - Threat scenario identification in accordance with **15.4**;
  - Impact rating in accordance with **15.5**;
  - Attack path analysis in accordance with **15.6**;
  - Attack feasibility rating in accordance with **15.7**; and
  - Risk determination in accordance with **15.8**.
- For the identified threat scenarios and their associated risks, a risk treatment decision shall be performed.
- If the risk treatment decision for a threat scenario involves reducing the risk, then one or more corresponding cybersecurity goals shall be specified.

NOTE: If applicable, a CAL can be derived for cybersecurity goals.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(Clause 9.4) Cybersecurity Claims

- If the risk treatment decision for a threat scenario includes:
  - Sharing the risk, or
  - Retaining the risk due to assumptions made during the TARA,

  then one or more corresponding cybersecurity claims shall be specified.

  NOTE 6 Cybersecurity claims can be considered for cybersecurity monitoring.

- A verification shall be performed to confirm:
  a) Correctness and completeness of the TARA with respect to the item definition;
  b) Completeness, correctness and consistency of the risk treatment decisions;
  c) Completeness, correctness and consistency of the cybersecurity goals and of the cybersecurity claims of with respect to the risk treatment decisions; and
  d) Consistency of all cybersecurity goals and cybersecurity claims of the item.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example of Cybersecurity Goal

- **Item:** Electrical Park Brake (EPB) systems
  - The EPB system, when activated by a specific driver command, brakes the vehicle rear wheels to prevent unintended vehicle movement during parking.
- **Function:** Brakes the vehicle rear wheels on demand.
- **Threat:** Unintended function activated by a cyber attack (i.e., safety category of security).
- **Attack Mode:** Bluetooth hack which causes an unintended EPB activation (**unexpected deceleration**); i.e., without demand.
- **Damage Scenarios (Operational Situations):**
  - High Speed
  - Taking a bend
  - Low Adherence
  - Medium-low speed **AND** High Adherence

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example of Cybersecurity Goal

Failure Mode	Operational Situation	Threat Scenario	CAL	Cybersecurity Goal	Secure State
Unintended parking activation	High speed OR Taking a bend OR Low adherence	Unexpected deceleration (± 0.2 g over a 200 msec) with loss of vehicle control	Higher CAL	The Parking function shall not be activated with moving vehicle due to a cyber attack	EPB system disabled over xyz speed
Unintended parking activation	Medium-low speed AND High Adherence	Unexpected deceleration (± 0.2 g over a 200 msec) with possible crash with following vehicle	Lower CAL	The Parking function shall not be activated with moving vehicle due to a cyber attack	EPB system disabled over xyz speed

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

A Management View

Another view of the cybersecurity goal:

The cybersecurity goal is the top management cybersecurity requirement.

- It is the responsibility of the organization to know the cybersecurity goals.



This perspective on cybersecurity goals underlines an essential characteristic:

cybersecurity goals are descriptive, not technical.

- They must be understandable to a manager, and not prescribe a technological approach.

CYBERSECURITY GOAL

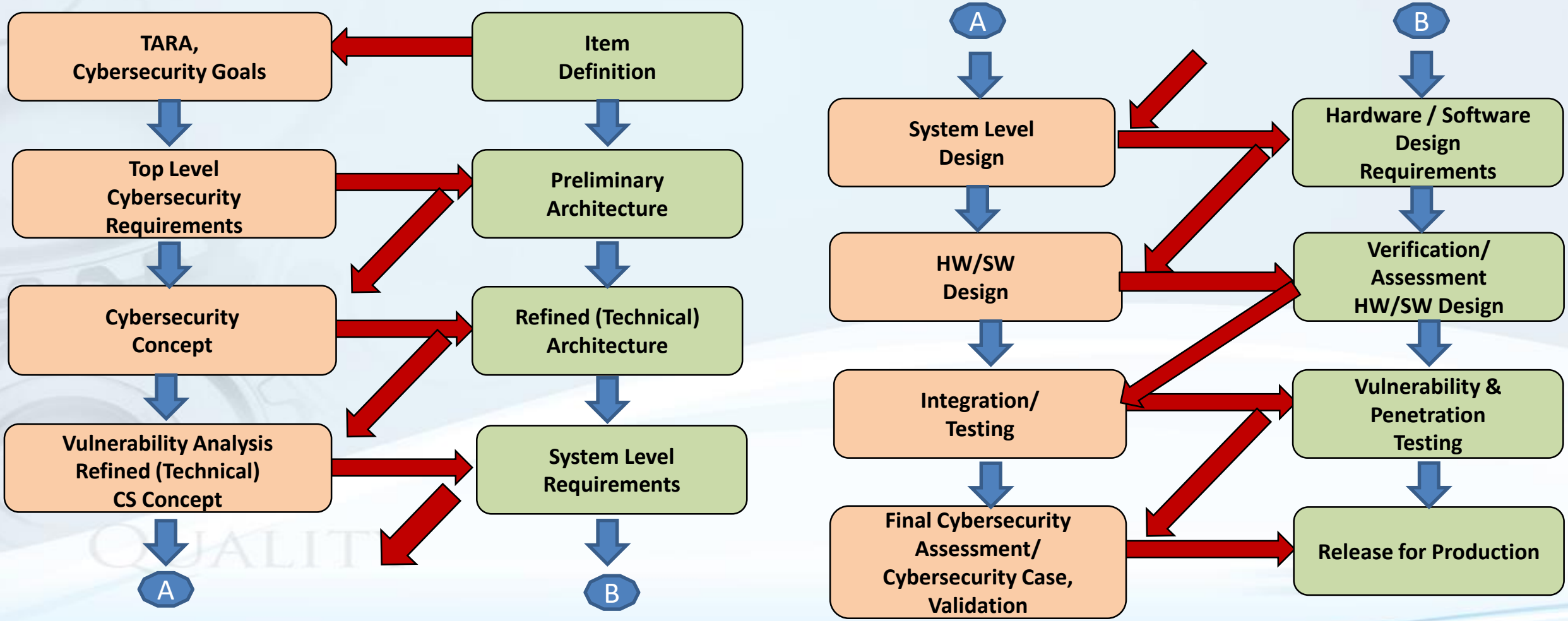


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

CYBERSECURITY CONCEPT



ISO/SAE 21434 Development Flow



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

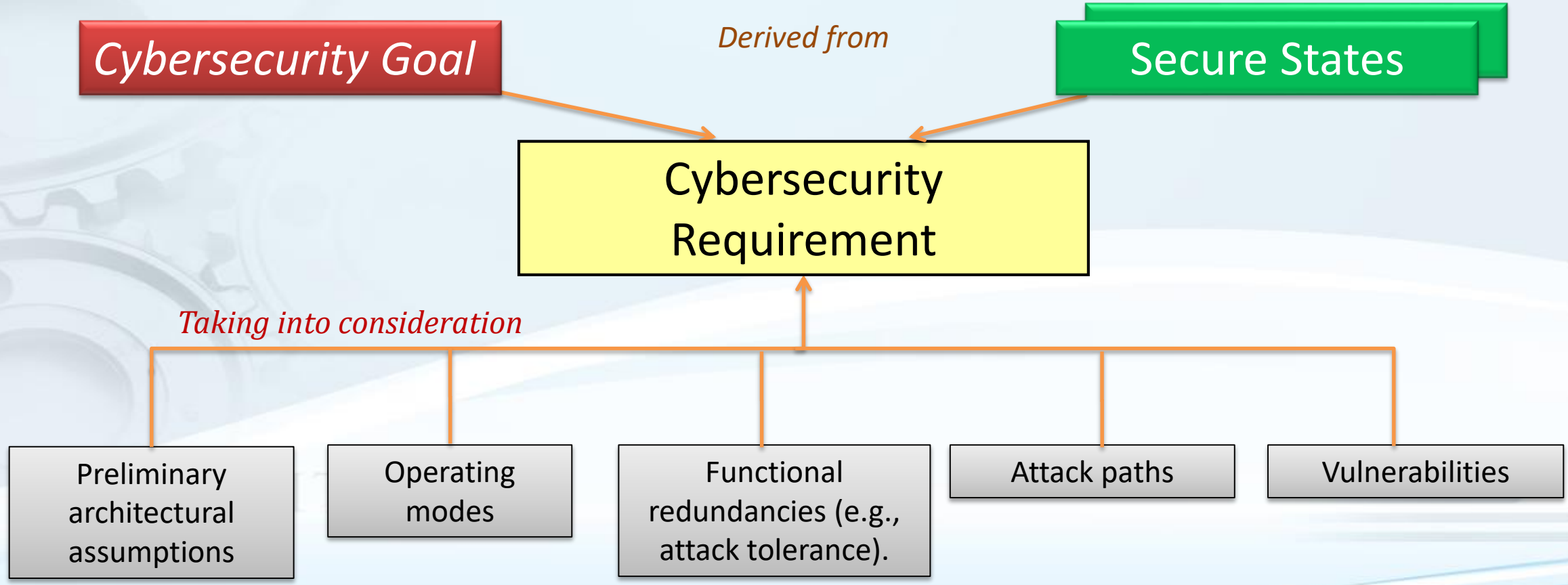
Cybersecurity Concept

- Technical and/or operational cybersecurity controls and their interactions to achieve the cybersecurity goals shall be described, taking into account:
  - Dependencies between the functions of the item; and/or
  - Cybersecurity claims.
- Cybersecurity requirements of the item shall be defined for the cybersecurity goals and allocated to the item (or its components).
- The cybersecurity controls, cybersecurity requirements, and its allocation shall be verified to confirm:
  - Completeness, correctness, and consistency with respect to cybersecurity goals; and
  - Consistency with respect to cybersecurity claims.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

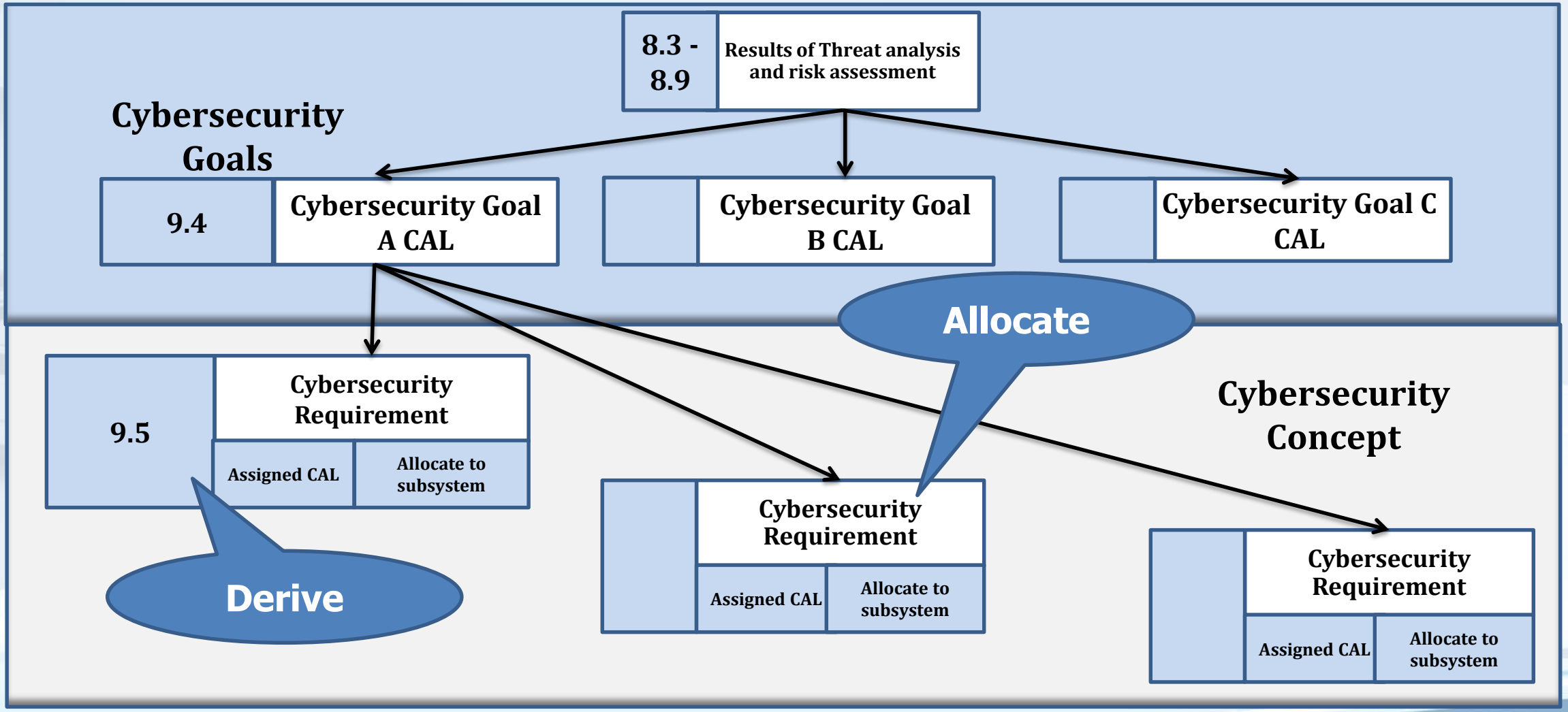
Requirements Derivation

The cybersecurity requirements shall be derived from the cybersecurity goals and secure states, taking into account the preliminary architectural assumptions.



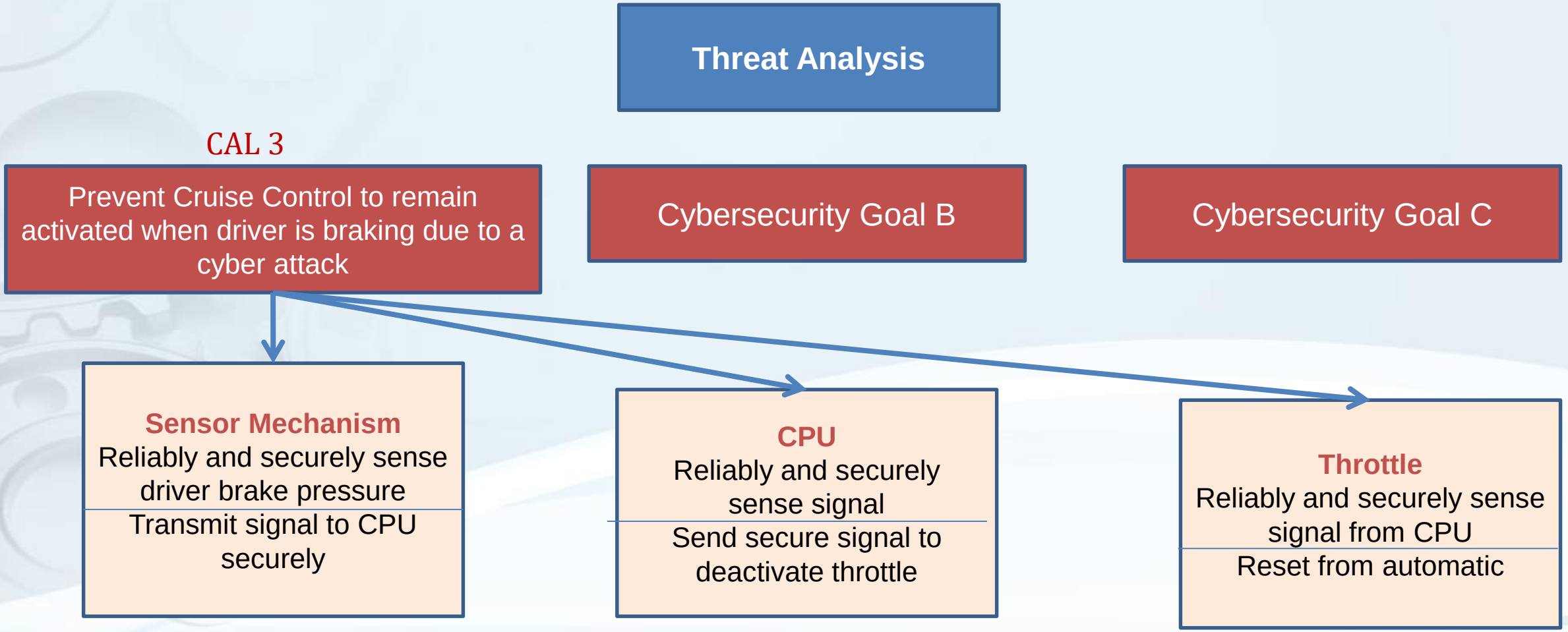
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

(Clause 9.5) Cybersecurity Concept and Requirements: Allocation Matrix



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Goals and Requirements – Cruise Control



Cybersecurity Concept: Allocation Matrix

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

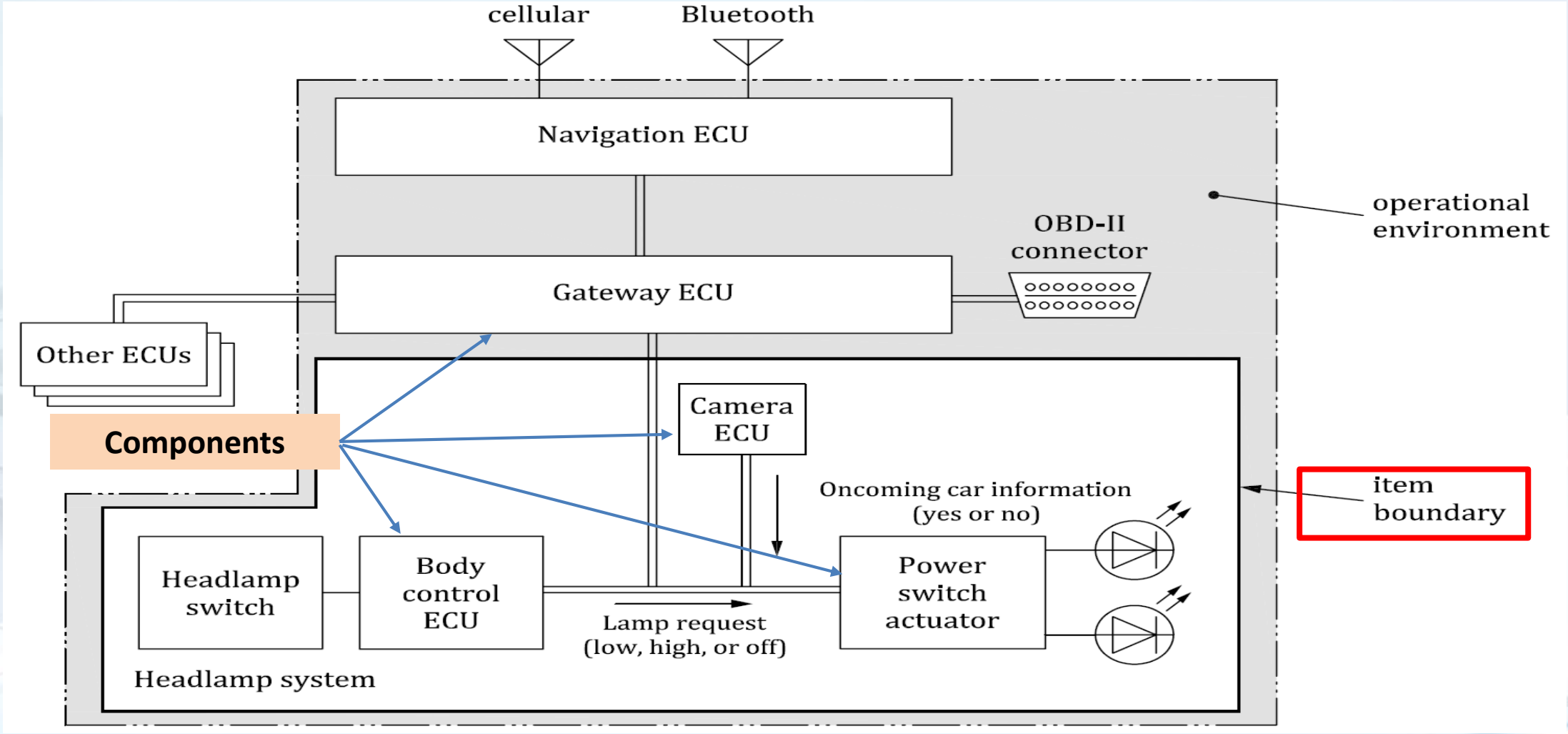
Characteristics of Cybersecurity Requirements (CSRs)

Cybersecurity requirements must:

- Be unambiguously identifiable as cybersecurity requirements.
- Inherit the CAL from the cybersecurity requirements from which they are derived.
- Be allocated to an item or an element.
- Have the following characteristics:
  - Unambiguous
  - Atomic
  - Feasible
  - Traceable
  - Complete / Comprehensive
  - Internally Consistent / Correct
  - Verifiable

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Preliminary Architecture: Headlamp System

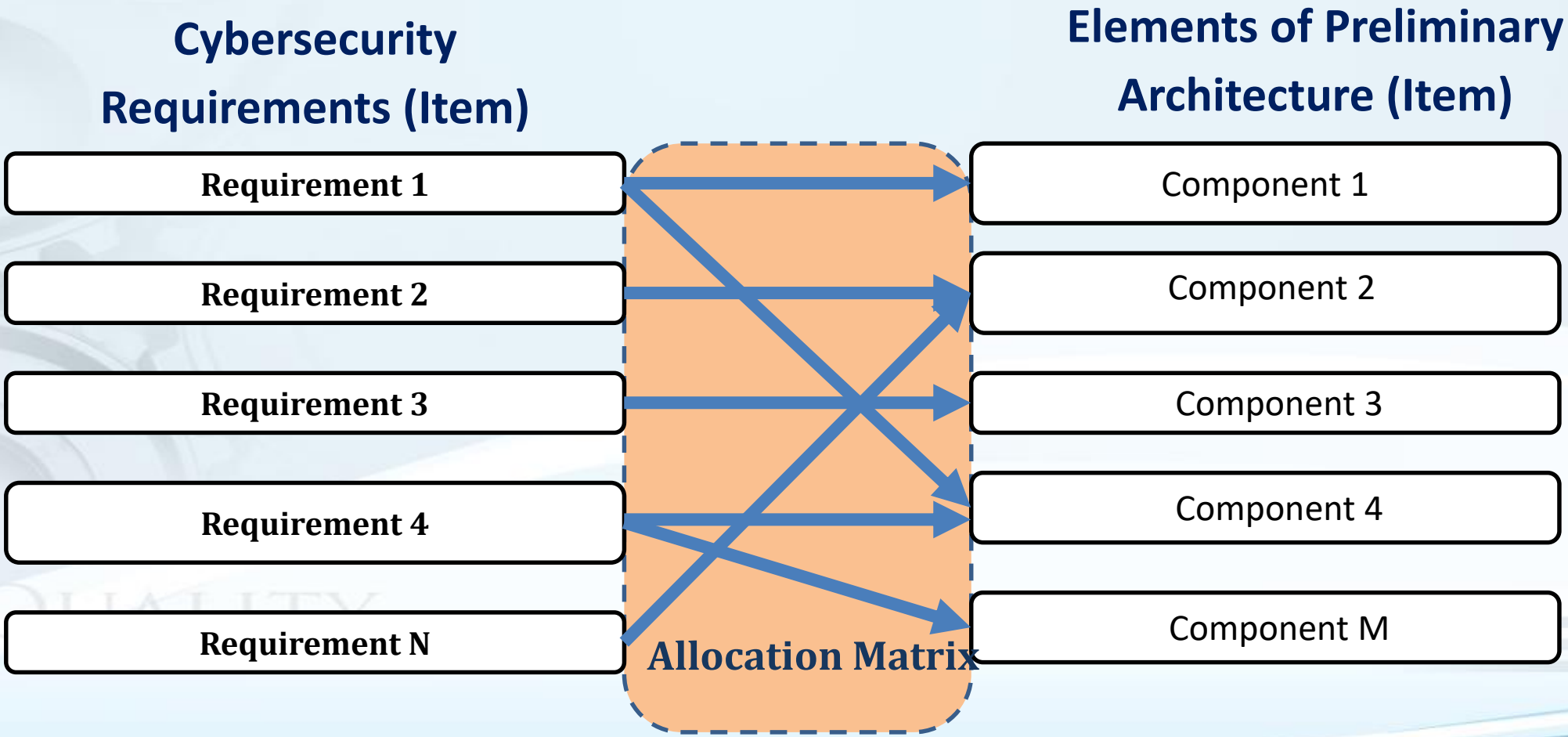


source: ISO/SAE 21434

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Concept

Requirements together with their allocation to architectural elements.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 5

Develop the Cybersecurity Goal, Requirements, and Concept

Allotted Time: 90 minutes



Chapter 3: TARA and the Cybersecurity Concept Phase (Clauses 15 & 9) — What We Covered

Competency 04: Perform Activities of the Concept Phase, including a Basic TARA

- Learning Objective 07: Develop the Item Definition for a typical project
- ***Breakout Exercise 3: Create the Item Definition***
- Learning Objective 08: Perform an automotive TARA for a typical project
- ***Breakout Exercise 4: Perform a TARA***
- Learning Objective 09: Define cybersecurity goals for a typical project
- Learning Objective 10: Develop the cybersecurity concept for a typical project
- ***Breakout Exercise 5: Develop the Cybersecurity Goal, Cybersecurity Requirements, and Cybersecurity Concept***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 4

Product Development Phase (Clauses 10 & 11)



Chapter 4: Product Development Phases (Clauses 10 & 11) — What We Will Cover

Competency 05: Perform Activities of the Product Development Phases

- Learning Objective 11: Perform product development activities for a typical project
- ***Breakout Exercise 6: Derive Flow-down of Hardware and Software Requirements***
- Learning Objective 12: Perform cybersecurity validation activities for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

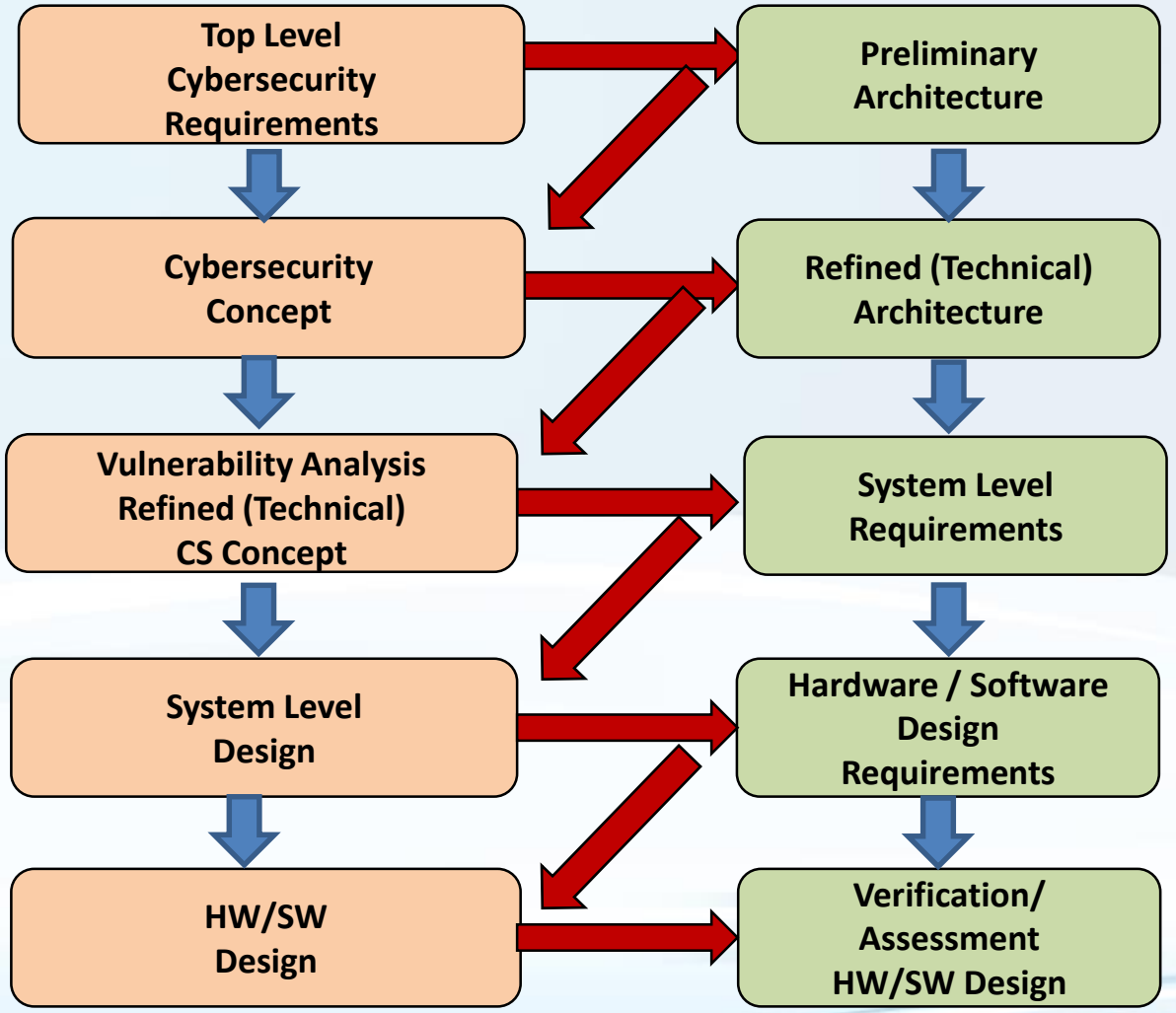
PRODUCT DEVELOPMENT (CLAUSE 10)



Introduction to Design and Verification

This figure depicts the main activities and work products related to design and verification.

- They involve the following:
  - Refined requirements;
  - Refined architecture;
  - System Level design;
  - HW/SW design requirements;
  - HW/SW design;
  - Verification/assessment of the design.
- Cybersecurity concept is an input to design and verification.

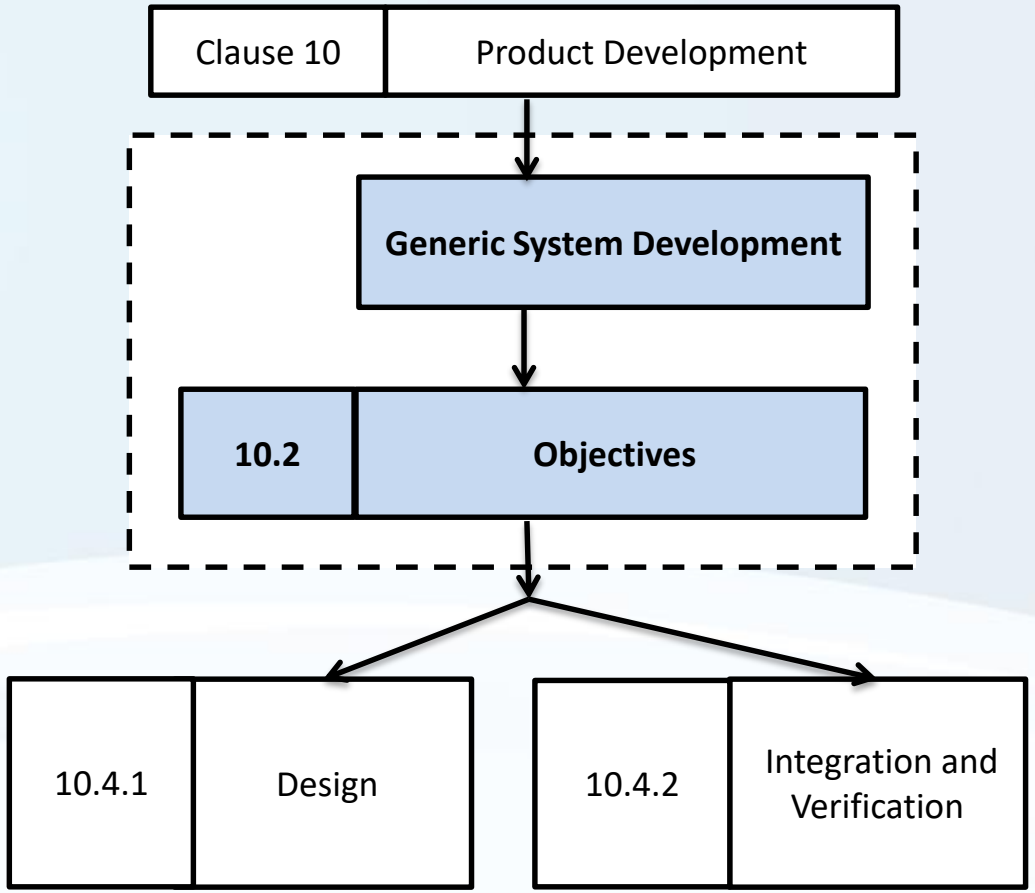


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Product Development (Clause 10)

Objectives

- Define cybersecurity specifications.
- Verify that the defined cybersecurity specifications conform to the cybersecurity specifications from higher levels of architectural abstraction.
- Identify weaknesses in the component.
- Provide evidence that the results of the implementation and integration of components conform to the cybersecurity specifications.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Product Development (Clause 10)

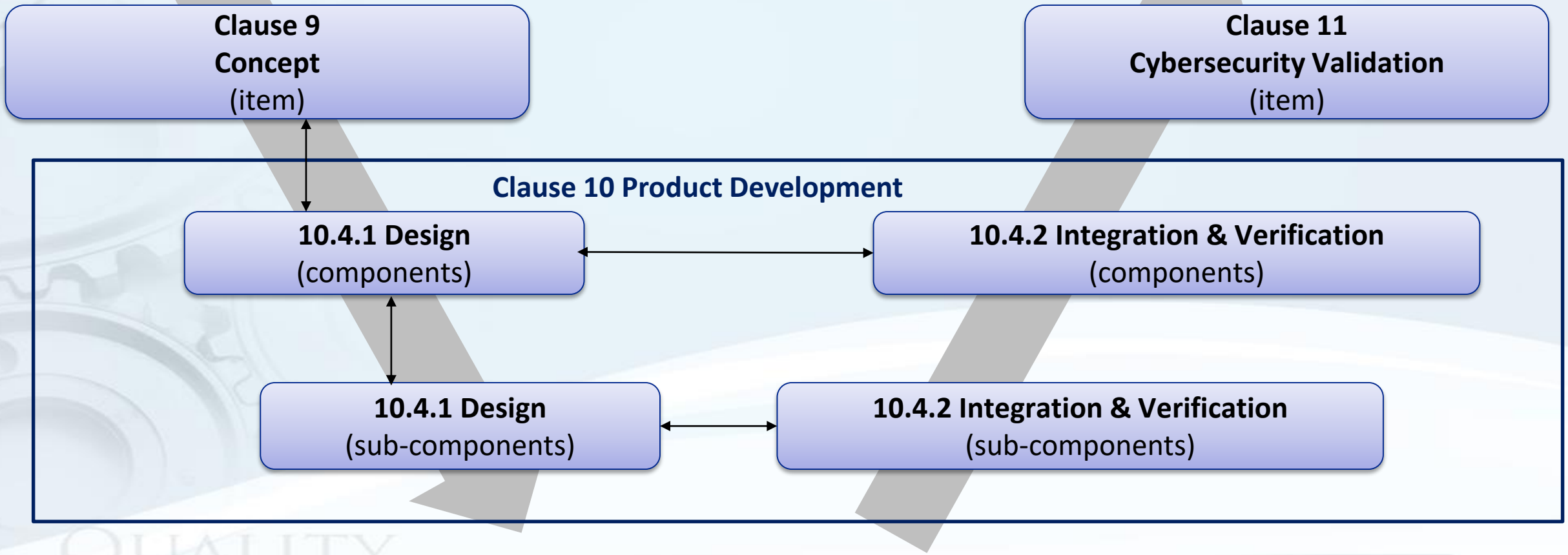
- The Product Development at the Design & Verification Level is divided into two parts.
  - Design (Refinement of cybersecurity requirements and refinement of cybersecurity architecture (left side of the V-Model).
  - Integration & Verification (right side of the V-Model).

  NOTE: Hardware and software development are not explicitly required.
- An “important outcome” of this phase is the “Refinement” concept.
  - Refinement means more detailed, specific, and derived (from top level to lower level) and can be applied to cybersecurity requirements and the cybersecurity concept.

  NOTE: In ISO/SAE 21434 there is no equivalent term to that of “technical safety concept” of ISO 26262.
- An engineering cross-functional team is required.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Left and Right Sides of the V-Model



↕ Verifications against the cybersecurity specification from a higher level of architectural abstract during design as described in **10.4.1**.

↔ Verifications of the implemented and integrated component against its cybersecurity specifications as described in **10.4.2**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

The "Refined" Concept

- Based on the cybersecurity concept, the preliminary architectural assumptions are **refined** with the following system properties:
  - The external interfaces, such as communication and user interfaces;
  - The constraints, e.g., environmental condition or functional constrains; and
  - The system configuration requirements.
- If other functions or requirements are implemented by the system, then these functions or requirements shall be specified or references made to their specification.

  EXAMPLE: Other requirements coming from other standards, e.g., ISO 26262.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

DESIGN
(CLAUSE 10.4.1)



Specifications (Design)

Objectives

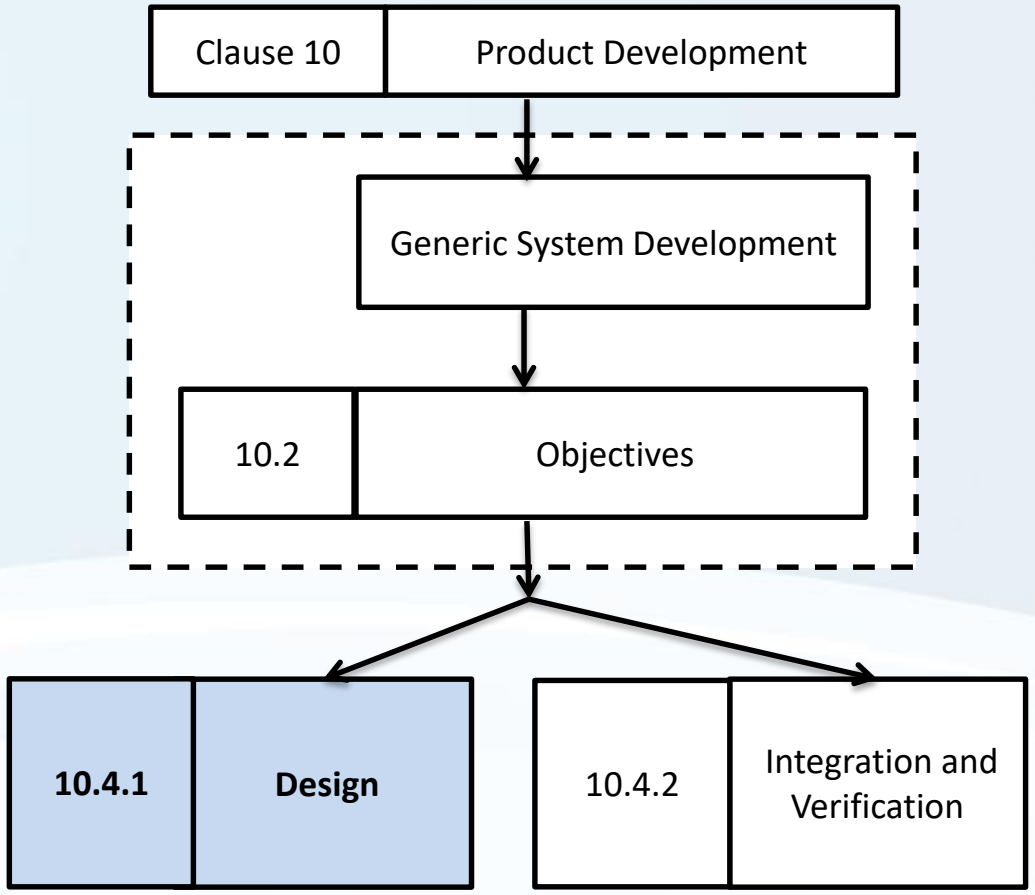
- Define cybersecurity specifications.
- Verify that the defined cybersecurity specifications conform to the cybersecurity specifications from higher levels of architectural abstraction.
- Identify weaknesses in the component.

Prerequisites

- Cybersecurity concept
- System architectural design
- Requirements to the item from other cybersecurity relevant items, if applicable

Work Products

- Cybersecurity specifications
- Cybersecurity requirements for post-development
- Documentation of the modelling, design or programming languages and coding guidelines
- Verification report for the cybersecurity specs
- Weaknesses found during product development

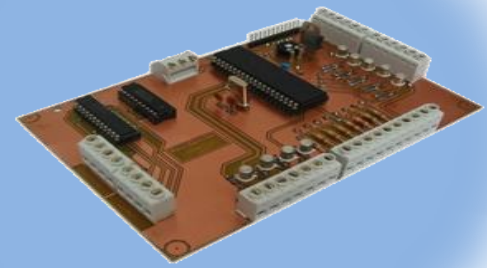


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Controls

These are technical solution implemented by E/E functions or elements or by other technologies to detect risks or mitigate attacks in order to achieve or maintain a secure state.

- Cybersecurity **controls** are safeguards or countermeasures to avoid, detect, counteract, or minimize security risks to the item, physical property, information, computer systems, or other assets.
- Cybersecurity controls are implemented within the item to prevent attacks.
- The cybersecurity control is either able to transition to, or maintain, the item in a secure state; or able to alert stakeholders.



Cybersecurity controls are added to the system.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Decision on Cybersecurity Controls

These include:

- Cybersecurity controls should be decided to realize the cybersecurity requirements of the cybersecurity concepts.
- Cybersecurity concept includes cybersecurity requirements on the operational environment.
- The cybersecurity concept sets the boundary within which a cybersecurity developer can select cybersecurity controls. It includes the system boundary, resource limitation, assumptions of external interfaces, and any other possible constraints.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Control Design

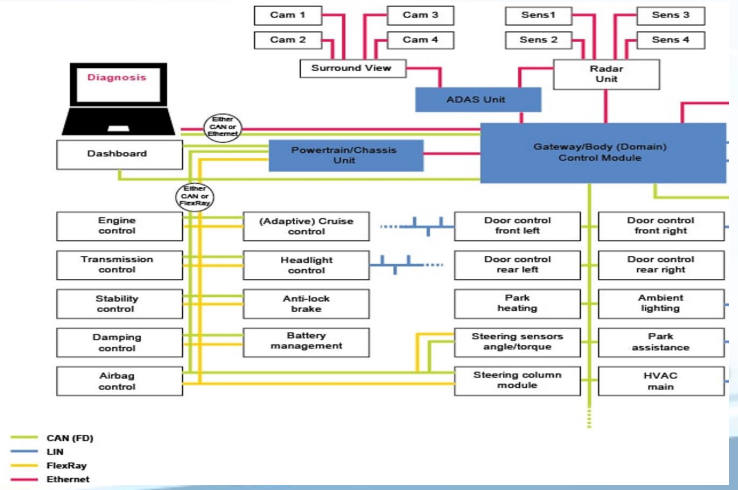
- Cybersecurity controls are dedicated to identify and mitigate threats or attacks and diagnostics of **the item elements.**
  - In many systems, a vulnerability can lead to incorrect system behavior and violation of a cybersecurity goal.
- The designer will usually have a **design choice** to make:
  - Design patches for vulnerabilities?
  - Or design the system to detect intrusion and switch to a secure state?
  - Or implement monitors to assess risk?
- Often a combination of these measures is necessary.
- **This is what the description of technical cybersecurity requirements is all about – making those hard design choices.**

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Controls: Domain Separation

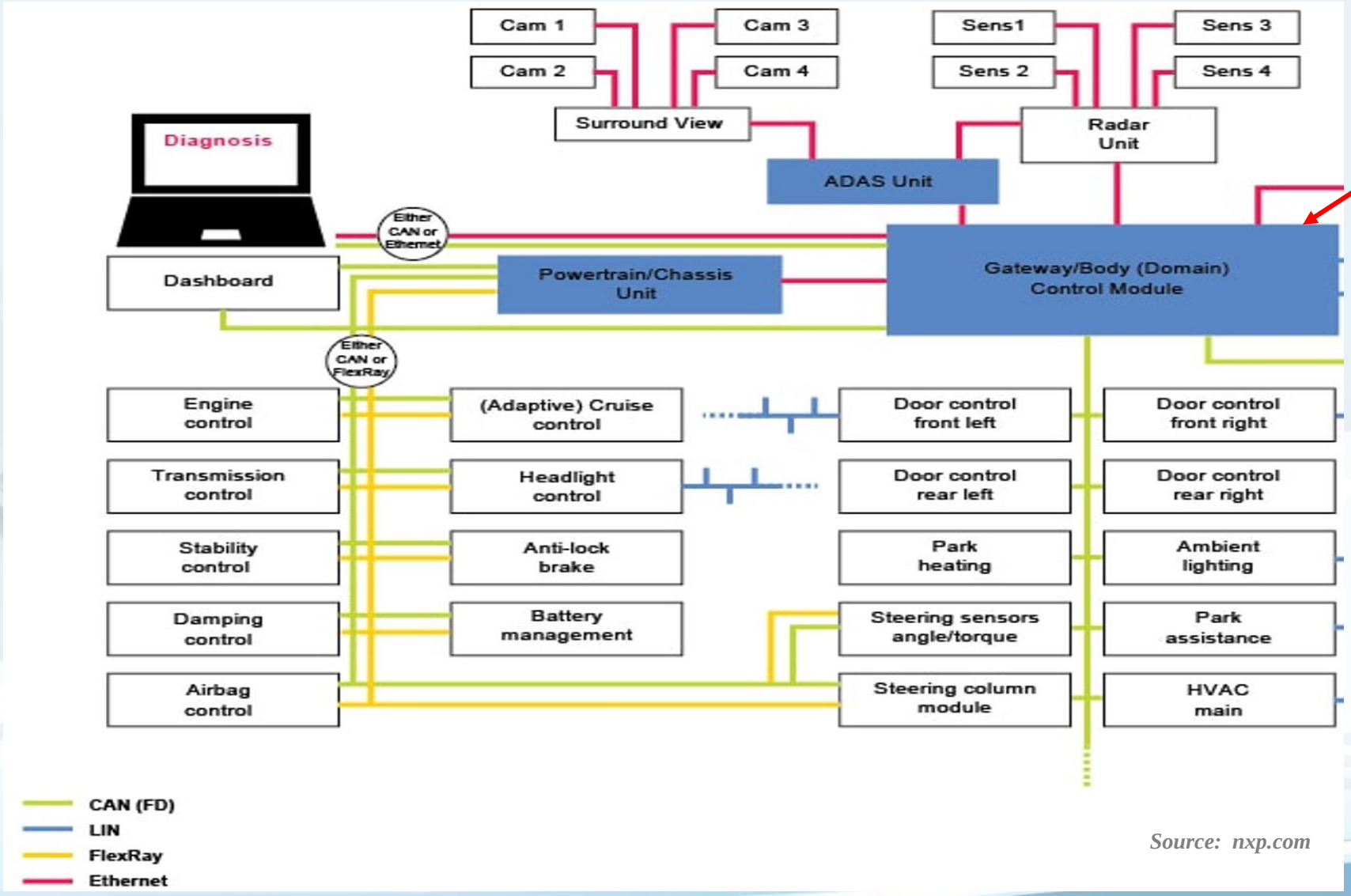
Cybersecurity Controls	Comments
Domain Separation	Separation of similar and dissimilar in-vehicle networks.

- Domain Separation is one of the main cybersecurity controls.
- The idea is to physically separate the various in-vehicle networks through a “Gateway.”
- The Gateway filters messages to the various networks and acts as a “domain separator”; each network is a domain.
- The main in-vehicle networks are:
  - **CAN-FD:** Controller area network – Flexible Data rate
  - **LIN:** Local interconnect bus
  - **FlexRay:** A network with safety properties
  - **Ethernet:** Used widely as a local backbone of Internet



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Controls: Domain Separation



Source: nxp.com

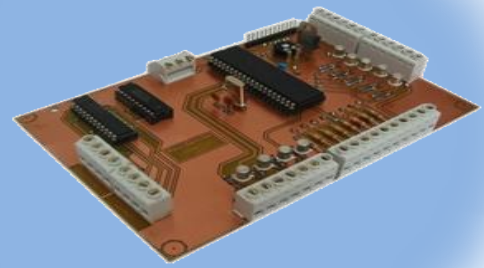
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Controls

Cybersecurity controls should be selected based on the cybersecurity requirements allocated from higher level and on the architectural design from higher level.

EXAMPLE 1: For system or hardware development: use of a separate microcontroller with an embedded hardware trust anchor for secure key store functionalities, and isolation of the trust anchor regarding non-secure external connections.

EXAMPLE 2: Use of catalogues and standard solutions that are traceable to national, international or industry standards.



Cybersecurity controls are added to the system.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Cybersecurity Requirements

Within the development life cycle of an Item, the refined cybersecurity requirements are the detailed requirements necessary to implement the cybersecurity concept, with the intention beginning to detail the Item Level cybersecurity requirements into the System Level refined cybersecurity requirements.

The System Level refined cybersecurity requirements are then allocated to the hardware and software for further development.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Cybersecurity Requirements

- The first objective is to specify detailed cybersecurity requirements which ***refines*** the cybersecurity concept, considering both the **functional concept and the preliminary architectural assumptions**.
- The second objective is to verify through analysis that the refined cybersecurity requirements ***comply with the higher level cybersecurity requirements***.
  - It is where the **handover from Customer to Supplier (internal or external)** usually occurs.
  - It is expected that the customer **should** create the cybersecurity concept, and the supplier implements it with the most appropriate technological solution.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Requirements – Sensor

Prevent Cruise Control to remain activated when driver is braking due to a cyber attack

Cybersecurity Concept

Sensor Mechanism
Reliably and securely sense driver brake pressure
Transmit signal to CPU securely

CPU
Reliably and securely sense signal
Send secure signal to deactivate throttle

Throttle
Reliably and securely sense signal from CPU
Reset from automatic

Cybersecurity Requirement

- Provide redundant sensing to signal “brake pedal is pressed” to the CPU.

Refined Cybersecurity Requirement 1

- Sensor senses Pressure on brake pedal of – xx lbs /square inch or greater and transmits encrypted to CPU to signal brake is pressed.

Refined Cybersecurity Requirement 2

- Sensor senses Travel of pedal of xx inches is transmitted encrypted to CPU to signal brake is pressed.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Cybersecurity Requirements

- **[RQ-10-01]** Cybersecurity specifications shall be defined based on:
  - Cybersecurity specifications from higher levels of architectural abstraction;
  - Cybersecurity controls selected for implementation, if applicable; and

    EXAMPLE 1: Use of a separate microcontroller with an embedded hardware trust anchor for secure key store functionality and isolation of the trust anchor regarding non-secure external connections.

    NOTE 1: Cybersecurity controls can be selected from trusted catalogues.
  - Existing architectural design, if applicable.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Specifications: Considerations

- Cybersecurity specifications include the specification of interfaces between sub-components of the architectural design, including their usage, static and dynamic aspects.
- When defining cybersecurity specifications, cybersecurity implications of Post-Development Phases can be considered, for example:
  - Secure management of the key store;
  - Deactivation of debug interfaces; procedures to delete personally identifiable information.
- The cybersecurity specifications can include the identification of configuration and calibration parameters relevant for fulfilling the cybersecurity requirements, as well as their settings or permitted range of values, e.g., the correct configuration for the integration of the hardware security module (HSM).
- Capability of a component necessary to implement the cybersecurity controls can be considered, for example:
  - Processor performance,
  - Memory resources.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

System Design

During System Design, the refinement of cybersecurity requirements are available, together with the cybersecurity concept and the Preliminary Architectural Design.

- At this point, the refined system design based on the refined cybersecurity requirements is created.
  - These describe how the requirements on the cybersecurity controls are to be implemented.
  - They carry through their allocation to hardware and software.
- The system design should be **verifiable.**
- The system design should make use of **appropriate** architectures.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

System Architectural Design Specification and Refined Cybersecurity Design

- The system architectural design in this sub-phase and the refined cybersecurity design shall be based on the item definition, cybersecurity concept and the prior system architectural design.
- The system architectural design shall implement the refined cybersecurity requirements and the following shall be considered:
  - The ability to verify the system architectural design;
  - The technical capability of the intended hardware and software elements with regard to the achievement of cybersecurity;
  - The ability to execute tests during system integration.
- The internal and external interfaces of cybersecurity-related elements shall be defined such that other elements shall not have adverse cybersecurity-related effects on the cybersecurity-related elements.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Design Principles

Recall that we are in the area of embedded systems:

- **Hierarchical component structure:** Embedded systems need hierarchy. The Unified Modeling Language (UML) only acquired the ability to model hierarchy with the second version (structured classes, components, composite structure diagrams).
- **Scheduling:** There is an entire body of knowledge on scheduling which must be applied.
- **Interrupts:** Similarly, there is much knowledge regarding how to design wisely with interrupts. Recommended to have a priority scheme.
- **Resource estimation:** CPU time, memory, etc. must be estimated.

IATF 16949

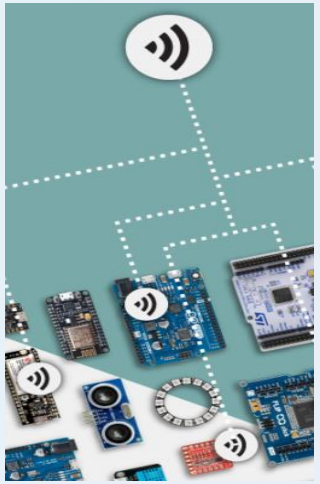
- **8.3.2.3 Development of Products with Embedded Software:** Use a process for quality assurance including a software development assessment methodology. Retain a software development capability self-assessment.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Other Activities

Recalling that this part concerns the overall development of the system, the specification of the cybersecurity-related requirements concerning production, operation, and maintenance (addressed later in **clauses 12 and 13**) are also initiated during this subpart:

- Assembly instructions;
- Description of specific cybersecurity-related characteristics;
- Procedures for production, diagnosis:
  - The requirements dedicated to ensure proper identification of systems or elements,
  - The verification methods and measures for production.
- Service requirements including diagnostic data and service notes;
- Procedures for field data acquisition and incident response.



OTA updates

Field data acquisition procedures



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Architectural Design

- **[RQ-10-02]** The defined cybersecurity requirements shall be allocated to components of the architectural design.

- **[RQ-10-03]** Procedures to ensure cybersecurity after the development of the component shall be specified, if applicable.

EXAMPLE 2: Procedures for correct integration and initialization of cybersecurity controls, as well as maintaining cybersecurity throughout production.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Architectural Design

- **[RQ-10-04]** If design, modeling or programming notations or languages are used for the cybersecurity specifications or their implementation, the following shall be considered when selecting such a notation or language:
  - An unambiguous and comprehensible definition in both syntax and semantics;
  - Support for achievement of modularity, abstraction and encapsulation;
  - Support for the use of structured constructs;
  - Support for the use of secure design and implementation techniques;
  - Ability to integrate already existing components; and

    EXAMPLE 3: Library, framework, software component written in another language.
  - Resilience of the language against vulnerabilities due to its improper use.

    EXAMPLE 4 Resilience against buffer overflows.

  NOTE 6: For software development, implementation includes coding using programming languages.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Architectural Design

Examples of Best Practices of cybersecurity design:

- Principle of least privilege
- Authentication
- Authorization
- Audit (security event logging)
- End to end security
- Architectural trust level (defense in depth)
- Segregation of interfaces (to allow proper cybersecurity analysis)
- Protection of maintainability during service (test interface, OBD…)
- Testability during development (test interface) and operations
- Security by default (simplicity, non-obfuscation, no reliance on expert users)

More Examples of Best Practices:

- Separation of cybersecurity domain from others (e.g., HW resource dedicated for cybersecurity functionalities, i.e., Secure Storage, TPM (trusted process module))
- Protection of the CS controls (e.g., the protection against tampering guarantees that any attempt to alter the firmware will fail)
- Non-bypass characteristics of cybersecurity controls
- Secure initialization of the cybersecurity controls

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Architectural Design

- **[RQ-10-05]** Criteria for suitable design, modeling or programming languages for cybersecurity that are not addressed by the language itself shall be covered by design, modeling and coding guidelines, or by the development environment.

  EXAMPLE 5: Use of MISRA C:2012 or CERT C for secure coding in the "C" programming language.

  EXAMPLE 6: Criteria for suitable design, modeling and programming languages.

  – Use of language subsets;
  – Enforcement of strong typing; and/or
  – Use of defensive implementation techniques.

- **[RC-10-06]** Established and trusted design and implementation principles should be applied to avoid or minimize the introduction of weaknesses.

  NOTE 7: Examples of design principles for architectural design for cybersecurity are given in **NIST Special Publication 800-160 Vol. 1, Appendix F.1**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Refined Architectural Design

- **[RQ-10-07]** The architectural design shall be analyzed to identify weaknesses.

  NOTE 8: Known weaknesses and vulnerabilities from reused components can be considered.

  NOTE 9: Identified weaknesses are analyzed for vulnerabilities (see **8.5**) and identified vulnerabilities are managed (see **8.6**). However, identified weaknesses can be resolved with changes to the architectural design without performing a vulnerability analysis.

- **[RQ-10-08]** The defined cybersecurity specifications shall be verified to ensure completeness, correctness, and consistency with the cybersecurity specifications from higher levels of architectural abstraction.

  NOTE 10: Verification methods can include:

  - Review;
  - Analysis;
  - Simulation; and/or
  - Prototyping.

Treatment of vulnerabilities in development can include:

- Isolation of functions;
- Use of encryption;
- Secure storage; and/or
- Anonymization of personal information.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

INTEGRATION AND VERIFICATION (CLAUSE 10.4.2)



Verification Activities

- **[RQ-10-09]** Integration and verification activities shall verify that the implementation and integration of components fulfill the defined cybersecurity specifications.
- **[RQ-10-10]** The integration and verification activities of **[RQ-10-09]** shall be specified considering:
  - The defined cybersecurity specifications;
  - Configurations intended for series production, if applicable;
  - Sufficient capability to support the functionality specified in the defined cybersecurity specifications; and
  - Conformity with the modeling, design and coding guidelines of **[RQ-10-05]**, if applicable.

Methods for verification can include:

- Requirements-based test;
- Interface test;
- Resource usage evaluation;
- Verification of the control flow and data flow;
- Dynamic analysis; and/or
- Static analysis.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification Activities

NOTE 3: If verification by testing is adopted, test cases and test environments can be selected, considering:

- Level of integration for testing to achieve the verification objectives;
- Necessity for additional tests during subsequent integration activities based on an analysis of the selected test environment, e.g., due to different bit widths of data words and address words of the target processor for final integration compared to a processor emulation or development environment.

Methods for deriving test cases include:

- Analysis of requirements;
- Generation and analysis of equivalence classes;
- Boundary value analysis; and/or
- Error guessing based on knowledge or experience.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification Activities

- **[RQ-10-11]** If verification by testing is adopted, test coverage shall be evaluated using defined test coverage metrics to determine sufficiency of the test activities.

Testing methods can include:
- Functional testing;
- Vulnerability scanning;
- Fuzz testing; and/or
- Penetration testing.

NOTE 5: Standard test coverage metrics can be inadequate for cybersecurity, e.g., statement coverage for software.

- **[RC-10-12]** Testing should be performed in order to confirm that unidentified weaknesses and vulnerabilities remaining in the component are minimized.

NOTE 6: Unnecessary functionalities can contain a weakness.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification Activities

- Identified weaknesses are analyzed for vulnerabilities (see **8.5**) and identified vulnerabilities are managed (see **8.6**).
- However, identified weaknesses can be resolved with changes to the architectural design without performing a vulnerability analysis.

- **[RQ-10-13]** If testing in accordance with **[RC-10-12]** is not performed, then a rationale shall be provided.

NOTE 9: The rationale can include the following considerations:

  - Feasibility to access the attack surface of the component;
  - Capabilities to (directly or indirectly) access the component in combination with compromise of other components; and/or
  - Simplicity of the component.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Software Unit Verification

- Verification activities shall be performed to confirm that the implementation of the design and the integration of the components or systems are compliant with:
  - The refined cybersecurity requirements;
  - The refined architectural design specification.

Examples of Verification Activities:

- Requirements-based test
- Interface test
- Resource usage evaluation
- Verification of the control flow and data flow
- Static analysis; for software: static code analysis
- Formal verification

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Static Code Analysis

The Goal is:

- To avoid any systematic faults that can lead to unexpected behavior of the SW under test, either early or after many years of operation.

How to Achieve It?

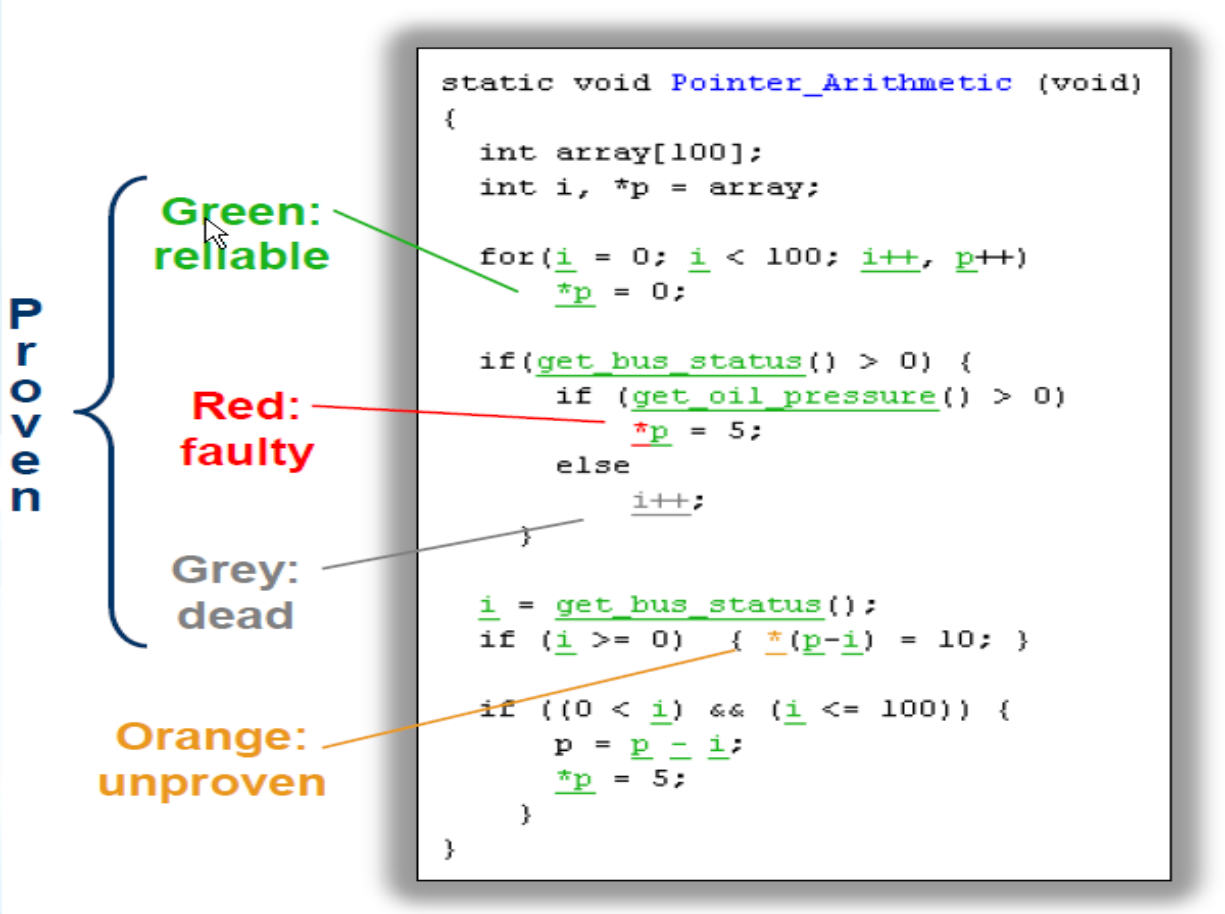
- Systematic analysis – tool oriented
- Check the source code for (examples):
  - SW metrics
  - Coding standard adherence
  - Control + data flow analysis
  - Interface analysis

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Unit Design Verification

- Unit design verification technology is improving rapidly.
- Note the static code analysis entry in **Table 23**: this corresponds to **symbolic execution.**

- New products are arriving on the market offering symbolic execution.
  - Examples are MathWorks, Polyspace.
  - Other formal approaches are emerging rapidly, even though classic approaches still dominate.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example: SW Unit Tests Verification Criteria for Peer Review

Management Review Criteria

1. Is the template in accordance with the selected process for the project?
   (May be Not Applicable if the design is reused from another project)

Technical Review Criteria

2. Are all software design requirements covered by the SW unit test cases?
   (Rationale: **ISO/SAE 21434-6 clause 10.4.2**)
3. Do the software unit test cases demonstrate:
   - 100% test coverage?
   - Mapping to the requirements?
   - Expected results?
     (can we state that there is not any unintended functionality?)
4. Is the minimum stabilization time required in HSIS tested by unit test cases?
   (at Unit Level in product environment, on target board)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example: SW Unit Tests Verification Criteria for Peer Review

Technical Review Criteria *(cont'd)*

5) Is the RAM and ROM consumption measured and conform to the budgets?
6) Are shared variables (existing in AAU scope only) and critical sections tested?
7) Are out of bounds access (array, pointer) tested?
8) Is an alternate escape mechanism other than the watchdog timer reset tested for all loops waiting an event?
9) Are the structural coverage targets respected?

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

No Hidden Data or Control Flow

The Goal is:

- To avoid unreachable code areas in the SW under development.

How to Achieve It?

- Any MISRA C rules checking tool can support this activity.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Control Flow Analysis

The Goal is:

- To detect potentially incorrect areas in software application under development.

How to Achieve It?

- Produce a graph of the flow by a static analysis of the software program.
- Check the graph for (examples):
  - Unreachable code
  - Knotted code (unwanted loops in flow)
  - Incomplete decision points

NOTE: this information will be also used for SW metrics.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Control Flow Analysis

A **control flow graph (CFG)** in computer science is a representation, using graph notation, of all paths that might be traversed through a program during its execution.

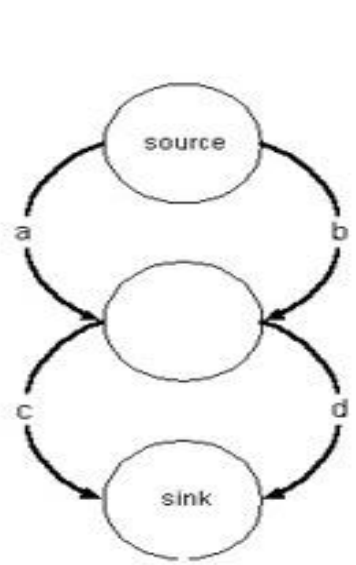


Fig 1. Simplified Control Flowgraph

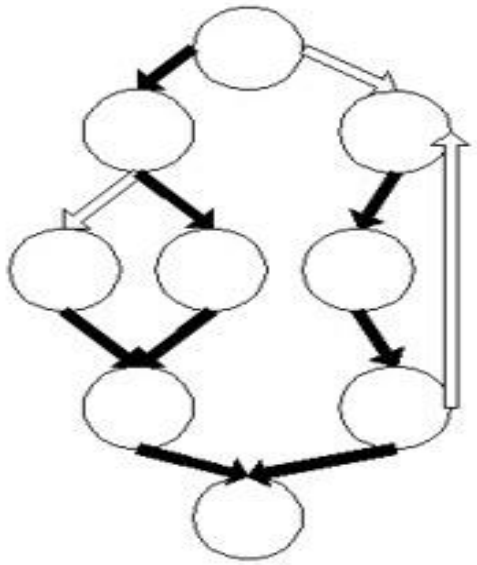


Fig 2. Flowgraph with marked edges

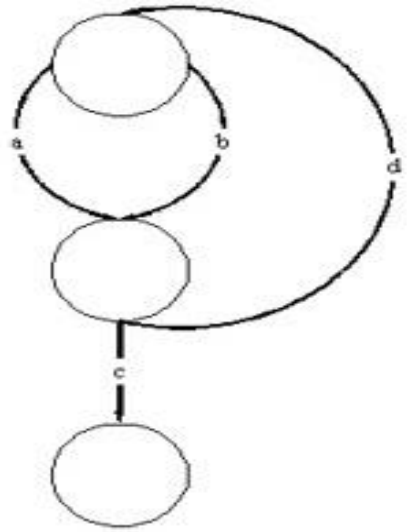


Fig 3. Simplified Flowgraph with Looping

source: http://en.wikipedia.org/wiki/Control_flow_graph

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Control Flow Analysis

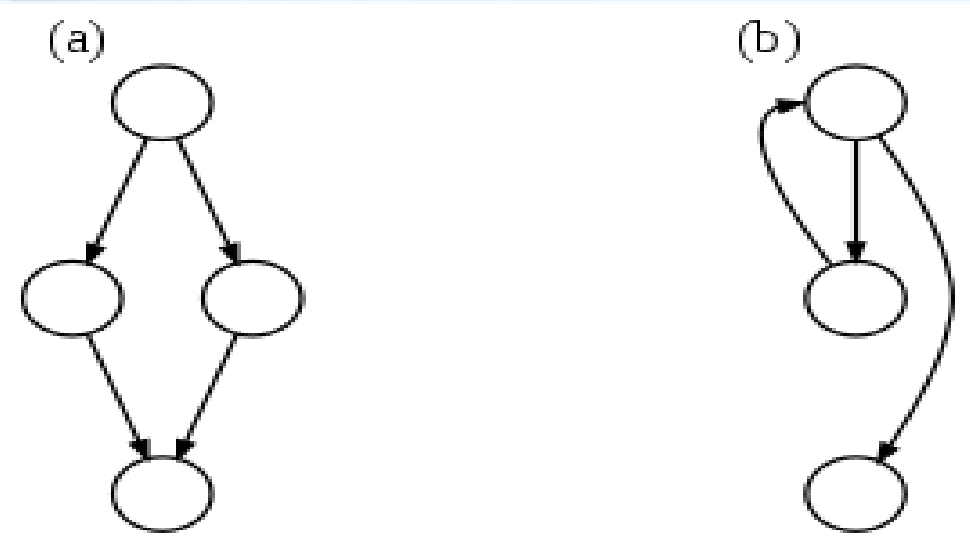
Some CFG examples:

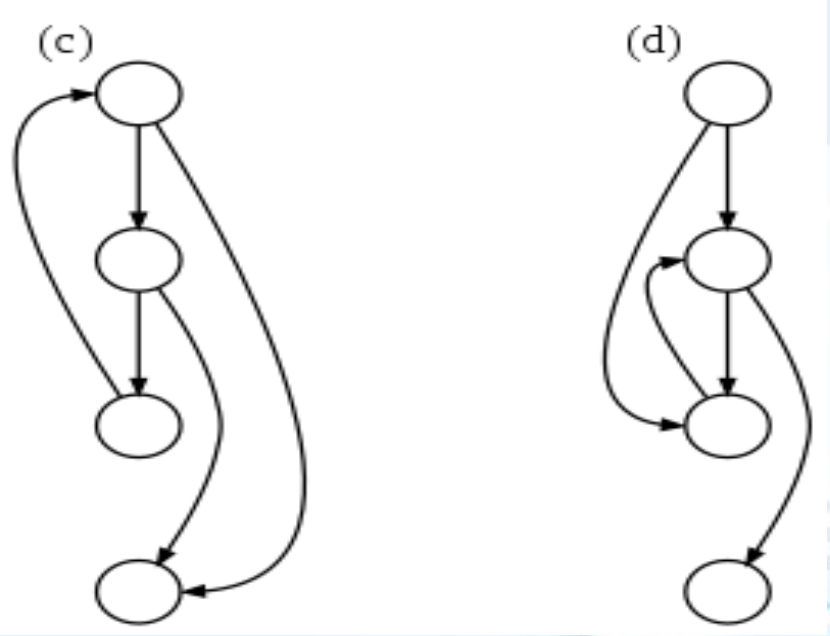
(a) An if-then-else

(b) A while loop

(c) A natural loop with two exits, e.g., while with an if...break in the middle; non-structured but reducible

(d) An irreducible CFG: a loop with two entry points, e.g., goto into a while or for loop





source: http://en.wikipedia.org/wiki/Control_flow_graph

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Data Flow Analysis

The Goal is:

- To detect potentially incorrect structures in SW application under development.

How to Achieve It?

- Combine information obtained from control flow analysis with analysis on variables.
- Check for: (examples)
  - Any variable read before it assigned a value.
  - Any variable written but never read.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification of Integration (Notes)

- To ensure the fulfilment of requirements influenced by the HW architectural design with sufficient tolerance, the following properties need to be determined:
  - Average and maximum processor performance;
  - Minimum or maximum execution times;
  - Storage usage (e.g., RAM for stack and heap, ROM for program and data);
  - Bandwidth of communication links (e.g., data buses).
- This method applies to interfaces, values approaching and crossing the boundaries and out of range values.
- Some aspects of the resource usage evaluation can only be performed properly when the software integration tests are executed on the target environment or if the emulator for the target processor adequately supports resource usage tests.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Timing for Test Development

There are some benefits if the unit test is designed and compiled before writing the code:

1. Reflection about the design before coding the system functions.
2. Testing the correctness of the functionalities by stressing and covering difficult scenarios.
3. Achieving better results in terms of cyclomatic complexity v(φ) in order to facilitate the verification activities.
   - Low cyclomatic complexity v(φ) levels make white-box testing easier due to the fact that they decrease substantially the number of paths (i.e., the control flow) that should be tested to reasonably guard against errors.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Example: Unit Testing Parameters

- "Recommended practice" a test strategy showing test and review targets for different components.
- Test and review coverage is a strong driver of cost in a big project you need to carefully balance requirements, methods and resources.
- A typical strategy would be to push toward a small part of the system having high CAL where strong methods can be applied at low cost and a large part of the system being low CAL.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Coverage Metrics

- The test environment for SW unit testing shall correspond as closely as possible to the target environment.
  - If the SW unit testing is not carried out in the target environment, the differences shall be analysed in order to specify additional tests in the target environment during the subsequent test phases.
  - Differences between the test environment and the target environment can arise in the source code or object code, for example, due to different bit widths of data words and address words of the processors.

Examples of Structural Coverage Metrics at the Software Unit Level:

- Statement coverage
- Branch coverage

Examples of Structural Coverage Metrics at the Software Architectural Level:

- Function coverage
- Call coverage

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Testing Environments

- **[RQ-10-16]** A verification that components do not contain any unspecified functionality shall be performed.

  NOTE 16: Unspecified functionality is not explicitly described in the architecture design specification but is implemented for any reason.

  EXAMPLE 6: For software development, code used for debugging or instrumentation.

NOTE 19. Target Environment Considerations:

- Depending on the scope of the tests and the hierarchical level of integration, the appropriate test environments for the execution of the software elements are used.
- Such test environments can be:
  - The target processor for final integration, or
  - A processor emulator or a development system for the previous integration steps.

- **[RQ-10-17]** If testing is used for the verification activities of **[RQ-10-12]**, the test environment shall be suitable for achieving the test objectives.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Testing Environments

Examples of Test Environments:

- Hardware-in-the-loop
- Electronic control unit network environments
- Vehicles

Target Environment Considerations:

- **NOTE 20:** If the integration testing is not carried out in the target environment, the differences between the test environment and the target environment are analyzed in order to specify additional tests in the target environment during the subsequent test phases.
- **NOTE 21:** In software development, differences between the test environment and the target environment can arise in the source or object code, for example, due to different bit widths of data words and address words of the processors.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

SPECIFIC REQUIREMENTS FOR SOFTWARE DEVELOPMENT (CLAUSE 10.4.3)



Design, Modeling and Coding

- When selecting a design, modeling or programming language the following shall be considered:
  - An unambiguous and comprehensible definition in both syntax and semantics;
  - Support for achievement of modularity, abstraction and encapsulation;
  - Support for the use of structured constructs; and
  - Support for the use of secure design and coding techniques.

EXAMPLE 1: Community or provider support for the language itself.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Design, Modeling and Coding

- Criteria for suitable modeling, design or programming languages for cybersecurity that are not sufficiently addressed by the language itself shall be covered by coding guidelines, or by the development environment.

  EXAMPLE 2: Use of MISRA C:2012 3rd edition, 1st Revision or CERT C for secure coding in the "C" programming language.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Design, Modeling and Coding

EXAMPLE 3: Criteria for suitable design, modeling and programming languages for cybersecurity can include (See **Table E.9**).

EXAMPLE 4: User input (e.g., input field, data import, APIs) is validated and sanitized.

NOTE 1: If CAL is used, then Annex E (**Table E.9**) provides topics and criteria for applicability.

Table E.9 — Topic List

Topics	CAL1	CAL2	CAL3	CAL4
Use of language subsets	✓	✓	✓	✓
Enforcement of strong typing	✓	✓	✓	✓
Use of defensive implementation techniques			✓	✓

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Design, Modeling and Coding

- Design principles for software unit design and implementation at the Source Code Level should be applied to achieve the following characteristics:
  - Correct order of execution of subprograms and functions within the software units, based on the software architectural design;
  - Consistency of the interfaces between the software units;
  - Correctness of data flow and control flow between and within the software units;
  - Low complexity;
  - Readability and comprehensibility;
  - Robustness;

    EXAMPLE 5: Methods to prevent use of tainted data.
  - Suitability for software modification (unless ease of software modification runs contrary to the cybersecurity requirements.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification Compliance

- Verification activities shall be performed to confirm that the implementation of the design and the integration of the components or systems are compliant with:
  - The refined cybersecurity requirements;
  - The refined architectural design specification;
  - The interface specifications.

- The software unit design and the implemented software unit shall be verified to provide evidence for compliance with the coding guidelines of **[RQ-10-20]**, if applicable.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification of Integration (Notes)

- To ensure the fulfilment of requirements influenced by the hardware architectural design with sufficient tolerance, the following properties need to be determined:
  - Average and maximum processor performance;
  - Minimum or maximum execution times;
  - Storage usage (e.g., RAM for stack and heap, ROM for program and data);
  - Bandwidth of communication links (e.g., data buses).
- This method applies to interfaces, values approaching and crossing the boundaries and out of range values.
- Some aspects of the resource usage evaluation can only be performed properly when the software integration tests are executed on the target environment or if the emulator for the target processor adequately supports resource usage tests.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Integration Issues

- Components and systems shall be verified to not contain any unspecified functionality.

  EXAMPLE: For software development, unspecified functions include code used for debugging or instrumentation.

  NOTE 1: If a component has functionality that is not fully specified, it is encapsulated in a separate zone outside of the trust boundary.

  NOTE 2: If the unspecified function is deactivated, this is an acceptable control.

- Host or target integration?
  - In theory, this is software-software integration and can therefore be carried out on the host (easier).
  - But some aspects of integration testing are affected by constraints placed by the hardware architecture and need to be tested on the target system.
  - These aspects include in particular resource usage: communication bandwidth, RAM and ROM (e.g., runtime stacks).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Testing Environments (Recommended)

Recall that ISO/SAE 21434 is a standard for automotive mass production. However it does take into consideration the fact that the software cannot be tested on its true final target: each individual car that is sold.

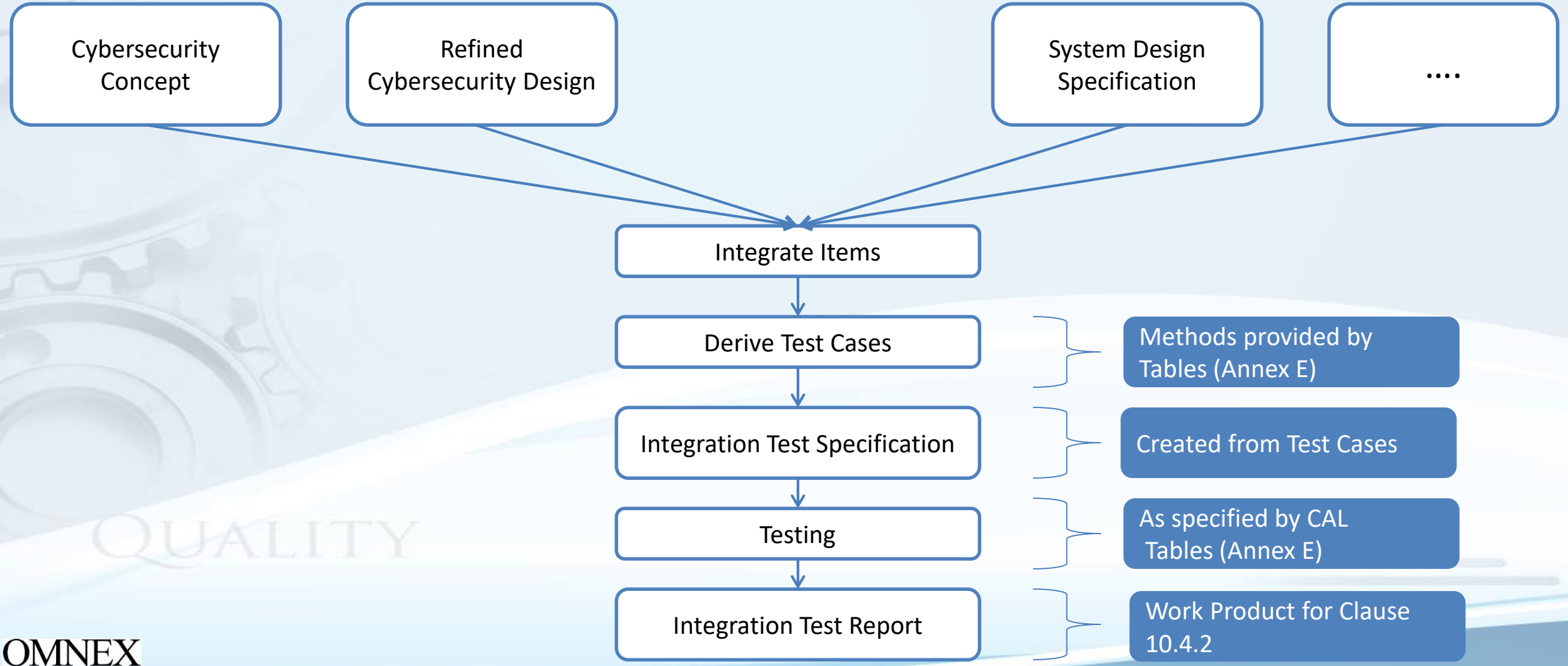
- First testing is done in the development environment.
- Then in progressively more realistic environments: software-in-the-loop, hardware-in-the-loop, “lab-cars”, prototype vehicles.



Regardless of CAL, it is essential that (item/systems) testing with real, complete vehicles is carried out before production starts!

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Item Integration and Testing



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Integration and Testing (Recommended)

When hardware and software development are completed, the next phase of System Level activities is the implementation of the System Level integration and test of the item.

Remember the integration testing and systems verification should be planned along with the system design before HW and SW design activities.

A battery of tests is appropriate for ISO/SAE 21434, depending on the CAL of the item.

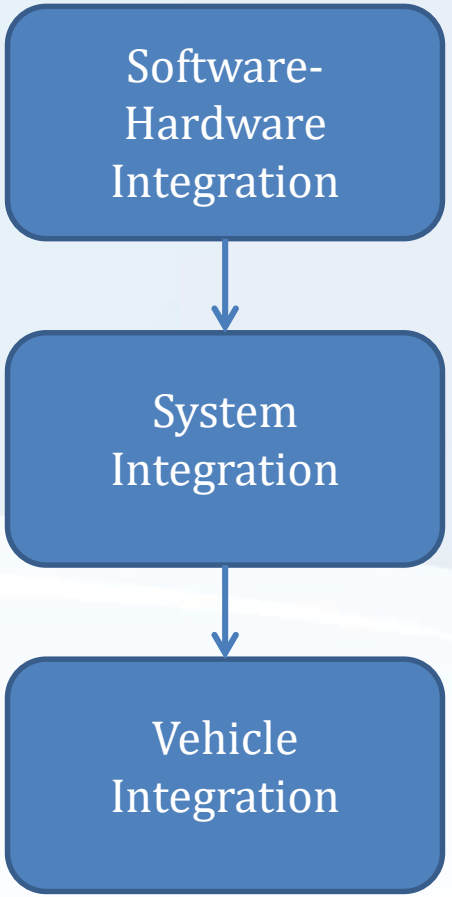


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

System Integration and Testing

The Integration and Testing Phase is comprised of three phases:

1. The first phase is the integration of the hardware and software of each element that the item comprises.
2. The second phase is the integration of the elements that comprise an item to form a complete system.
3. The third phase is the integration of the item with other systems within a vehicle and with the vehicle itself.



Specified integration tests are performed at each integration stage to provide evidence that the integrated elements interact correctly.

Recommended System Level testing practices are CAL-dependent.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Planning and Specification

Objective is to confirm the following at the Hardware-Software Integration, System and Vehicle Levels:

- Correct implementation of the cybersecurity requirements and refined cybersecurity design.
- Correct functional performance, accuracy and timing of the cybersecurity mechanisms.
- Consistent and correct implementation of the external and internal interfaces.
- Effectiveness of a cybersecurity mechanism's diagnostic or structural coverage.
- Level of robustness.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Planning and Specification

Consider the following:

- Hardware-Software Integration Test Planning:
  - Interface and interaction between hardware and software.
- System Integration Test Planning:
  - Refinement based on hardware-software integration testing.
  - Address open items from hardware-software verification.
  - Interface between vehicle and sub-systems (internal and external) and the environment.
- Vehicle Integration Test Planning:
  - Correct vehicle behavior under typical and extreme vehicle conditions and environments.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Planning and Specification

Additional Considerations:

- For different configurations and calibration data, must provide evidence of compliance with cybersecurity requirements for each configuration.
- All test equipment are subject to the control of a monitoring quality system.
- Each refinement of cybersecurity design and cybersecurity requirements shall be verified.
- Methods for deriving test cases are given in **clause 10.4.2**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

System Integration and Testing

The system integration tests are intended to provide evidence that each system element interacts correctly, complies with the refined cybersecurity requirements.

System and component testing should be performed to search for new vulnerabilities.

Different weaknesses can exist in the test environment and the target environment, and their triggering into vulnerabilities depends on the functionality or code that executes on them.



Examples for Test Methods:

- Penetration Testing
- Vulnerability Scanning
- Fuzz Testing

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

System Level Integration

General Requirements

- The individual elements incorporated in the system shall be integrated according to the system design, tested with the system integration tests in accordance with the specified system integration tests.
- To detect design weaknesses and flaws, the test goals shall be addressed by the test methods given in **clause 10.4.2**.
- Joint test development and testing between supplier and the OEM may be appropriate and documented in the DIA.
- Test methods can be moved to other integration sub-phases with adequate rational.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification and Validation Methods (Annex F)

Testing can be done on the item or element itself, or based upon a model.

- **Functional Testing**

  Applied to a component or system, possibly integrated in a test environment, to determine whether the functionality of the component or system meets the requirements.

- **Interface Testing**

  It is performed by applying functional testing to verify all incoming inputs and outputs to and from the system under test.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification and Validation Methods (Annex F)

Penetration Testing

- A group of testing methods used to find vulnerabilities present in a system that can be exploited by an adversary to take control, gain privileged access, expose privileged data, or simply cause system malfunction.
- Penetration testing can be performed at various levels of information know about the system under test; for example, black, grey and white box testing of the system.
- The output of penetration testing can be used to harden systems to deny entry to external agents.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification and Validation Methods (Annex F)

Vulnerability Scanning

- A suite of software techniques where risk of vulnerability exploitation is assessed and quantified.
- Vulnerability scanning can be performed via passive scanning (e.g., looking for bugs that can be exploited) or active scanning of accessibility to host processes, network protocols, file systems access, and memory access.
- Vulnerability testing can also be applied to hardware and system architecture in a similar manner.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification and Validation Methods (Annex F)

Fuzz Testing

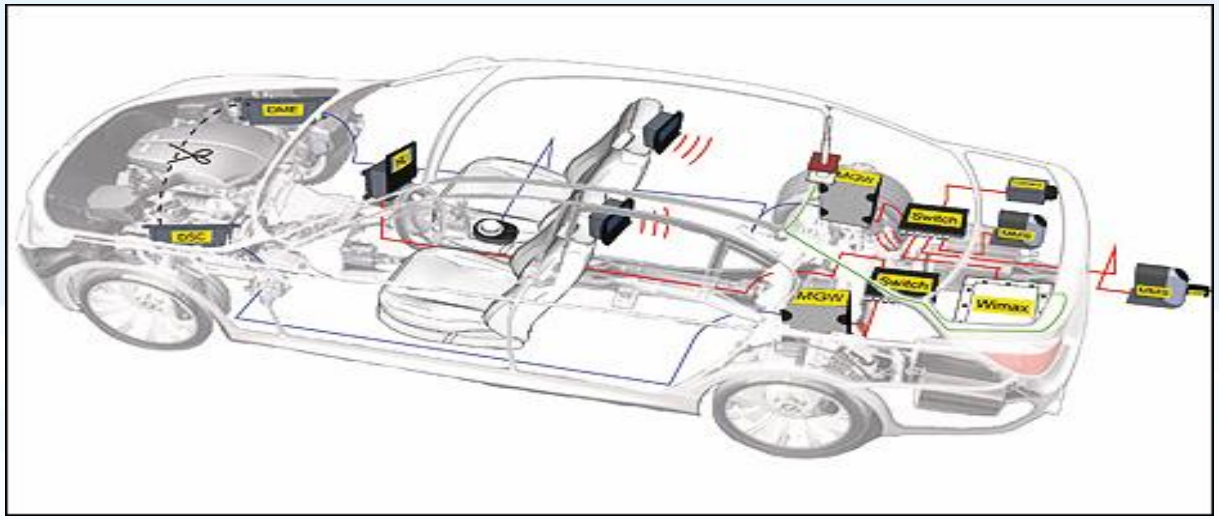
- A type of testing where large amounts of random data are provided as input to system, usually in an automated (or semi-automated) fashion, to look for failures and coding errors.
- If the system crashes or departs from normal defined behavior, output is reported as an error.
- Fuzz testing can be done at the System or Function Interface Level, or more exhaustively by listing every variable in the software under test and fuzzing random values for each software variable in the code under test.
- In the latter approach, tests are typically highly automated.
- Fuzz testing can be used to discover, for example, overflows, segmentation, and heap errors that have security implications.
- Fuzz testing can also similarly be applied to hardware inputs.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vehicle Level Integration

The item shall be integrated into the vehicle and the vehicle integration tests shall be completed.

- These tests include the verification of the interface specification of the item with:
  - The in-vehicle communication network, and
  - The in-vehicle power supply network.



- To detect design weaknesses and flaws during vehicle integration, the test goals shall be addressed by the application of adequate test methods.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

HW-SW Teamwork (Recommended)

- When refining the software requirements and developing the architecture, usually new ideas emerge for better cybersecurity solutions.
- In particular, modifying the way that hardware and software cooperate to provide cybersecurity related functions.
  - Sometimes it involves more software functionality.
  - Sometimes it involves more hardware functionality.
- It always involves close cooperation and communication between hardware and software development.

Software Development



Hardware Development

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

HW-SW Risk Mitigation

Examples of risk mitigation involving hardware and software trade-offs:

- When refining the software requirements, it may be discovered that a particularly heavy cybersecurity requirement is being placed on the software.
- It may become clear that a hardware technique such as hardware memory protection can eliminate the cybersecurity requirement on the software.
- Conversely, it may become clear that the software is able to detect intrusions that happen through hardware elements, and so it becomes possible to go back to the hardware design and use cheaper components.



```
40 import java.awt.image.IndexColorModel;
41 import java.awt.image.ColorModel;
42 import java.awt.image.MemoryImageSource;
43 import java.awt.event.*;
44
45 /** The representation of a Chemical .xyz model */
46 class XYZChemModel {
47     float vert[];
48     Atom atoms[];
49     int tvert[];
50     int ZsortMap[];
51     int nvert, maxvert;
52
53     static Hashtable atomTable = new Hashtable();
54     static Atom defaultAtom;
55     static {
56         atomTable.put("c", new Atom(0, 0, 0));
57         atomTable.put("h", new Atom(210, 210, 210));
58         atomTable.put("n", new Atom(0, 0, 255));
59         atomTable.put("o", new Atom(255, 0, 0));
```


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Hardware-Software Interface (HSI) (Recommended)

Cybersecurity relevant interactions between architectural elements, e.g., interactions between hardware and software, shall be identified.

- The Hardware-Software Interface may require specific consideration.

- The hardware diagnostic features shall be defined.
- The diagnostic features concerning the hardware to be implemented in software shall be defined.

The HSI should be specified during the system design and will be refined during hardware development and during software development.



software

hardware



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Hardware-Software Interface (HSI) (Recommended)

The HSI specification shall specify the hardware and software interaction and be consistent with the technical cybersecurity concept. The HSI specification should include:

- The component's hardware devices, that are controlled by software and hardware resources that support the execution of software.
- The relevant ***operating modes*** of hardware devices and the relevant ***configuration parameters.***
- The hardware features that ***ensure the independence*** between elements and that support software partitioning.
- Shared and exclusive ***use of hardware resources***, e.g., Memory mapping, allocation of registers, timers, interrupts, I/O ports.
- The ***access mechanism*** to hardware devices; e.g., Serial, parallel, slave, master/slave; and the ***timing*** constraints defined for each service involved in the technical cybersecurity concept.
- The relevant ***diagnostic*** capabilities of the hardware, and their use by the software.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Clause 10: Product Development

Work Products

- **[WP-10-01]** Cybersecurity specifications
- **[WP-10-02]** Cybersecurity requirements for post-development
- **[WP-10-03]** Documentation of the modeling, design or programming languages and coding guidelines, if applicable
- **[WP-10-04]** Verification report for the cybersecurity specifications
- **[WP-10-05]** Weaknesses found during product development, if applicable
- **[WP-10-06]** Integration and verification specification
- **[WP-10-07]** Integration and verification report

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 6

Derive Flow-down of Hardware and Software Requirements

Allotted Time: 90 minutes



OMNEX

CYBERSECURITY VALIDATION (CLAUSE 11)



Cybersecurity Validation

Objectives

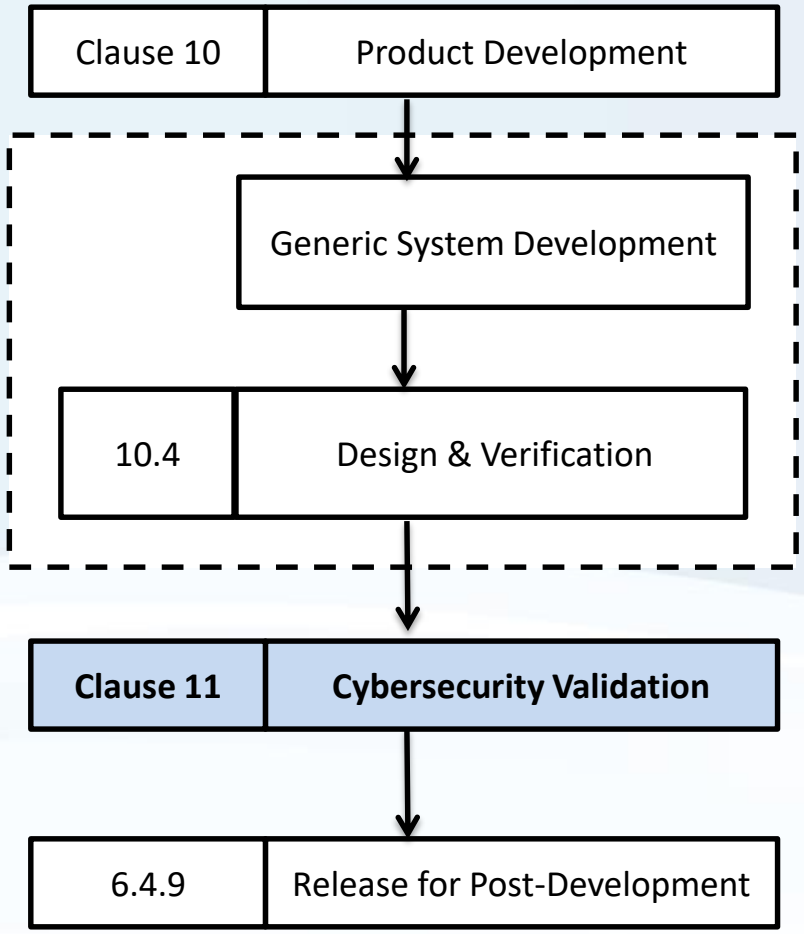
- Validate the cybersecurity goals and cybersecurity claims.
- Confirm that the item satisfies the cybersecurity goals.
- Confirm that no unreasonable risks remain.

Prerequisites

- Item definition
- Cybersecurity goals
- Cybersecurity claims, if applicable

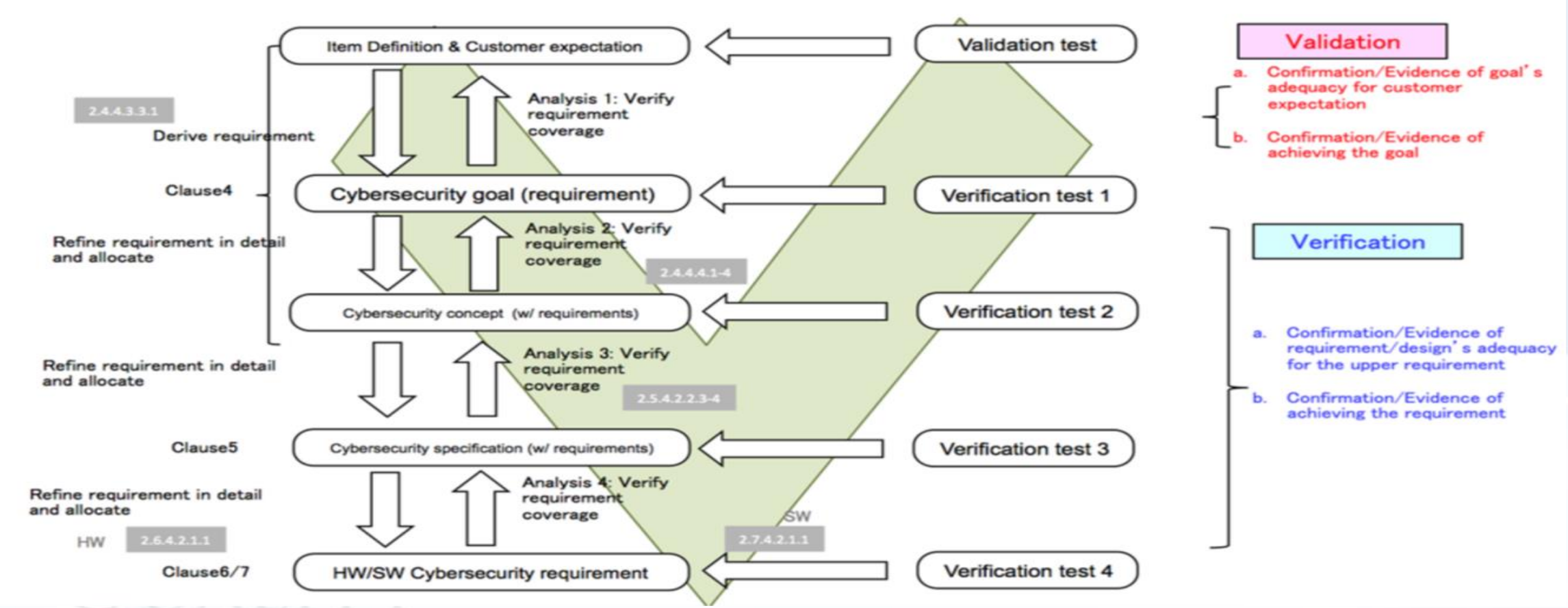
Work Products

- [WP-11-01] Validation report



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Verification and Validation



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Validation

Cybersecurity Validation activities are performed to confirm:

- The adequacy of the cybersecurity goals;
- The completeness, consistency, correctness and adequacy of:
  - The item; and
  - The cybersecurity requirements on the operational environment to achieve the cybersecurity goals of the item.
- If applicable, the validity of the cybersecurity claims.

Since cybersecurity validation is performed at the Vehicle Level, it is generally the responsibility of the OEM.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Validation

- Cybersecurity validation is carried out **at the Vehicle Level**, including:
  - E/E system
  - Hardware + software
  - Elements of other technologies (e.g., mechanical)
  - External measures



- The validation of the integrated item in representative vehicle(s) aims to provide:
  - Evidence of appropriateness for the intended use, and
  - Confirm the adequacy of the cybersecurity measures for a class or set of vehicles.

Cybersecurity validation does cover assurance that the cybersecurity goals are sufficient and have been achieved, based on examination and tests.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Aspects of Validation

- The cybersecurity goals of the item shall be validated at the Vehicle Level by evaluating the following:
  - **Impact & Attack feasibility** of the threat scenario;
  - **Effectiveness of cybersecurity controls** for controlling weaknesses & flaws in the design;
  - The **effectiveness of the external** controls that may play a role in the cybersecurity concept;
  - The **effectiveness of the elements of other technologies** (e.g., RF, self-driving vehicle, …)
- The validation must not only demonstrate the activation of cybersecurity controls when appropriate, but also the **absence of erroneous activation** of the cybersecurity controls when they are not needed.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Validation

Execution of Validation – Methods

Follow
Validation Plan

Planning of Validation

- Configuration of the Item
- Specification of Validation Procedures, Confirm Validity, Penetration Testing, Acceptance Criteria
- Equipment and Required Environmental Conditions

Carry Out
Execution of Validation

Execution of Validation

Document
Validation Report

Report on Evaluation

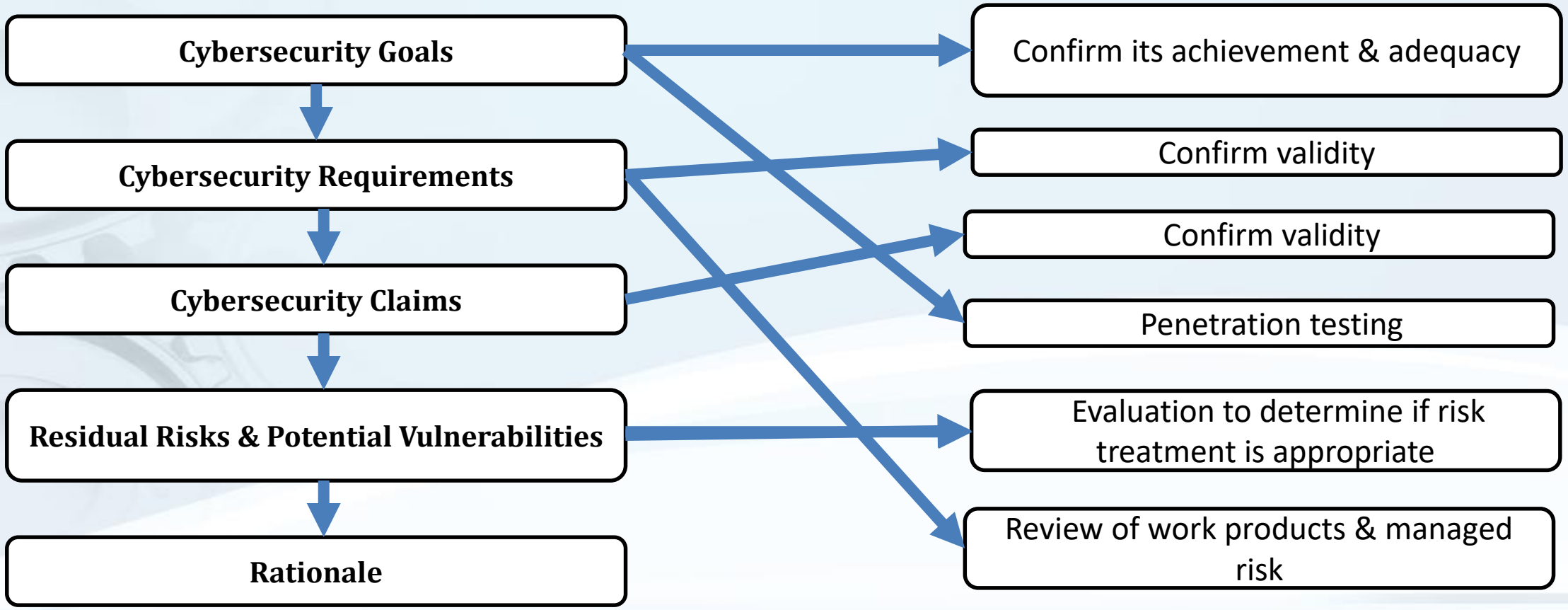
Cybersecurity Goals of Item Shall be Validation at Vehicle Level by Evaluating:

- **Impact & Attack Feasibility of the threat scenario**
- **Effectiveness of cybersecurity controls for controlling design weaknesses & flaws**
- **Effectiveness of external controls**
- **Effectiveness of elements of other technologies (RF, Self-driving vehicle, etc.)**

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Validation: Requirements

Validation Activities



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case – Part 2

At this point the Cybersecurity Case must be complete!

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Case – Part 2

Review of the Completeness of the Cybersecurity Case

- Confirmation that the work products referenced in the cybersecurity case are available and sufficiently complete, so that the item's achievement of functional cybersecurity can be adequately evaluated.
  - The referenced work products can be the work products that are identified as relevant to support the cybersecurity case.
- Confirmation that the work products referenced in the cybersecurity case:
  - Are traceable from one to another;
  - Have no contradictions within or between work products; and
  - Either have no open issues that can lead to the violation of a cybersecurity goal, or have only open issues that are controlled and have a plan for closure.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 4: Product Development Phases (Clauses 10 & 11) — What We Covered

Competency 05: Perform Activities of the Product Development Phases

- Learning Objective 11: Perform product development activities for a typical project
- ***Breakout Exercise 6: Derive Flow-down of Hardware and Software Requirements***
- Learning Objective 12: Perform cybersecurity validation activities for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 5

Post-Development Phases (Clauses 12, 13, & 14)



Chapter 5: Post-Development Phases (Clauses 12, 13 & 14) — What We Will Cover

Competency 06: List and Describe Applicable Activities of the Production, Operations & Maintenance, and Decommissioning Phases for a Typical Project

- Learning Objective 13: Perform activities of the Production, Operations and Maintenance, and Decommissioning Phases for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of Production Phase

Clause 12 — Production

- Production covers the manufacturing and assembly of an item or component, including the Vehicle Level.
- A production control plan is created to ensure that cybersecurity requirements for post-development are applied to the item or component and to ensure that vulnerabilities cannot be introduced during production.

Objectives

- Apply the cybersecurity requirements for post-development.
- Prevent the introduction of vulnerabilities during production.

Prerequisites

- Release for post-development report
- Cybersecurity requirements for post-development

Work Products

- Cybersecurity production control plan

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of Production Phase

Production Control Plan

- A production plan shall be created and implemented that includes:
  - Sequence of steps that apply the cybersecurity requirements for post-development;
  - Production tools and equipment;
  - Cybersecurity controls to prevent unauthorized alteration during production; and

    EXAMPLE 1: Physical controls that prevent physical access to production servers holding software.

    EXAMPLE 2: Logical controls that apply cryptographic techniques and/or access controls.
  - Methods to confirm that the cybersecurity requirements for post-development are met.

    NOTE 2: Methods can include inspection and calibration checks.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of Production Phase

Production Process

- The organization should have appropriate cybersecurity controls over their manufacturing processes.

  EXAMPLE: Cybersecurity for production facilities as documented in IEC/ISA 62443 Industrial Network and System Security.

- The production plan shall specify the restrictions on production access in a product to authorized purposes and users.

NOTES

- To manufacture an item or component and install the hardware and software, the production process can use privileged access. Such access can introduce vulnerabilities in the item or component if used in an unauthorized manner after production.
- Production access is designed to allow usage after a product is deployed in the field and authorization controls are implemented to control access.
- The cybersecurity requirements received from development should establish whether production access is removed or not.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of Production Phase

Logistics

- The organization shall establish and maintain controls and processes to protect supplier components during logistics and shipping from unauthorized access, deletion or alteration.
- The software, hardware and other information required for production and post-production activities and received from the Development Phase shall be protected from unauthorized access, deletion or alteration.

HW and SW Examples to be Protected:

- Microcontrollers and processors
- Complete control units
- Complete systems
- Low-level programs
- Bootloaders
- Application software
- Cryptographic material

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Operations and Maintenance

Clause 13 — Operations and Maintenance

Major Activities

- Cybersecurity incident response
- Updates

  NOTE: Modifications of items or components that are in the Concept, Product Development or Production Phases are covered by change management instead of this clause.

Objectives

- Determine and implement remedial actions for cybersecurity incidents.
- Maintain cybersecurity during and after updates to items or components after production until their end of cybersecurity support.

Work Products

- **[WP-13-01]** Cybersecurity incident response plan

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Operations and Maintenance

13.3 Cybersecurity Incident Response

- Cybersecurity incident response occurs when a cybersecurity event requires a response outside the normal course of operations.

- For example, incident remediation requires an update to products in the field. If a cybersecurity event needs to be managed, but does not rise to the level of a cybersecurity incident, it will be managed according to **8.6**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of the Operations & Maintenance Phase

13.3 Cybersecurity Incident Response

- **[RQ-13-01]** For each cybersecurity incident, a cybersecurity incident response plan shall be created that includes:
  - Remedial actions;

    NOTE 1: Remedial actions are determined by vulnerability management in **8.6**.
  - A communication plan;
  - Assigned responsibilities for the remedial actions;
  - A procedure for recording new cybersecurity information relevant to the cybersecurity incident;
  - A method for determining progress;
  - Criteria for closure of the cybersecurity incident response; and
  - Actions for the closure.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of the Operations & Maintenance Phase

Responsibilities for remedial actions:

- Expertise in affected items or components, including legacy items and components;
- Organizational knowledge (e.g., business processes, communications, purchasing, legal); and/or
- Decision authority.

Measures for determining progress include:

- Percentage of affected items or components that are remediated; and/or
- Percentage of items or components affected by remedial actions.

New cybersecurity information to be collected includes:

- Affected components;
- Related incidents and vulnerabilities;
- Forensic data such as data logs, crash sensor data; and/or
- End-user complaints.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of the Operations & Maintenance Phase

13.4 Updates

Prerequisites

- Release for Post-Development Report

Requirements for Post-Development

- **[RQ-13-03]** Updates and update-related capabilities within the vehicle shall be developed in accordance with ISO/SAE 21434.
- Updates may contain the following attributes:
  - Controls to protect the integrity of updates through delivery to the product;
  - The authenticity of the issuer of the update;
  - Unique identification of each update.

EXAMPLE: Cryptographic signatures of updates to protect integrity and prove authenticity.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of the Operations & Maintenance Phase

13.4 Updates

- Updates received from a supplier shall be analyzed for cybersecurity impact.

  EXAMPLE: A Tier 2 supplier decides to publish an update only to its customers. In this case, the suppliers higher in the supply chain would also decide on whether the update is necessary and whether to publish it to their customers or the general public.

- Update procedures shall be secured according to the identified risks associated with them.

NOTES:

- Update procedures include processes, technical channels and sequences of actions that are performed by organizations to achieve the update of products covered by ISO/SAE 21434.
- Such products are generally part of vehicle-internal E/E systems.
- Thus, update procedures are usually part of an overarching update procedure reaching from lower tier suppliers to vehicles' operators in the field.
- Secure update procedures can be achieved by considering CS principles (confidentiality, integrity and availability) and risk-based approaches.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Overview of the Operations & Maintenance Phase

13.4 Updates

- Updates shall contain necessary information for the safe and effective application of the update.

  EXAMPLE: Target of the update,

  - Models or parts to which the update applies
  - Software, firmware versions
  - Hardware configuration and/or versions

- Cybersecurity impacts of recovery options for updates shall be considered.

  EXAMPLE: Recovery options include:

  - Rollback of the update to restore the product to its previous state
  - Replacement/repair of the product

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

End of Cybersecurity Support and Decommissioning

Clause 14

- A product is considered decommissioned when it can no longer function as designed in the field.

  EXAMPLE: a vehicle that has been retired for service and stripped down for parts.
- The vehicle is then decommissioned, although the parts would not be. An airbag would be considered decommissioned when it is removed from a vehicle and destroyed.
- Decommissioning is a normal lifecycle phase for an item and is considered in the Concept and Product Development Phases under ISO/SAE 21434.
- There are cybersecurity issues associated with this phase with potential impacts.
- Decommissioning is different from end of support.
- An organization can end support for a product, but that product will still function as designed in the field.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

End of Cybersecurity Support and Decommissioning

Objectives

- Communicate the end of cybersecurity support; and
- Enable decommissioning of items and components with regard to cybersecurity.

Decommissioning can occur without the organization's knowledge and in such a way that decommissioning procedures cannot be enforced, therefore the act of decommissioning is out of scope of ISO/SAE 21434.

Decommissioning Issues:

- Sensitive information (both personal and proprietary) on products that have reached the decommissioning stage that needs to be removed or destroyed securely.
- The product itself can pose a threat if not decommissioned in a certain way, for example, products that contain pyrotechnics.
- The product can also have functions or components that need to be decommissioned to avoid CS consequences.
- If a communication mode is no longer being used, the function will need to be decommissioned to ensure that it is no longer an existing communication path for the product.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

End of Cybersecurity Support and Decommissioning

- **[RQ-14-01]** A procedure shall be created to communicate to customers when an organization decides to end cybersecurity support for an item or component.

  NOTE 1: These communications can be handled under contract requirements between suppliers and customers.

  NOTE 2: Communication to vehicle owners can be delivered by an announcement.



Work Products

- **[WP-14-01]** Procedures to communicate the end of cybersecurity support

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 5: Post-Development Phases (Clauses 12, 13 & 14) — What We Covered

Competency 06: List and Describe Applicable Activities of the Production, Operations & Maintenance, and Decommissioning Phases for a Typical Project

- Learning Objective 13: Perform activities of the Production, Operations and Maintenance, and Decommissioning Phases for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 6

Continual Cybersecurity Activities (Clause 8)



OMNEX

Chapter 6: Continual Cybersecurity Activities (Clause 8) — What We Will Cover

Competency 07: Develop a Plan for Continual Cybersecurity Activities for a Typical Project

- Learning Objective 14: Execute a plan for continual cybersecurity activities for a typical project
- ***Breakout Exercise 7: Develop Cybersecurity Plans (Continual Cybersecurity Activities and Incidence Response)***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

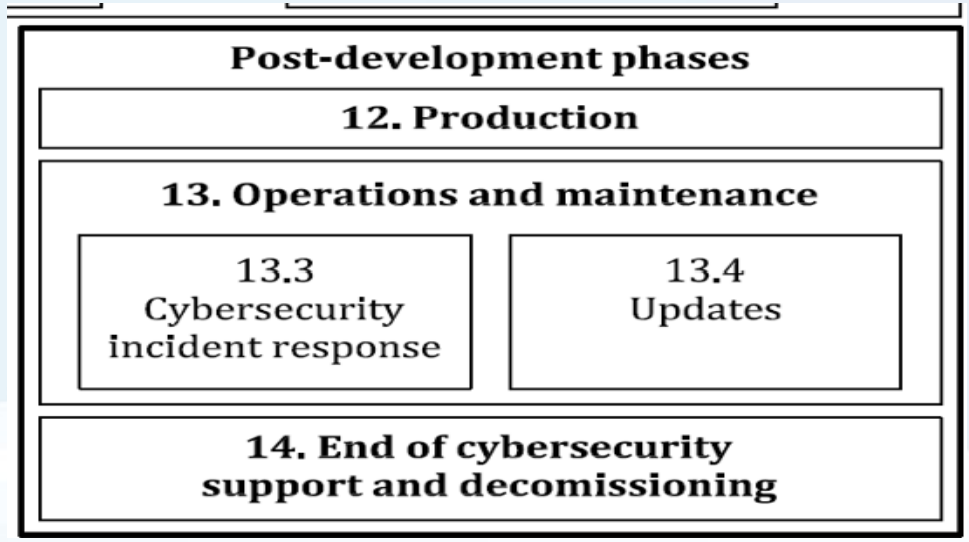
Continual Cybersecurity Activities (Clause 8)

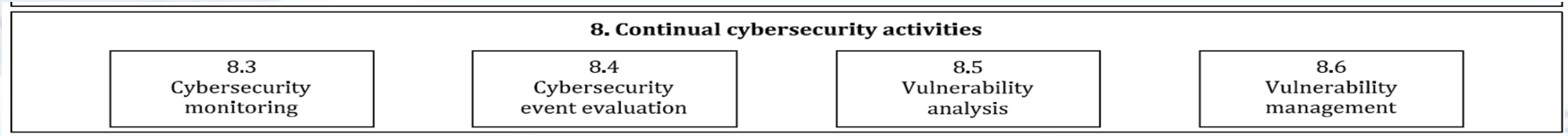
Continual Cybersecurity Activities is what differentiates ISO/SAE 21434 from ISO 26262.

Objectives

The objectives of this clause are to:

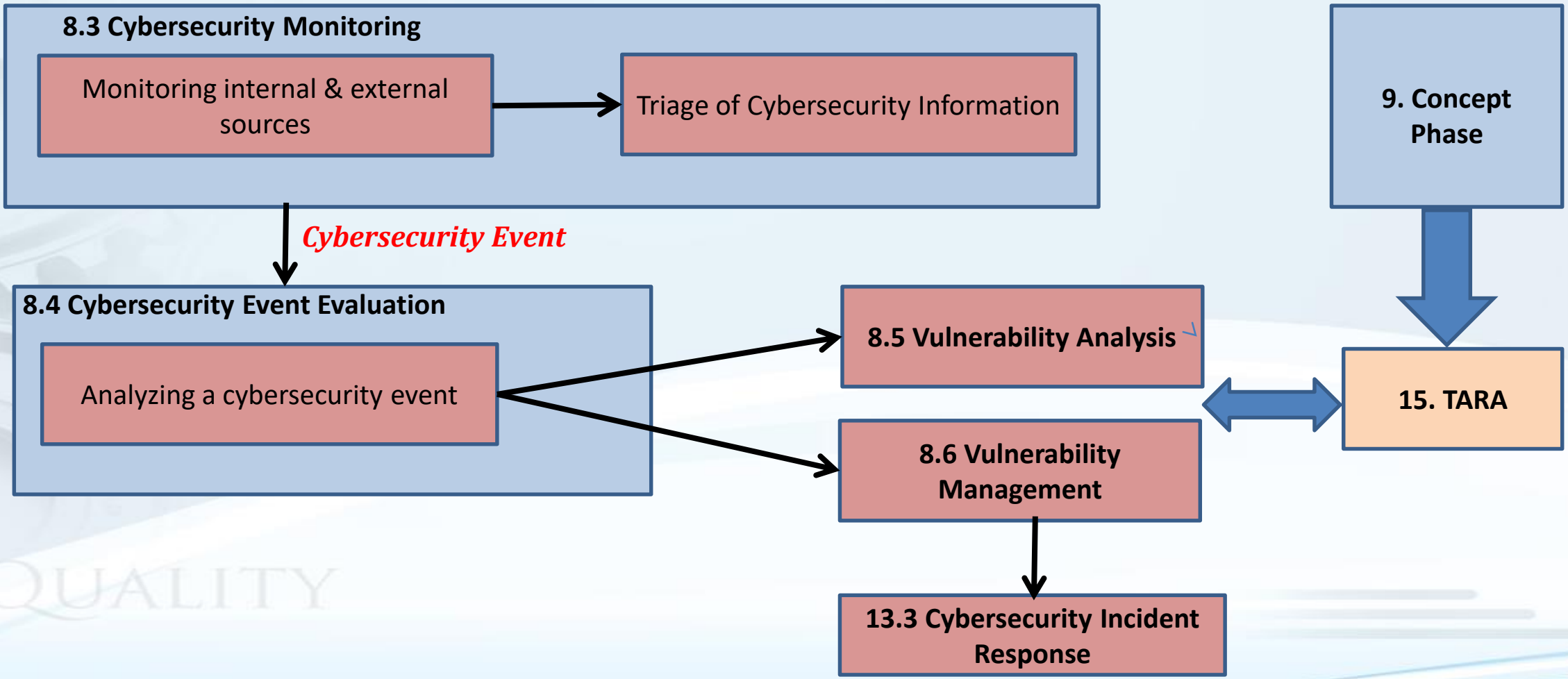
- Monitor cybersecurity information to identify cybersecurity events;
- Evaluate cybersecurity events to identify weaknesses;
- Identify vulnerabilities from weaknesses; and
- Manage identified vulnerabilities.





Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Continual Cybersecurity Activities (Clause 8)



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.3 Cybersecurity Monitoring

Cybersecurity Monitoring collects cybersecurity information and analyzes the cybersecurity information for triage based on defined triggers.

Prerequisites

- Rules and processes for the development of triggers

Additional Information

- Item definition **[WP-09-01]**
- Cybersecurity claims **[WP-09-04]**
- Cybersecurity specifications **[WP-10-01]**
- Threat scenarios **[WP-15-03]**
- Past vulnerability analyses **[WP-08-05]**
- Information received from the field

  EXAMPLE Vulnerability scanning reports, repair information, consumer usage information.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.3 Cybersecurity Monitoring

- **[RQ-08-01]** Sources shall be selected for collection of cybersecurity information.

  NOTE 1: Internal and/or external sources can be selected.

- **[RQ-08-02]** Triggers shall be defined and maintained for the triage of cybersecurity information.

  NOTE 4: Triggers can include keywords, reference for configuration information, names of components or suppliers.

- **[RQ-08-03]** Cybersecurity information shall be collected and triaged to determine if the cybersecurity information becomes one or more cybersecurity events.

External/Internal Sources of Cybersecurity Information:

- Researchers
- Commercial and/or non-commercial sources of CS information
- Organization's supply chain
- Security information received from products in the field
- Customers of the organization; government sources
- Results of vulnerability assessments
- Information received from products in the field (e.g., vulnerability scanning reports, repair information, consumer usage information)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.3 Cybersecurity Monitoring

- The organization should define frequencies for collecting cybersecurity information.
- The organization should maintain monitoring for cybersecurity relevant products starting from the Concept Phase and continuing through to at least the end of cybersecurity support for the product.
- The organization should have a process for providing cybersecurity information to those responsible for all Development Phases.

NOTES:

- The frequency of CS information collection is determined by the threat environment and the needs of the organization, including such factors as timeliness in threat response and the capability to analyze CS information.
- An organization can choose to extend monitoring even after CS support has ended.
- CS information is shared to relevant parties in accordance with the information sharing policy.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.3 Cybersecurity Monitoring

Work Products:

- **[WP-08-01]** Sources for cybersecurity information
- **[WP-08-02]** Triggers
- **[WP-08-03]** Cybersecurity events

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.4 Criteria for Triage

- Triage should be based on defined triggers and applied to cybersecurity information to determine if cybersecurity information becomes one or more cybersecurity events.

- Criteria for the triage that can be used to define the trigger thresholds can include:
  - Whether cybersecurity information comes from a known trusted source;
  - The determined risk of the threat scenarios of the item resulting from the activity ; and/or
  - The type of information obtained (e.g., an active attack or proof of concept).

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.4 Cybersecurity Event Evaluation

- Cybersecurity event assessment happens after cybersecurity information is triaged and determined to be a cybersecurity event.
- Cybersecurity event evaluation determines if the cybersecurity event presents a weakness for an item or component.

Prerequisites

- Cybersecurity events
- Cybersecurity requirements for post-development, if applicable;
- Configuration information

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.4 Cybersecurity Event Evaluation

- A cybersecurity event assessment shall be conducted to determine if the cybersecurity event affects the product.
- Appropriate testing methods for cybersecurity vulnerabilities for use in cybersecurity event assessment shall be maintained.
- The vulnerability analysis from product development shall be reviewed to determine if the vulnerability was previously considered (e.g., in the threat analysis stage) and any applicable risk treatment determined.
- If no risk treatment exists, then an attack path analysis shall be performed in accordance with **15.6**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.4 Cybersecurity Event Evaluation

- **[RQ-08-04]** A cybersecurity event shall be evaluated to identify weaknesses in an item and/or component.

  NOTE 1: This activity can be combined with triage.

  NOTE 2: If a weakness exists and there is a remediation available.
  (e.g., a patch provided by a supplier for a vulnerability in a component), the organization can handle the remediation (see **8.6**) as an assumed vulnerability without any other activity.

  NOTE 3: Threat scenarios can be updated based on the result of this evaluation.

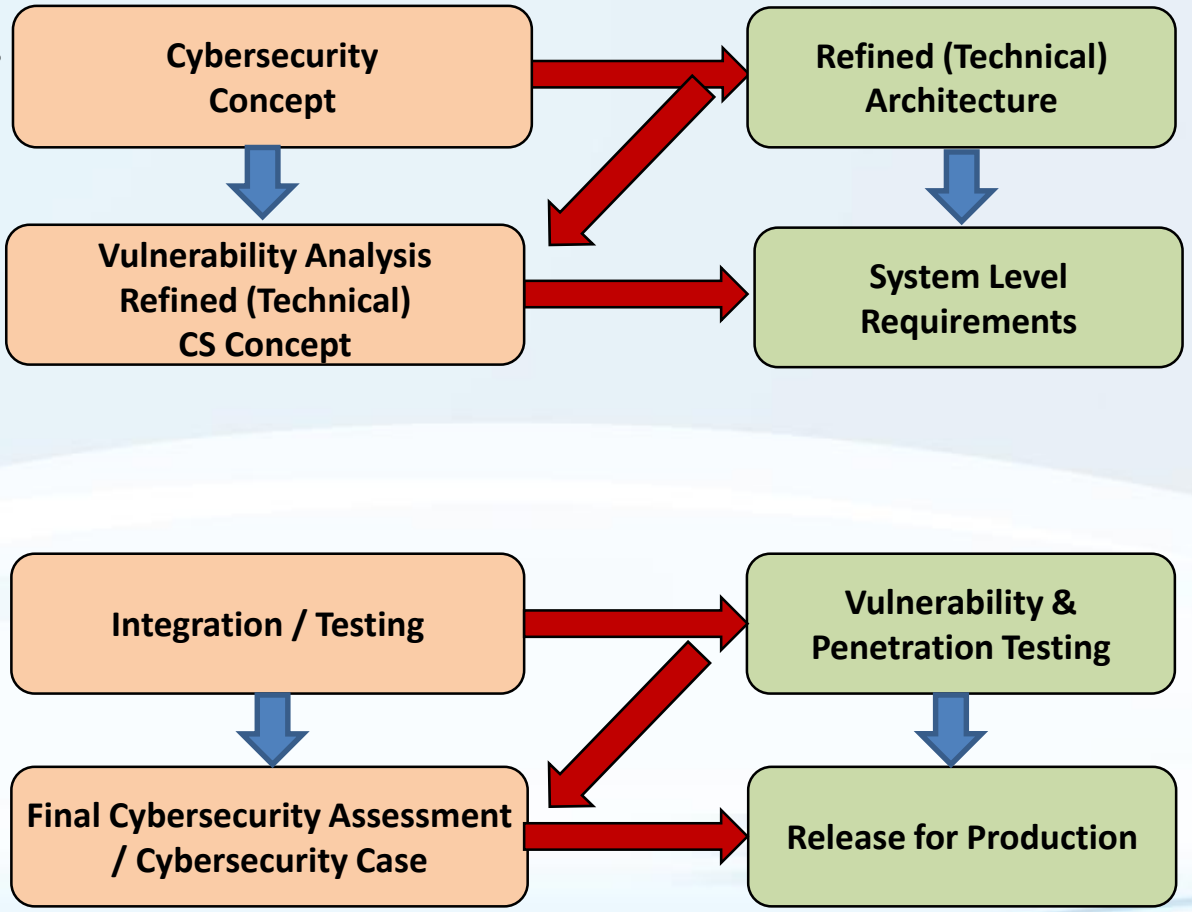
Work Products

- **[WP-08-04]** Weaknesses from cybersecurity events.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.5 Vulnerability Analysis

- **Vulnerability:** Weakness of an item or control that can be exploited by one or more threats.
- Vulnerabilities with threats ➔ Attacks
- Typical Vulnerabilities categories:
  - Architectural issues;
  - Design weaknesses;
  - Implementation flaws;
  - Hardware or software bugs;
  - Missing security controls;
  - Incorrect implementation. etc.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.5 Vulnerability Analysis

Objectives

- The objective of this subclause is to identify and analyze cybersecurity vulnerabilities.

General

- Vulnerability analysis is an activity that examines flaws or weaknesses in the target-of-analysis and assesses if a particular weakness or flaw could be exploited to launch an attack.

Weaknesses Examples:

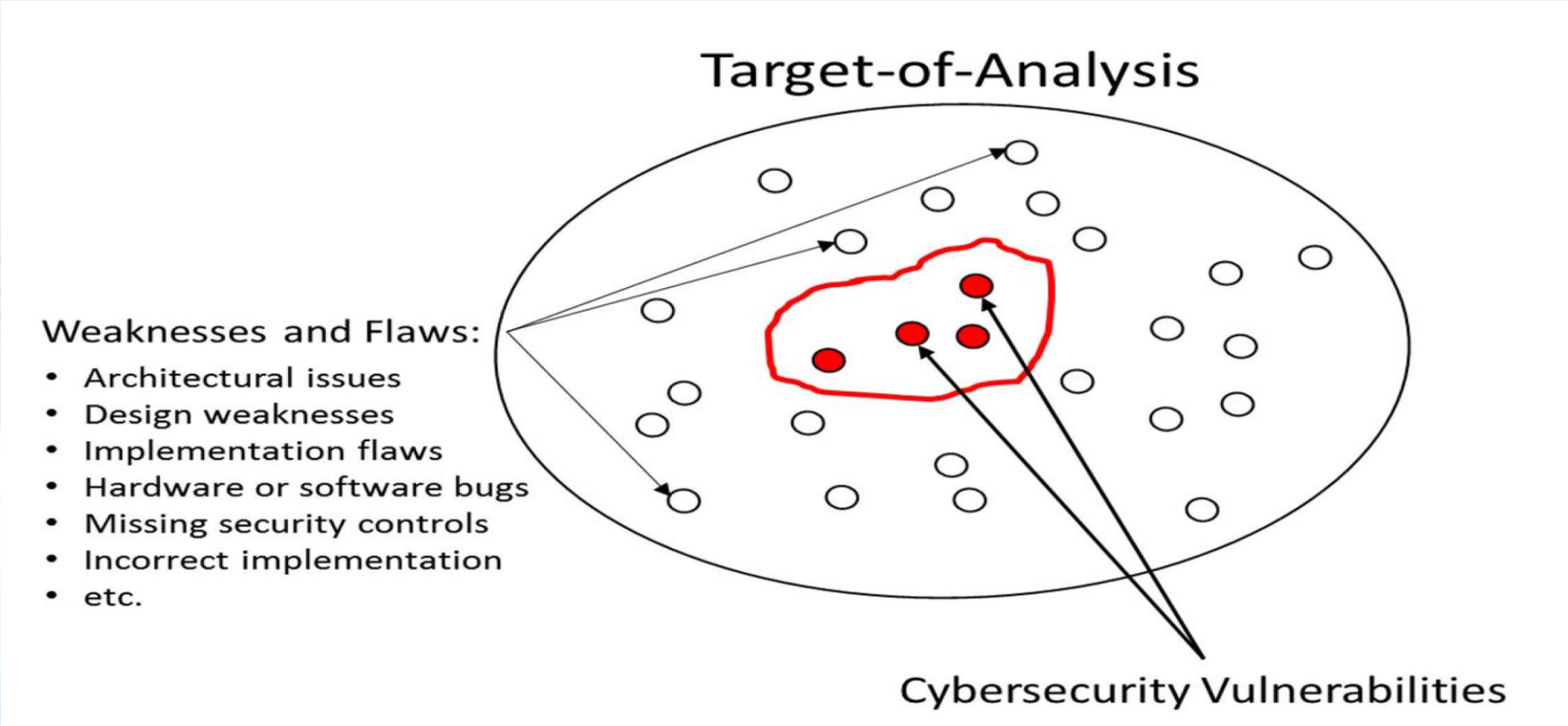
- Missing requirements or specifications
- Architectural or design weaknesses and flaws
- Implementation weakness or flaws, including hardware and software bugs
- Weaknesses in the operational processes and procedures including misuse
- Inadequate user-training and education
- Use of outdated or deprecated functions
- Use of broken cryptographic algorithms
- Incorrect design or implementation of security protocols

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.5 Vulnerability Analysis

General

- A flaw, or a weakness becomes a cybersecurity vulnerability when it holds the potential of being used to launch an attack.



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.5 Vulnerability Analysis

Further Supporting Information

- Known vulnerabilities from common sources

  EXAMPLES: CVE, CWE, SANS, OWASP

  CVE= common vulnerabilities and exposures ; CWE= common weakness enumeration; OWASP= open web application security project

- Reports from vulnerability scan tools

  NOTE: A vulnerability scan generally is an automated scan that looks for the existence of historically discovered generic known-vulnerabilities in the current target of analysis.

- List of unpublished vulnerabilities and vulnerabilities disclosure program

  NOTE: These are potential vulnerabilities that have not been exploited, not known in the wild or not published on common vulnerability databases or integrated in vulnerability scanning tools.

- Knowledge from past vulnerability analyses
- Cybersecurity incident records and cybersecurity information

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.5 Vulnerability Analysis

- **[RQ-08-05]** Weaknesses shall be analyzed to identify vulnerabilities.

  NOTE 1: The analysis can include:

  - Analysis of the architecture;
  - Attack path analysis in accordance with **15.6**; and/or
  - Attack feasibility rating in accordance with **15.7**.

  NOTE 2: A root cause analysis can be performed to determine any underlying factors that contribute to the possibility of a weakness being a vulnerability.

  EXAMPLE 1: Attack path analysis reveals no attack path exists and therefore, the weakness is not treated as a vulnerability.

  EXAMPLE 2: The attack feasibility rating is very low for exploiting the weakness and therefore, the weakness is not treated as a vulnerability.

- **[RQ-08-06]** A rationale shall be provided for a weakness that is not identified as a vulnerability.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

8.6 Vulnerability Management

- **[RQ-08-07]** Vulnerabilities shall be managed such that for each vulnerability:
  - The corresponding cybersecurity risks are assessed and treated such that no unreasonable risks remain; or
  - The vulnerability is eliminated by applying an available remediation independent of a TARA.

    EXAMPLE: Patches for open source software.

    NOTE 1: If vulnerability management results in a change to an item or component, change management is applied.

    NOTE 2: Information about vulnerabilities can be shared within the context of distributed cybersecurity activities (see **7.4.3**, e.g. sharing knowledge of attack paths) and to other interested parties (see **5.4.3**).

- **[RQ-08-08]** If a risk treatment decision necessitates cybersecurity incident response, then **13.3** shall be applied.

  NOTE 3: The cybersecurity incident response process can be applied independent of a TARA.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 7

Develop Cybersecurity Plans (Continual Cybersecurity Activities and Incidence Response)

Allotted Time: 90 minutes



Chapter 6: Continual Cybersecurity Activities (Clause 8) — What We Covered

Competency 07: Develop a Plan for Continual Cybersecurity Activities for a Typical Project

- Learning Objective 14: Execute a plan for continual cybersecurity activities for a typical project
- ***Breakout Exercise 7: Develop Cybersecurity Plans (Continual Cybersecurity Activities and Incidence Response)***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 7

Distributed Cybersecurity Activities (Clause 7)



Chapter 7: Distributed Cybersecurity Activities (Clause 7) — What We Will Cover

Competency 08: Perform Distributed Cybersecurity Activities for a Typical Project

- Learning Objective 15: Perform distributed cybersecurity activities for a typical project
- ***Breakout Exercise 8: Develop a Cybersecurity Interface Agreement***

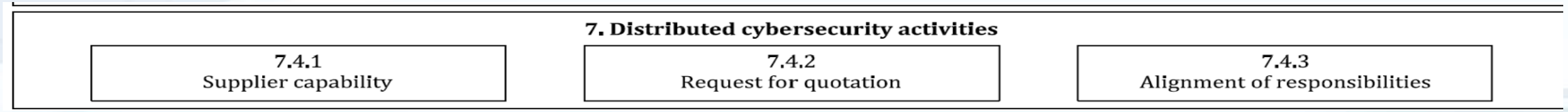
Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Clause 7: Distributed CS Activities

This clause describes management of distributed cybersecurity activities and applies to:

- Items and components developed in a distributed activity;
- Interactions between a customer and a supplier; and
- All phases where an agreement is applicable to the customer/supplier interface.

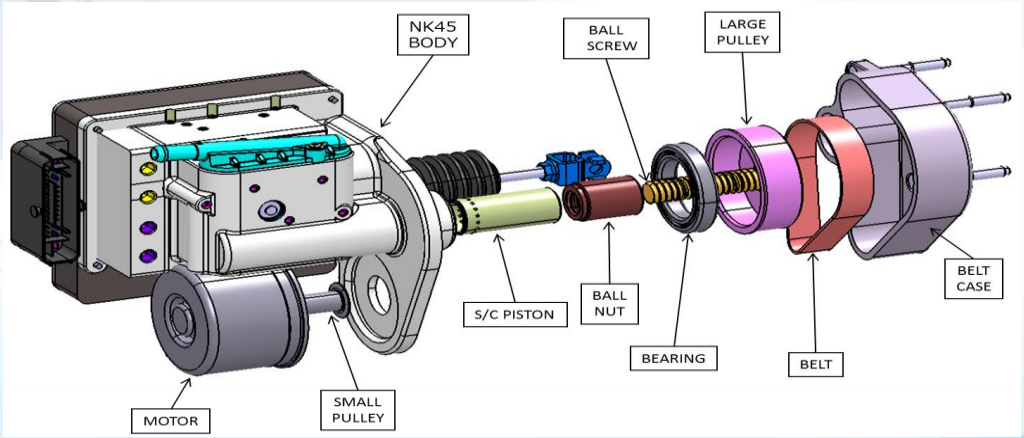
Internal suppliers can be managed in the same way as external suppliers.

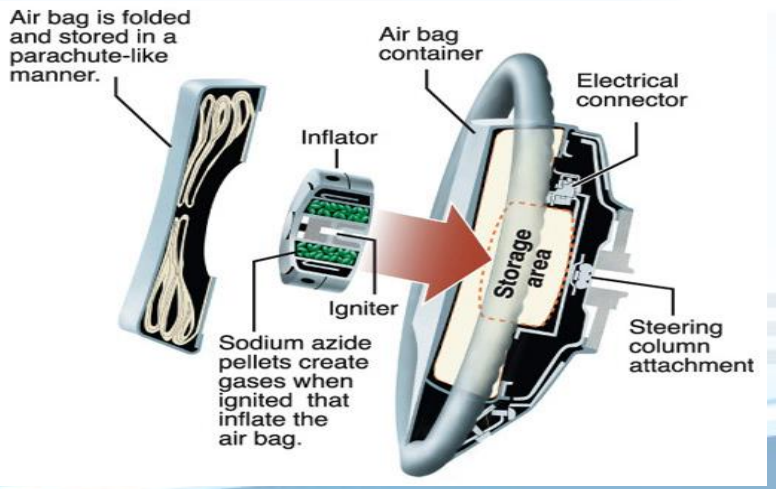


Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Distributed Development

- Since most OEMs do not develop the complete system, the ISO/SAE 21434 requirements need to be split (i.e., distributed) to the Tier 1 and sometimes, Tier 2, Suppliers, etc.
- ISO/SAE 21434 compliance is initiated by the customer (e.g., OEM).
- Cybersecurity requirements start at the Vehicle Level.
- This distribution of requirements is established in the Development Interface Agreement (DIA).

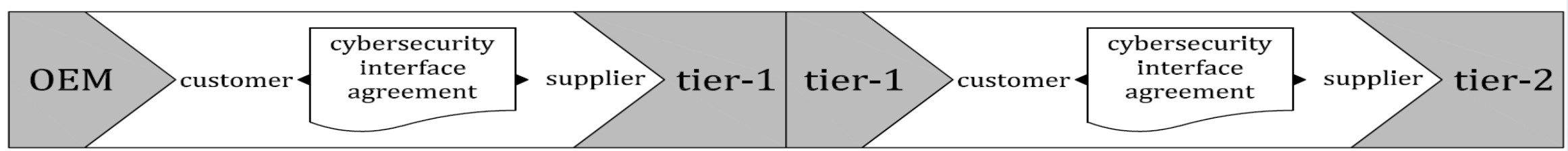




Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Distributed Development

For example, a Tier 1 organization can be a supplier to an OEM during development and in another contractual relationship the Tier 1 organization can be a customer of a Tier 2 organization for a component. This is illustrated in the figure below.



Objectives:

- The objective of this clause is to define the interactions, dependencies, and responsibilities for distributed cybersecurity activities between customers and suppliers.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

7.4.1 Supplier Capability

- **[RQ-07-01]** The capability of a candidate supplier to develop and, if applicable, perform post-development activities in accordance with ISO/SAE 21434 shall be evaluated.

  NOTE 1: This evaluation supports supplier selection and can be based on the supplier's capability to conform to ISO/SAE 21434, or on an evaluation of the previous implementation of another national or international standard with regard to cybersecurity engineering.

- **[RC-07-02]** To support a customer's evaluation of supplier capability, a supplier should provide a record of cybersecurity capability.

  NOTE 2: A record of cybersecurity capability can include:

  - Evidence of the organization's capability concerning cybersecurity (e.g., cybersecurity best practices from development, post-development, governance, quality, and information security);
  - Evidence of continual cybersecurity activities (**Clause 8**) and cybersecurity incident response (**Clause 13**); and
  - Summary of previous cybersecurity assessment reports.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

7.4.2 Request for Quotation

- **[RQ-07-03]** A request for quotation from a customer to a candidate supplier shall include:
  - A formal request to conform to ISO/SAE 21434;
  - The expectation that cybersecurity responsibilities will be taken on by the supplier in accordance with **7.4.3**; and
  - The cybersecurity goals and/or set of cybersecurity requirements relevant to the item or component for which the supplier is quoting.

EXAMPLE: Cybersecurity requirements related to message authentication.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

7.4.3 Alignment of Responsibilities

- **[RQ-07-04]** A customer and a supplier shall specify the distributed cybersecurity activities in a cybersecurity interface agreement including:
  - Appointment of customer's and supplier's points of contact regarding cybersecurity;
  - Identification of cybersecurity activities that are to be performed by customer and supplier ,respectively;

    EXAMPLE 1: Cybersecurity validation at the Vehicle Level performed by the customer.

    EXAMPLE 2: The distribution of cybersecurity activities regarding post-development.

    EXAMPLE 3: The cybersecurity assessment concerning the components or work products developed by the supplier can be performed by a third party, the customer or the supplier.
  - If applicable, a joint tailoring of cybersecurity activities;
  - The information and the work products to be shared;
  - Milestones regarding the distributed cybersecurity activities; and
  - Definition of the end of cybersecurity support for the item or component.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

7.4.3 Alignment of Responsibilities

- **[RC-07-05]** The cybersecurity interface agreement should be mutually agreed upon between customer and supplier prior to the start of the distributed cybersecurity activities.
- **[RQ-07-06]** If there is an identified vulnerability to be managed in accordance with **[RQ-08-07]**, the customer and supplier shall agree on actions and responsibility for those actions.
- **[RQ-07-07]** If requirements are unclear, not feasible, or conflict with other cybersecurity requirements or requirements from other disciplines, then customer and supplier shall each notify the other so that appropriate decisions and actions can be taken.
- **[RC-07-08]** Responsibilities should be specified in a responsibility assignment matrix.

NOTE 2: A RASIC table can be used.

7.5 Work Products

- **[WP-07-01]** Cybersecurity Interface Agreement

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

7.4.3 A RASIC Table

It is an element of a DIA (Development Interface Agreement) related to work sharing to illustrate how responsibilities of cybersecurity activities to be performed by the customer and by the supplier.

"**R**" stands for **responsible**. The organization marked "R" is responsible for getting the activity done.

"**A**" stands for **approve**. The organization marked "A" gives approve or deny the activity once it's complete.

"**S**" stands for **support**. The organization marked "S" actively will help the organization responsible for the activity.

"**I**" stands for **inform**. The organization marked "I" need to be informed of the progress of the activity and any decisions being made.

"**C** "stands for **consult**. The organization marked "C" offers advice or guidance but do not actively work on the activity.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

RASIC Table Template

Phase	Work Product	Dec. Ref.	Supplier					Customer					Level of Confidentiality	Comment
			R	A	S	I	C	R	A	S	I	C		
Concept Phase	*Item Definition*	*2.4.4.1*												
	Threat Analysis and Risk Assessment	*2.4.4.3*												
	Cybersecurity Concept	2.4.5.1												
	Cybersecurity Concept Verification Report	2.4.5.2												
System Development Phase	Cybersecurity Requirements	2.5.5.1												
	Hardware-Software Interface Specification	2.5.5.3												

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

After Release for Production

- Each party that becomes aware of a cybersecurity-related event shall report this in a timely manner and according to the DIA.
- If a cybersecurity-related event occurs, an analysis of that event shall be performed.
- This analysis should include similar items and related parties which are potentially affected by a similar event.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Breakout Exercise 8

Develop a Cybersecurity Interface Agreement (CIA)

Allotted Time: 90 minutes



OMNEX

Chapter 7: Distributed Cybersecurity Activities (Clause 7) — What We Covered

Competency 08: Perform Distributed Cybersecurity Activities for a Typical Project

- Learning Objective 15: Perform distributed cybersecurity activities for a typical project
- ***Breakout Exercise 8: Develop a Cybersecurity Interface Agreement***

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 8

Implementing Automotive Cybersecurity



OMNEX

Chapter 8: Implementing Automotive Cybersecurity — What We Will Cover

Competency 09: Develop a Plan to Implement Automotive Cybersecurity

- Learning Objective 16: Develop a plan to implement automotive cybersecurity for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

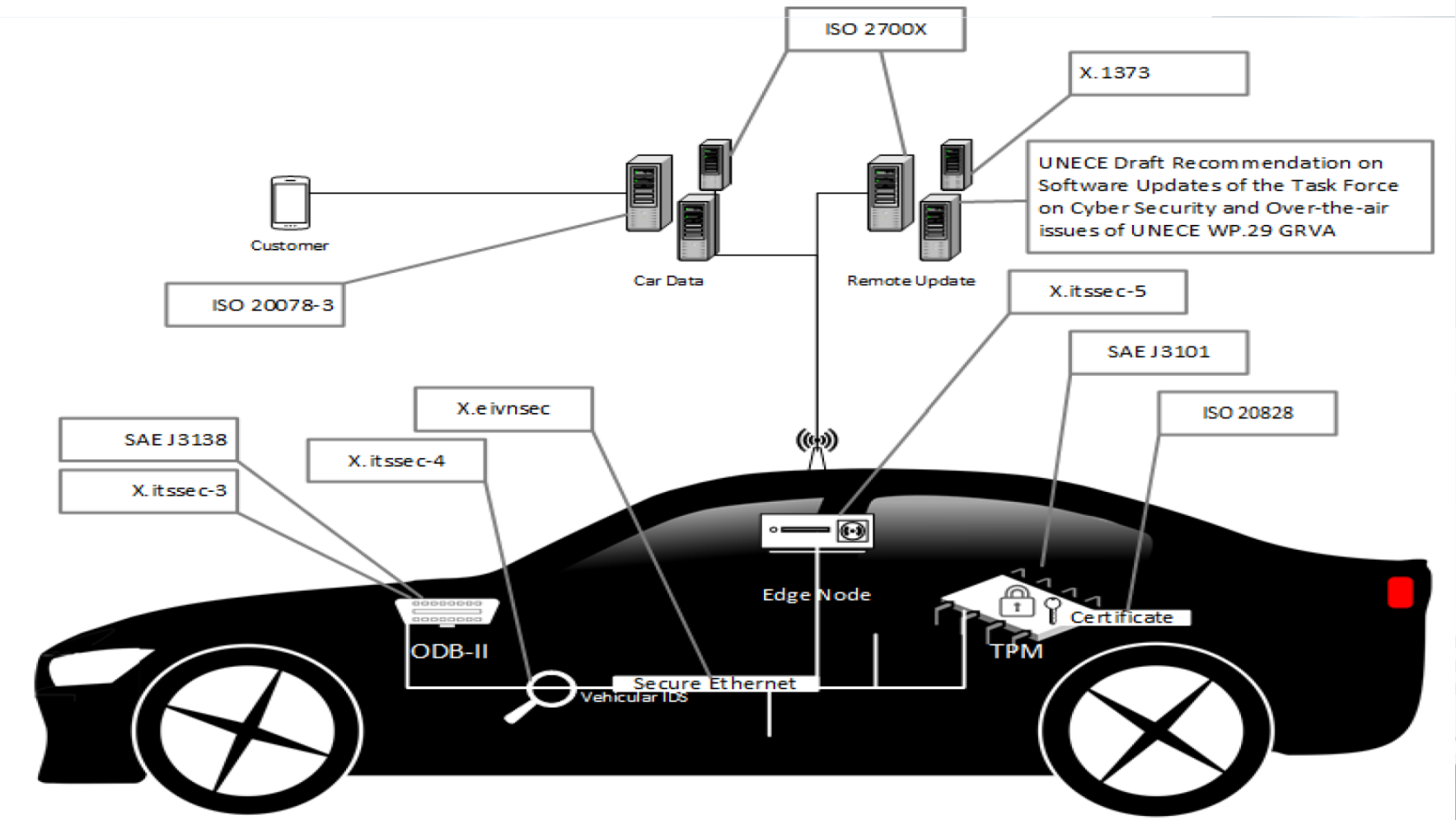
Automotive Cybersecurity Context

- At the time ISO/SAE 21434 was developed, there were many automotive–related standards and documents available or in development.
- ISO/SAE 21434 does **NOT** cover all aspects of automotive cybersecurity.
- Missing components:
  - Hardware security environment, HSM (hardware security module), etc.
  - Over the air (OTA) software updates
  - Detailed specifications and specifications
  - Wireless communications and protocols (e.g., Bluetooth (BT))
  - OBD-II (On-board diagnostics II)
  - Web-based
  - Cloud-based

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Automotive Cybersecurity Context

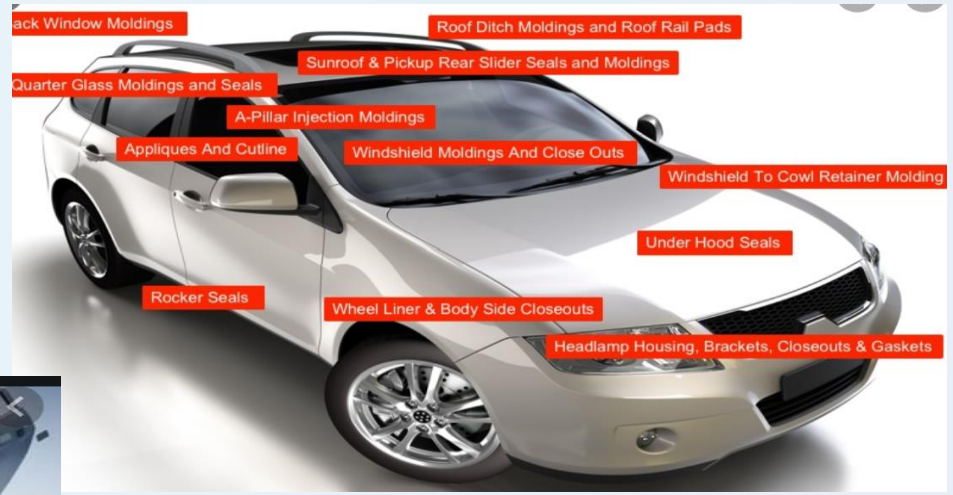
Standards available or in development at the time ISO/SAE 21434 was developed:



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Supply Chain Considerations

- Implementing automotive cybersecurity is different for:
  - OEMs
  - Tier 1s
  - Tier 2s







Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Supply Chain Considerations

Types of Cybersecurity Requirements by Supply Chain Organizations

Organization	Requirements Implementation Considerations
OEMs	Requirements are mostly at the Vehicle Level (i.e., at the System Level) including emphasis on management aspects and the specification of various methods. For example, a TARA conducted at the Vehicle Level can identify mitigations for risk, i.e., prevention and detection at the Vehicle, System, Hardware or Software Levels of the architecture of BOM.
Tier 1	Requirements are related to the Vehicle Level (including flow-down to lower levels), Subsystem Level, balance on management & technical aspects, and implementation of specific standards. A Tier 1 may be required to conduct its own TARA at the System Level to identify prevention and detection for asset protection within the system and its sub-components including software. This may be specified in the DIA or it may be from their implementation of ISO/SAE 21434.
Tier 2	Requirements are mostly at the Component Level with emphasis on technical, implementation of specific standards.

Note: Some statements in the above table are not clear cut and are based on experience and observed trends in the industry; thus, they are not statements that always hold true in all cases.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Supply Chain Considerations: CooC

Component out-of-Context (CooC) Activities by Supply Chain Organizations

Tier 2 Activities	Tier 1 Activities	OEM Activities
Assumptions on the scope of CooC and its related item	Establish validity of assumptions	Establish validity of assumptions
Assumption on functional cybersecurity requirement of the CooC	CooC integration in the item	Item integration in the vehicle
Execution of CooC development		
Provision of work products to system integrator		

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

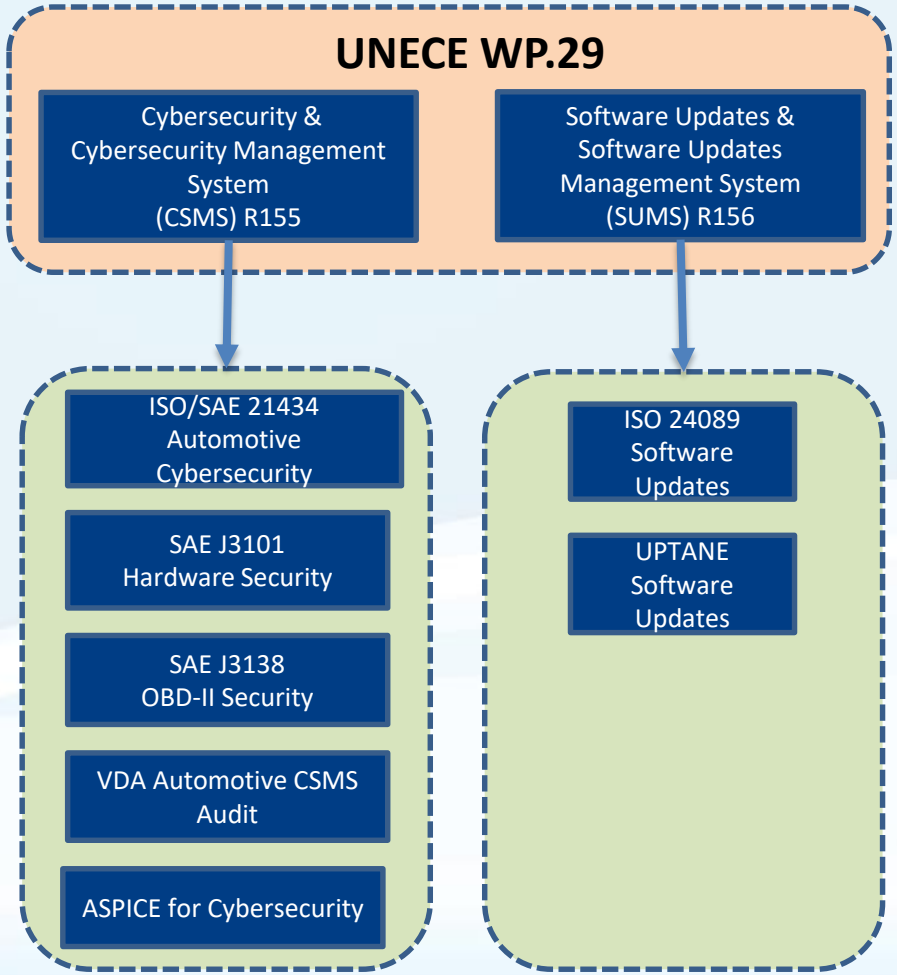
Other Standards

Main Roles of Various Documents for Implementing Cybersecurity

Standard	Main Role
ISO/SAE 21434	Security management (overall and product), risk based, safety lifecycle, main cybersecurity requirements, TARA.
WP.29 (UNECE R155 and R156)	Initiate and pursue actions aimed at the worldwide harmonization or development of cybersecurity regulations (R155) and software updates (R156) for vehicles.
SAE J3101	Common set of requirements and mitigations to be implemented in hardware-assisted functions. Defines a Hardware Protected Security Environment (HPSE).
SAE J3138	Describes some of the actions that should be taken to help ensure safety in the case that any connected device (external test equipment, etc.) has been compromised by a source external to the vehicle.
Uptane	An open and secure software update system design which protects software delivered over-the-air (OTA) to the various ECUs in a vehicle.
ASPICE for Cybersecurity	An ASPICE extension to cover the Concept Phase, Product Development Phase, TARA, and distributed cybersecurity activities as defined by ISO/SAE 21434.
ISO 24089	ISO standard for software updates.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Relationship of UNECE WP.29 Regulations with Other Standards / Documents



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Nature of Standards: SAE J3101

1. Introduction
2. References
3. Definitions
4. Hardware Protected Security Environment (HPSE)
5. Lifecycle of HW Protected Security in a Vehicle
6. Common Requirements
7. Profiles of HW Security Common Requirements
8. Validation and Verification
9. Primary Use Cases
10. Application Use Cases

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

SAE J3101: Common Requirements

6. COMMON REQUIREMENTS

- 6.1 Mandatory vs Optional, Required vs. Conditional
- 6.2 Cryptographic Key Protection
- 6.3 Cryptographic Algorithms and Protocols
- 6.4 Random Number Generation
- 6.5 Nonvolatile Critical Security Parameters
- 6.6 Cryptographic Algorithm Agility
- 6.7 Interface Control
- 6.8 Secure Execution Environment
- 6.9 Self-Test

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

SAE J3101: Primary and Application Use Cases

9. PRIMARY USE CASES

- 9.1 Authenticated Boot
- 9.2 Authenticated Update
- 9.3 Secure In-vehicle Messaging
- 9.4 Access Mechanisms
- 9.5 Secure Storage

10. APPLICATION USE CASES

- 10.1 IP Protection
- 10.2 Secure Diagnostics at ECU Level
- 10.3 Secure Logging

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Nature of Standards: SAE J3138

Main Contents of the SAE Guideline

3. TERMS AND DEFINITIONS

4. GENERAL RECOMMENDATIONS

- 4.1 Protocol Service Categorization
- 4.2 Legislated Services
- 4.3 Network Communications and CAN Protocol Error Handling
- 4.4 Measurement, Calibration and Enhanced Protocols
- 4.5 Service Requests to Gateway(s) or Individual ECUs
- 4.6 Safe System Condition

5. TECHNICAL RECOMMENDATIONS FOR NEW VEHICLE NETWORKS WITH NO GATEWAY

6. TECHNICAL RECOMMENDATIONS FOR NEW VEHICLE NETWORKS WITH PARTIAL GATEWAY

7. TECHNICAL RECOMMENDATIONS FOR NEW VEHICLE NETWORKS WITH FULL GATEWAY OR MULTIPLE GATEWAY CONFIGURATION(S)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Nature of Standards: WP.29 (Cybersecurity Management System – R155)

Main Contents of the UN R155 Regulation

5. APPROVAL

6. CERTIFICATE OF COMPLIANCE FOR CYBERSECURITY MANAGEMENT SYSTEM

7. SPECIFICATIONS

8. MODIFICATION AND EXTENSION OF THE VEHICLE TYPE

9. CONFORMITY OF PRODUCTION

10. PENALTIES FOR NON-CONFORMITY OF PRODUCTION

11. PRODUCTION DEFINITIVELY DISCONTINUED

12. NAMES AND ADDRESSES OF TECHNICAL SERVICES RESPONSIBLE FOR CONDUCTING APPROVAL TEST, AND OF TYPE APPROVAL AUTHORITIES

ANNEXES

1 Information Document

2 Communication

3 Arrangement of Approval Mark

4 Model of Certificate of Compliance for CSMS

5 List of Threats and Corresponding Mitigations

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Nature Of Standards: Uptane (Software OTA)

1. Introduction
2. Terminology
3. Rationale For and Scope of Uptane Standards
4. Threat Model and Attack Strategies
5. Detailed Design of Uptane
   - 5.1. Roles on Repositories
   - 5.2. Metadata Structures
   - 5.3. Server / Repository Implementation Requirements
   - 5.4. In-vehicle Implementation Requirements
6. References

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29: R155 Security Requirements

The UN R155 regulation has a large number of stringent and specific requirements for OEMs and the vehicles they manufacture.

- There are 17 generic group of requirements in the following categories:
  1. OEM specific (**Sections 6 & 7**)
  2. Vehicle specific (**Annex 5, Parts A and B**)
  3. Back-end servers holding vehicle data (**Annex 5, Part C**)
- Nevertheless, an OEM is responsible for implementing **ALL** requirements.
- In light of these requirements, what are the significant standards to help OEMs implementing them?

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29: R155 Security Requirements

OEM SPECIFIC (Sections 6 & 7)

1. Certificate of Compliance of a CSMS (**Section 6 & 7.2**)
2. Identify and manage supplier-related risks (**7.3.2**)
3. Identify critical elements, perform an exhaustive risk assessment, and treat/manage identified risks (**7.3.3**)
4. Protect the vehicle against risks identified in the risk assessment through mitigations (**7.3.4**)
5. Perform appropriate and sufficient testing to verify the effectiveness of the security measures implemented (**7.3.6**)
6. Cryptographic modules used for the purpose of R155 shall be in line with consensus standards (**7.3.8**)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29: R155 Security Requirements In Annex 5

VEHICLE SPECIFIC

- **Part A**: Describes the baseline for threats, vulnerabilities and attack methods.
- **Part B:** Describes mitigations to the threats which are intended for vehicle types.

BACK-END SERVERS

- **Part C:** Describes mitigations to the threats which are intended for areas outside of vehicles, e.g., on IT backends.

NOTE: Part A, Part B, and Part C shall be considered for risk assessment and mitigations to be implemented by vehicle manufacturers.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29: R155 Security Requirements

VEHICLE SPECIFIC

1. Vulnerabilities and Attack Methods to be Addressed (**Annex 5, Part A, Table A1**)
2. Mitigations for Vehicle Communication Channels (**Annex 5, Part B, Table B1**)
3. Mitigations for Update Process (**Annex 5, Part B, Table B2**)
4. Mitigations for Unintended Human Actions (**Table B3**)
5. Mitigations for External Connectivity and Connections (**Table B4**)
6. Mitigations for Potential Targets for an Attack (**Annex 5, Part B, B5**)
7. Mitigations for Potential Vulnerability, Not Sufficiently Protected (**Table B6**)
8. Mitigations for Data Loss/ Data Breach from Vehicle (**Table B7**)
9. Mitigations for "Physical Manipulation of Systems to Enable an Attack" (**Table B8**)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29: R155 Security Requirements

BACK END SERVERS

1. Mitigations for Back-end Servers (**Annex 5, Part C, Table C1**)
2. Mitigations for Unintended Human Actions (**Annex 5, Part C, Table C2**)
3. Mitigations for Physical Loss of Data Loss (**Annex 5, Part C, Table C3**)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Other Standards: WP.29 – R155

Supply Chain Classification of Some R155 Requirements

Sample of WP.29 Cybersecurity Requirements	OEM	Tier 1	Tier 2
Certificate of Compliance of a CSMS. (**6.1 to 6.11**)	X		
The vehicle manufacturer shall identify and manage supplier-related risks (**7.3.2**)	X		
The vehicle manufacturer shall identify the critical elements and perform an exhaustive risk assessment and shall treat/manage the identified risks appropriately (**7.3.3**)	X		
The vehicle manufacturer shall protect the vehicle type against risks identified in the vehicle manufacturer's risk assessment. Proportionate mitigations shall be implemented to protect the vehicle type (**7.3.4**)	X		
Secure software update procedures shall be employed.		X	
Security controls shall be applied to systems that have remote access.		X	
Cybersecurity best practices for software and hardware development shall be followed.		X	X
Access control techniques and designs shall be applied to protect system data/code.			X
Security controls shall be implemented for storing cryptographic keys.			X

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29 – R156: Software Update and Software Updates Management System (SUMS)

- The UN R156 regulation applies similarly to R155 (Cybersecurity Management System).
- An application for a Certificate of Compliance for Software Update Management System shall be submitted by the vehicle manufacturer.
- The manufacturer shall declare and demonstrate to the satisfaction of the Approval Authority that they have the necessary processes to comply with all requirements for software updates according to R156.
- A number of processes are to be verified at the initial assessment:
  - A process whereby information regarding all initial and updated software versions, including integrity, validation data, and relevant hardware components of a type-approved system can be uniquely identified;
  - Etc.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

WP.29 – R156: Software Update and Software Updates Management System (SUMS)

- The vehicle manufacturer shall record and store the following information for each update applied to a given vehicle type:
  - Documentation for all software updates for the vehicle type describing:
    a) The purpose of that update;
    b) What systems or functions of the vehicle the update may affect;
    c) Which of these are type-approved (if any);
    Etc.
- Security – The vehicle manufacturer shall demonstrate the process they will use to ensure that software updates will be protected to reasonably prevent manipulation before the update process is initiated, etc.
- Additional requirements for software updates over-the-air:
  - The vehicle manufacturer shall demonstrate the process and procedures they will use to assess that over-the-air updates will not impact safety, if conducted during driving.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

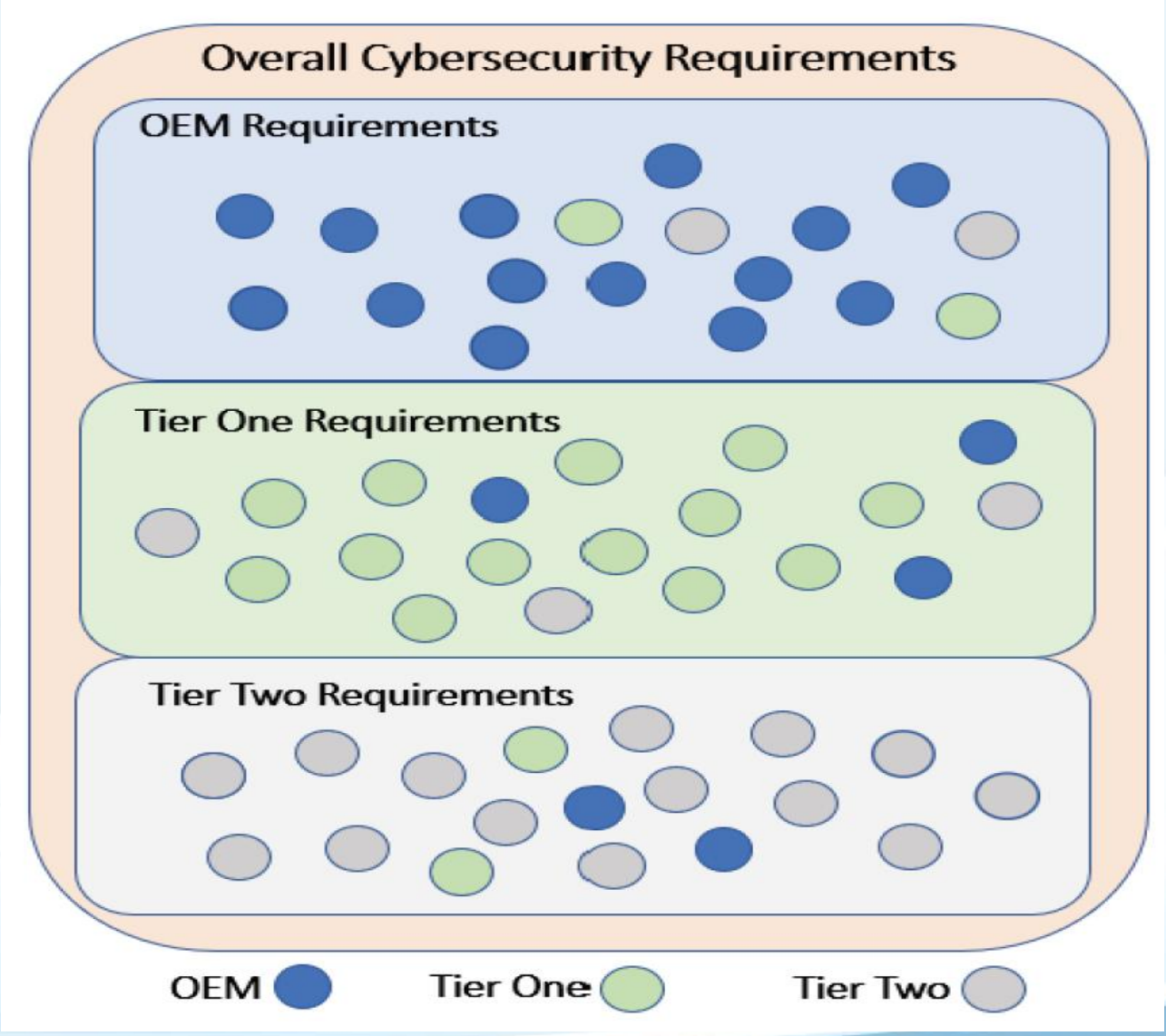
Cybersecurity Strategy

Given the current automotive related standards landscape, having a sound strategy is beneficial.

- The strategy depends on the type of organization (OEM, Tier 1, or Tier 2).
- Strategy for a Tier 1 organization:
  - Determine the requirements for your product portfolio;
  - Determine applicable standards, guidelines, and regulations;
  - Perform a gap analysis;
  - Partner to fill any gaps;
  - Determine requirements arising from:
    - OEMs,
    - Internal company,
    - Applicable standards, guidelines, and regulations;
  - Implement requirements.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Strategy



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Cybersecurity Strategy

Appropriateness of Standards for Each Supply Chain Organization

Organization	Appropriate Standards to be Implemented
OEM	ISO/SAE 21434, WP.29, ISO/IEC 27001, OWASP, NCSC
Tier 1	ISO/SAE 21434, WP.29, Uptane, ISO/IEC 27001, OWASP, NCSC
Tier 2	ISO/SAE 21434, WP.29, SAE J3101, SAE J3138, Uptane

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 8: Implementing Automotive Cybersecurity — What We Covered

Competency 09: Develop a Plan to Implement Automotive Cybersecurity

- Learning Objective 16: Develop a plan to implement automotive cybersecurity for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 9

ISO/SAE 21434 Implementation Strategy



Chapter 9: ISO/SAE 21434 Implementation Strategy — What We Will Cover

Competency 10: Develop a Plan to Implement ISO/SAE 21434 for a Typical Project

- Learning Objective 17: Develop a plan to implement ISO/SAE 21434 for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Conduct a Gap Analysis

- Assess organizational processes, work products of an product, and DIA
- Identify major and minor areas that do not meet ISO/SAE 21434 requirements
- Sample projects to identify gaps between CAL3 and CAL4 to current processes
  - Hypothesize the CAL level of products for the gap
- Identify areas that require overall improvements
  - ***What practices are good for the entire business and not only for E/E Cybersecurity Characteristics?***
- Develop implementation plans
- Assign organizational responsibilities

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Create an Implementation Team

- **Project Manager:** Responsible for the ISO/SAE 21434 implementation
- **Cross Functional Team:** Players from Design, Testing, Manufacturing, Suppliers, Lab, Others
- **Process Teams:** Process Development
- Sponsor(s)

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Choose a Pilot Project

- Pilot a product for Threat Analysis, Technical cybersecurity Concepts, including DIA, and implement it in Operations
- Understand and develop integration with APQP processes
- Create plan to transition all cybersecurity related products to Integrated APQP and Cybersecurity Plan
- Train Project Managers, Design and Engineering teams

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Set Strategy for ISO/SAE 21434 Implementation

- What Products?
- Product and Process Families?
- Which Customers?
- Risk mitigation and cybersecurity controls strategy
- Identify which practices need improvement
- Integrate ISO/SAE 21434 to the Business Management System, i.e., integrated system

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

List of Automotive Cybersecurity Controls

Cybersecurity Controls	Comments
Domain Separation	Separation of similar and dissimilar in-vehicle networks.
PKI	The PKI infrastructure support could happen at various levels: specific vehicle, vehicle model or organizational.
Hardware Trust Anchor and/or HSM	Semiconductor manufacturers are beginning to incorporate HW trust anchors in automotive microcontrollers.
AUTOSAR	AUTOSAR security services need to be mapped to actual MCU services in a specific microcontroller.
Signed SW Updates (secure OTA)	Authenticated OTA updates are beginning to be common.
Secure Diagnostic Services (OBD-II)	Together with the CAN protocol, OBD-II and associated protocols are inherently unsecure. This is beginning to change.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

List of Automotive Cybersecurity Controls

Cybersecurity Controls	Comments
Secure and Authenticated Boot	Booting an automotive MCU (or ECU) is perhaps the most critical step from the viewpoint of security.
Secure Communications with Backend	There is commonalities between this automotive control with that used in EIT and other industrial areas.
Secure In-Vehicle Communications	Solutions are beginning to appear to add security features to the CAN protocol which is inherently unsafe and unsecure.
Firewalls	Firewall filters are highly dependent on the details of automotive applications.
IDS/IPS	Lessons learned from IDS/IPS from EIT and other industrial areas are beginning to be incorporated in automotive cybersecurity.
Wi-Fi/Bluetooth Security	Wi-Fi and Bluetooth are only two examples of a wide range of in-vehicle RF communication technologies.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

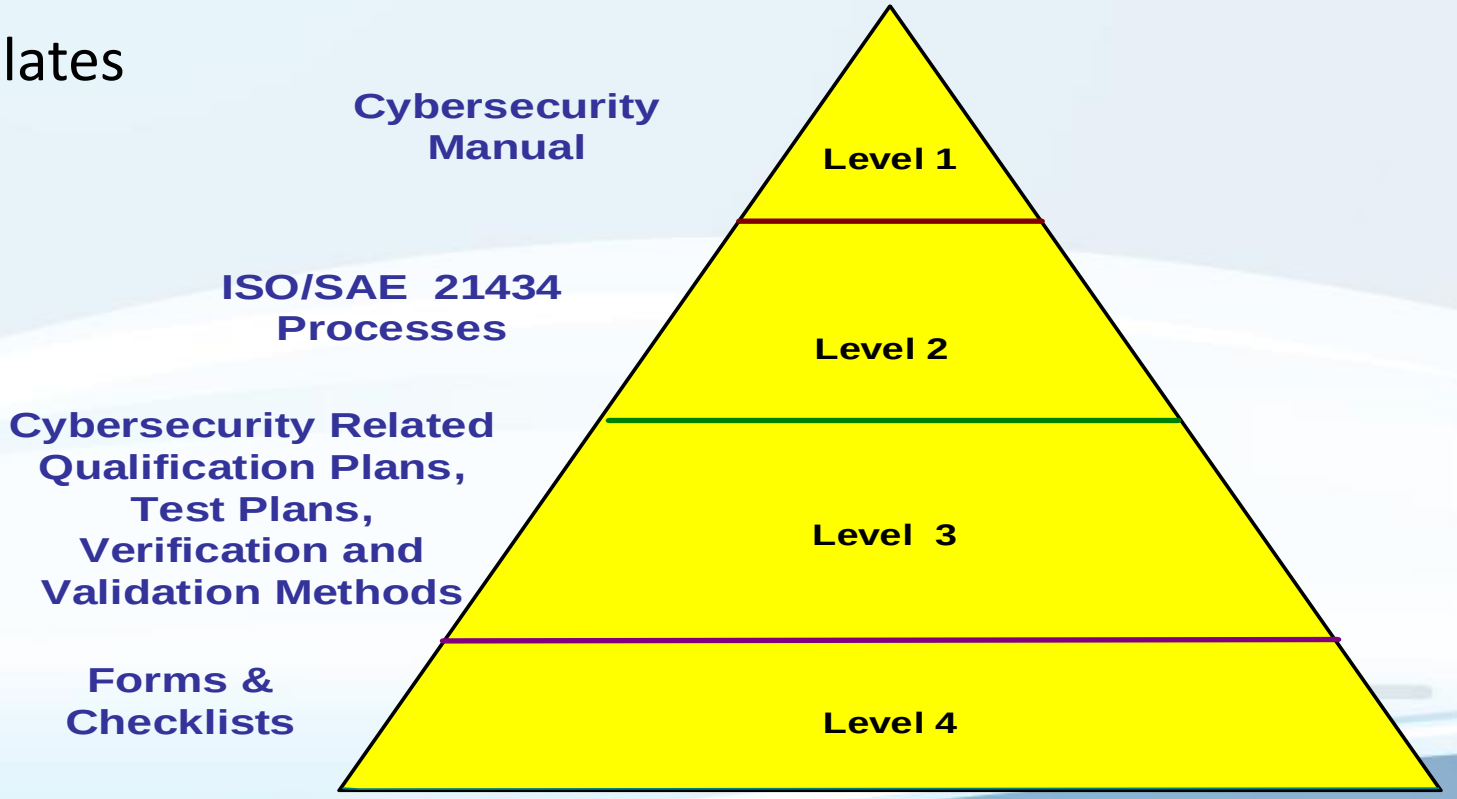
Developing Documentation

Level I – Cybersecurity Manual

Level II – Processes for Cybersecurity

Level III – Work Instructions and Templates

Level IV – Forms and Checklists



Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Develop Implementation Plan

Month	1	2	3	4	5	6
GAP Analysis	X					
Form Implementation Team	X					
Conduct Training	X					
Cybersecurity Manual		X				
Process Documentation		X	X	X		
Threat Analysis		X	X	X		
Cybersecurity Concept		X	X	X	X	
Refined Cybersecurity Design		X	X	X	X	
Penetration Testing		X	X	X	X	

Note: This list is not exhaustive ….

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Conduct Roll Out

- Process Owners conduct training for those who work within the process
- Choose initial projects to initiate functional cybersecurity to transition organization
- Conduct internal assessments & audits and corrective actions

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Corrective Action and Change Management Process

- Integrate cybersecurity issues with the corrective action and change management process
- Corrective action for internal, supplier and external cybersecurity related issues
- Implement change management for external, internal, and supplier change process

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Conduct Assessments and Audits

- Decide on assessment and audit strategy
  - Internal or second or third party
- Conduct required internal assessments and audits and initiate corrective action
- Initiate supplier audits and corrective actions
- Complete the cybersecurity case
- Declare ISO/SAE 21434 conformance

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Chapter 9: ISO/SAE 21434 Implementation Strategy — What We Covered

Competency 10: Develop a Plan to Implement ISO/SAE 21434 for a Typical Project

- Learning Objective 17: Develop a plan to implement ISO/SAE 21434 for a typical project

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Thank You!

Questions?



info@omnex.com
734.761.4940

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Glossary

ISO/SAE 21434 – Clause 3



Vocabulary

Clause 3 provides definitions for the use of terms in the context of the ISO/SAE 21434 Standard.

The definitions for these terms can be different than the use of the same term at various companies – be clear on terms and definitions used internally and those in standards, understand differences.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.1
Architectural Design

- Representation that allows for identification of **components (3.1.7)**, their boundaries, interfaces and interactions.

3.1.2
Asset

- Object that has value, or contributes to value.

  Note 1 to entry: An asset has one or more **cybersecurity properties (3.1.20)** whose compromise can lead to one or more **damage scenarios (3.1.22)**.

3.1.3
Attack Feasibility

- Attribute of an **attack path (3.1.4)** describing the ease of successfully carrying out the corresponding set of actions.

3.1.4
Attack Path

- Set of deliberate actions to realize a **threat scenario (3.1.33)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.5
Attacker

- Person, group, or organization that carries out an **attack path (3.1.4)**.

3.1.6
Audit

- Examination of a process to determine the extent to which the process objectives are achieved.

3.1.7
Component

- Part that is logically and technically separable.

3.1.8
Customer

- Person or organization that receives a service or product.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.9
Cybersecurity

- Road vehicle cybersecurity
- Condition in which **assets (3.1.2)** are sufficiently protected against **threat scenarios (3.1.33)** to **items (3.1.25)** of road vehicles, their functions and their electrical or electronic **components (3.1.7)**.

3.1.10
Cybersecurity Assessment

- Judgment of **cybersecurity (3.1.9)**.

3.1.11
Cybersecurity Case

- Structured argument supported by evidence to state that **risks (3.1.29)** are not unreasonable.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.12
Cybersecurity Claim

- Statement about a **risk (3.1.29)**.

  Note 1 to entry: The cybersecurity claim can include a justification for retaining or sharing the risk.

3.1.13
Cybersecurity Concept

- Cybersecurity requirements of the **item (3.1.25)** and requirements on the **operational environment (3.1.26)**, with associated information on **cybersecurity controls (3.1.14)**.

3.1.14
Cybersecurity Control

- Measure that is modifying **risk (3.1.29)**.

3.1.15
Cybersecurity Event

- **Cybersecurity information (3.1.18)** that is relevant for an **item (3.1.25)** or **component (3.1.7)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.16
Cybersecurity Goal

- Concept Level cybersecurity requirement associated with one or more **threat scenarios (3.1.33)**.

3.1.17
Cybersecurity Incident

- Situation in the field that can involve **vulnerability (3.1.38)** exploitation.

3.1.18
Cybersecurity Information

- Information with regard to **cybersecurity (3.1.9)** for which relevance is not yet determined.

3.1.19
Cybersecurity Interface Agreement

- Agreement between **customer (3.1.8)** and supplier concerning **distributed cybersecurity activities (3.1.23)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.20
Cybersecurity Property

- Attribute that can be worth protecting.

3.1.21
Cybersecurity Specification

- Cybersecurity requirements and corresponding **architectural design (3.1.1)**.

3.1.22
Damage Scenario

- Adverse consequence involving a vehicle or vehicle function and affecting a **road user (3.1.31)**.

3.1.23
Distributed Cybersecurity Activities

- Cybersecurity activities for the **item (3.1.25)** or **component (3.1.7)** whose responsibilities are distributed between **customer (3.1.8)** and supplier.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.24
Impact

- Estimate of magnitude of damage or physical harm from a **damage scenario (3.1.22)**.

3.1.25
Item

- **Component** or set of **components (3.1.7)** that implements a function at the Vehicle Level.

  Note 1 to entry: A system can be an item if it implements a function at the Vehicle Level, otherwise it is a component.

3.1.26
Operational Environment

- Context considering interactions in operational use.

3.1.27

Out-of-context

- Not developed in the context of a specific **item (3.1.25)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.28
Penetration Testing

- Cybersecurity testing in which real-world attacks are mimicked to identify ways to compromise **cybersecurity goals (3.1.16)**.

3.1.29
Risk

- Cybersecurity risk
- Effect of uncertainty on **road vehicle cybersecurity (3.1.9)** expressed in terms of **attack feasibility (3.1.3)** and **impact (3.1.24)**.

3.1.30
Risk Management

- Coordinated activities to direct and control an organization with regard to **risk (3.1.29)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.31
Road User

- Person who uses a road.

  EXAMPLE: Passenger, pedestrian, cyclist, motorist, or vehicle owner.

3.1.32
Tailor

- To omit or perform an activity in a different manner compared to its description in ISO/SAE 21434.

3.1.33
Threat Scenario

- Potential cause of compromise of **cybersecurity properties (3.1.20)** of one or more **assets (3.1.2)** in order to realize a **damage scenario (3.1.22)**.

3.1.34
Triage

- Analysis to determine the relevance of **cybersecurity information (3.1.18)** to an **item (3.1.25)** or **component (3.1.7)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.35
Trigger

- Criterion for **triage (3.1.34)**.

3.1.36
Validation

- Confirmation, through the provision of objective evidence, that the **cybersecurity goals (3.1.16)** of the **item (3.1.25)** are adequate and are achieved.

3.1.37
Verification

- Confirmation, through the provision of objective evidence, that specified requirements have been fulfilled.

3.1.38
Vulnerability

- **Weakness (3.1.40)** that can be exploited as part of an **attack path (3.1.4)**.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Vocabulary

3.1.39
Vulnerability Analysis

- Systematic identification and evaluation of **vulnerabilities (3.1.38)**.

3.1.40
Weakness

- Defect or characteristic that can lead to undesirable behavior.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ANNEX A

ISO/SAE 21434 WORK PRODUCTS



ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Organizational Cybersecurity Management	
5.4.1 Cybersecurity Governance	[WP-05-01] Cybersecurity policy, rules and processes
5.4.2 Cybersecurity Culture	[WP-05-01] Cybersecurity policy, rules and processes [WP-05-02] Evidence of competence management, awareness management and continuous improvement
5.4.3 Information Sharing	[WP-05-01] Cybersecurity policy, rules and processes
5.4.4 Management Systems	[WP-05-03] Evidence of the organization's management systems
5.4.5 Tool Management	[WP-05-04] Evidence of tool management
5.4.6 Information Security Management	[WP-05-03] Evidence of the organization's management systems
5.4.7 Organizational Cybersecurity Audit	[WP-05-05] Organizational cybersecurity audit report

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Project-dependent Cybersecurity Management	
6.4.1 Cybersecurity Responsibilities	[WP-06-01] Cybersecurity plan
6.4.2 Cybersecurity Planning	[WP-06-01] Cybersecurity plan
6.4.3 Tailoring	[WP-06-01] Cybersecurity plan
6.4.4 Reuse	[WP-06-01] Cybersecurity plan
6.4.5 Component-out-of-Context	[WP-06-01] Cybersecurity plan
6.4.6 Off-the-Shelf Component	[WP-06-01] Cybersecurity plan
6.4.7 Cybersecurity Case	[WP-06-02] Cybersecurity case
6.4.8 Cybersecurity Assessment	[WP-06-03] Cybersecurity assessment report
6.4.9 Release for Post-Development	[WP-06-04] Release for post-development report

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Distributed Cybersecurity Activities	
7.4.1 Supplier Capability	None
7.4.2 Request for Quotation	None
7.4.3 Alignment of Responsibilities	[WP-07-01] Cybersecurity interface agreement

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Continual Cybersecurity Activities	
8.3 Cybersecurity Monitoring	[WP-08-01] Sources for cybersecurity information [WP-08-02] Triggers [WP-08-03] Cybersecurity events
8.4 Cybersecurity Event Evaluation	[WP-08-04] Weaknesses from cybersecurity events
8.5 Vulnerability Analysis	[WP-08-05] Vulnerability analysis
8.6 Vulnerability Management	WP-08-06] Evidence of managed vulnerabilities

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Concept Phase	
9.3 Item Definition	[WP-09-01] Item definition
9.4 Cybersecurity Goals	[WP-09-02] TARA [WP-09-03] Cybersecurity goals [WP-09-04] Cybersecurity claims [WP-09-05] Verification report for cybersecurity goals
9.5 Cybersecurity Concept	[WP-09-06] Cybersecurity concept [WP-09-07] Verification report of cybersecurity concept

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Product Development Phase	
10.4.1 Design	[WP-10-01] Cybersecurity specifications [WP-10-02] Cybersecurity requirements for post-development [WP-10-03] Documentation of modeling, design or programming languages and coding guidelines [WP-10-04] Verification report for cybersecurity specifications [WP-10-05] Weaknesses found during product development
10.4.2 Integration and Verification	[WP-10-05] Weaknesses found during product development [WP-10-06] Integration and verification specification [WP-10-07] Integration and verification report
Clause 11 Cybersecurity Validation	[WP-11-01] Validation report

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Post-Development Phases	
Clause 12 Production	[WP-12-01] Production control plan
13.3 Cybersecurity Incident Response	[WP-13-01] Cybersecurity incident response plan
13.4 Updates	None
14.3 End of Cybersecurity Support	[WP-14-01] Procedures to communicate the end of cybersecurity support
14.4 Decommissioning	None

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ISO/SAE 21434 Work Products (Annex A)

Sub-clause	Work Products
Threat Analysis and Risk Assessment Methods	
15.3 Asset Identification	[WP-15-01] Damage scenarios [WP-15-02] Assets and cybersecurity properties
15.4 Threat Scenario Identification	[WP-15-03] Threat scenarios
15.5 Impact Rating	[WP-15-04] Impact rating with associated impact categories
15.6 Attack Path Analysis	[WP-15-05] Attack paths
15.7 Attack Feasibility Rating	[WP-15-06] Attack feasibility rating
15.8 Risk Value Determination	[WP-15-07] Risk value
15.9 Risk Treatment Decision	[WP-15-08] Risk treatment decisions

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

ANNEX B

AUTOMOTIVE CYBERSECURITY CONTROLS



OMNEX

Automotive Cybersecurity Controls (Annex B)

Cybersecurity Controls	Brief Description
Domain Separation	Separation of similar and dissimilar in-vehicle networks.
PKI	The PKI infrastructure support could happen at various levels: specific vehicle, vehicle model or organizational.
Hardware Trust Anchor and/or HSM	Semiconductor manufacturers are beginning to incorporate HW trust anchors in automotive microcontrollers.
AUTOSAR	AUTOSAR security services needs to be mapped to actual MCU services in a specific microcontroller.
Signed SW Updates (secure OTA)	Authenticated OTA updates are beginning to be common.
Secure Diagnostic Services (OBD-II)	Together with the CAN protocol, OBD-II and associated protocols are inherently unsecure. This is beginning to change
Secure and Authenticated Boot	Booting an automotive MCU (or ECU) is perhaps the most critical step from the viewpoint of security.
Secure Communications with Backend	There are commonalities between this automotive control with that used in EIT and other industrial areas.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET

Automotive Cybersecurity Controls (Annex B)

Cybersecurity Controls	Brief Description
Secure In-Vehicle Communications	Solutions are beginning to appear to add security features to the CAN protocol, which is inherently unsafe and unsecure.
Firewalls	Firewall filters are highly dependent on the details of automotive applications.
IDS/IPS	Lessons learned from IDS/IPS from EIT and other industrial areas are beginning to be incorporated in automotive cybersecurity.
Wi-Fi / Bluetooth Security	Wi-Fi and Bluetooth are only two examples of a wide range of in-vehicle RF communication technologies.

Copyright © 2022 Omnex, Inc. All Rights Reserved. Reprinted under License by OET